

A Trusted ^{Authorisation}~~Authorization~~ Framework for Multi-Party Patient Consent in Healthcare Data Sharing

Principal Supervisor: Professor Farookh Hussain

Co-Supervisor: Dr. Firas Al-Doghman

Presenter: Yasir Dhaifallah O Alyoubi

Student ID: 24724078

August 2026

Contents

1	Introduction	4
1.1	Research Context	4
1.2	Problem Statement	5
1.3	Research Motivation	6
2	Systematic Literature Review	9
2.1	Overview	9
2.2	Systematic Literature Review Methodology	9
2.2.1	Review Design and Reporting Framework	10
2.2.2	Questions for Review	10
2.2.3	Search Databases and Search Strategy	10
2.2.4	Search Period and Search Execution	11
2.2.5	Eligibility Criteria	12
2.2.6	Screening and Study Selection	13
2.2.7	Data Extraction and Synthesis	13
2.3	Review	14
2.3.1	Healthcare Consent and Decentralised Data Governance	14
2.3.2	Blockchain-Based Consent and Data Governance	15
2.3.3	Decentralised Identity and Verifiable Credentials	16
2.3.4	Multi-Party Authorisation and Collaborative Consent	17
2.3.5	Policy-Based and Context-Aware Access Control	17
2.3.6	Trusted Computing, Secure Execution, and Security Assurance	18
2.3.7	Comparative Analysis of Existing Approaches	19
2.4	Synthesis and Research Gap	20

3	Research Gaps and Questions	21
3.1	Research Gap	21
3.2	Main Research Question	23
3.3	Sub-Research Questions	23
3.3.1	SRQ1: Trust-Centric Consent Modelling	24
3.3.2	SRQ2: Decentralised Identity and Authority Trust	24
3.3.3	SRQ3: Trustworthy Multi-Party Authorisation	25
3.3.4	SRQ4: Policy- and Context-Aware Access Control	25
3.3.5	SRQ5: Temporal and Lifecycle Trust	26
3.3.6	SRQ6: Formal Security Assurance and Empirical Validation	26
3.4	Research Questions as an Integrated Research Problem	28
4	Research Objectives	29
4.1	RO1 - Trust-Centric Consent Model	29
4.2	RO2 - Decentralised Identity and Authority Trust	30
4.3	RO3 - Trustworthy Multi-Party Authorisation	30
4.4	RO4 - Policy- and Context-Aware Access Control	30
4.5	RO5 - Temporal and Lifecycle Trust	30
4.6	RO6 - Formal Security Assurance and Empirical Validation	31
4.7	Relationship Between Research Questions and Objectives	31
5	Research Architecture: MVC	34
5.1	MVC Layered Architecture and Component Decomposition	35
5.1.1	MVC Component Decomposition	36
5.1.2	Trust Evaluation Across the MVC Layers	37
5.1.3	Relationship Between MVC Layers and Research Questions	39
5.1.4	Architectural Boundary and Trust Assumptions	39
5.2	Trust-Oriented Consent Authorization ^{Authorisation} Workflow	40
5.3	Model: Trust-Aware Consent and Authorisation Representation	42
5.4	View: Controlled Interaction Among Independent Participants	44
5.5	Controller: Trusted Multi-Party Authorisation Enforcement	44
5.6	Multi-Party Consent as Distributed Trust Establishment	46
5.7	Policy-Aware Consent Enforcement	46
5.8	Authorisation Evidence and Auditability	47
5.9	Architectural Security Properties	47
5.10	MVC Architecture and the Research Objectives	48
5.11	Architectural Contribution and Scope	48
6	Proposed Solution	51
6.1	Trust-Centric Consent Model for RO1	51
6.1.1	RO1 Consent Creation Workflow	51
6.1.2	Procedure for Trust-Aware Consent Creation	53
6.1.3	Algorithm 1: Trust-Aware Consent Creation	55
6.2	Decentralised Identity and Authority Trust for RO2	55
6.2.1	RO2 Identity and Authority Verification Workflow	56
6.2.2	Procedure for DID and VC Identity and Authority Verification	56
6.2.3	Algorithm 2: DID and VC Identity and Authority Verification	59

TOC: regenerate after edits. New: \$1.1 'Australian regulatory context', \$2.2.8 Quality Assessment, \$7.7 Prototype Evidence, \$7.8 Limitations. Move \$6.4.2 to \$6.5.2. Remove 'Figure 4'.

6.3	Trustworthy Multi-Party Authorisation for RO3	61
6.3.1	RO3 Multi-Party Authorisation Workflow	61
6.3.2	Procedure for Threshold-Based Multi-Party Authorisation	61
6.3.3	Algorithm 3: Threshold-Based Multi-Party Authorisation	65
6.4	Policy- and Context-Aware Access Control for RO4	67
6.4.1	RO4 Policy-Aware Access Workflow	67
6.4.2	Procedure for Temporal and Lifecycle Validation	69
6.4.3	Algorithm 4: Policy-Aware Access Decision	72
6.4.4	Procedure for Policy-Aware Access Decision	73
6.5	Temporal and Lifecycle Trust for RO5	76
6.5.1	RO5 Temporal and Lifecycle Workflow	77
6.5.2	Algorithm 5: Temporal and Lifecycle Validation	77
6.6	Formal Security Assurance and Empirical Validation for RO6	79
6.6.1	RO6 Assurance and Validation Workflow	79
6.6.2	Procedure for Formal and Empirical Authorisation Validation	79
6.6.3	Algorithm 6: Formal and Empirical Authorisation Validation	86
6.7	Algorithms and the Research Objectives	86
7	Current Progress Status	87
7.1	Progress of RO1: Trust-Centric Consent Model	87
7.2	Progress of RO2: Decentralised Identity and Authority	88
7.3	Progress of RO3: Trustworthy Multi-Party Authorisation	88
7.4	Progress of RO4: Policy-Aware Access Control	89
7.5	Progress of RO5: Temporal and Lifecycle Trust	89
7.6	Progress of RO6: Security Assurance and Validation	89
8	Publications Summary	90
9	Research Plan	90
9.1	Current Stage: Completed and Current Work	91
9.2	Next Stage: Planned Work	91

1 Introduction

1.1 Research Context

The rapid digitalisation of contemporary society has created an increasing demand for secure, interoperable, and trustworthy data sharing across organisational and institutional boundaries. Modern digital ecosystems frequently involve multiple independent stakeholders, including individuals, healthcare providers, service organisations, regulatory authorities, researchers, and third-party data processors, who may need to exchange information while maintaining privacy, accountability, and control over how that information is used [6, 19]. Although digital transformation creates significant opportunities for collaboration and service innovation, it also introduces a fundamental governance challenge: how can data access be authorised and trusted when the participating entities do not belong to a single administrative or institutional domain?

Healthcare represents a particularly important and challenging example of this broader problem. The increasing digitisation and decentralisation of healthcare information enables patients, healthcare professionals, guardians, researchers, healthcare organisations, and other authorised entities to participate in data-sharing processes [31, 14, 32]. At the same time, healthcare data is highly sensitive, heterogeneous, and often subject to strict privacy, ethical, and governance requirements. Its exchange therefore raises complex questions concerning identity, authority, patient consent, privacy protection, accountability, and fine-grained access control [24, 22, 12].

Traditional access-control architectures are commonly based on centralised identity providers, institution-specific authentication systems, and relatively static permission-management mechanisms [28, 25, 11]. These approaches can provide effective access control within a well-defined organisational boundary, but they become increasingly difficult to apply when authorisation decisions involve multiple independent entities operating across decentralised or cross-organisational environments. In such settings, no single participant may possess sufficient authority to determine access independently, and trust cannot necessarily be assumed on the basis of membership in a common administrative domain.

This problem is particularly relevant in healthcare, where data-sharing decisions may require the coordinated participation of patients, guardians, healthcare professionals, institutional authorities, and other authorised stakeholders [21, 9]. Similar challenges also arise in enterprise, financial, and other cross-organisational data-sharing environments, where a decision may depend on the joint approval of customers, service providers, compliance entities, or regulatory authorities. These scenarios demonstrate that authorisation is increasingly a distributed governance problem rather than simply a process of authenticating a user and checking a static permission.

Several emerging technologies provide important building blocks for addressing these challenges. Blockchain-based mechanisms can provide tamper-resistant recording and distributed auditability, while decentralised identifiers can support the identification of participants without relying exclusively on a central identity provider. Verifiable credentials can provide cryptographically verifiable evidence concerning roles, attributes, qualifications, or authority, and cryptographic and policy-based access-control mechanisms can restrict access to authorised resources [2, 7, 3]. More broadly, blockchain-based approaches have demonstrated the potential to improve the integrity, transparency, and traceability of decentralised data-management processes [8, 1].

However, the availability of these technologies does not, by itself, establish trustworthy authorisation. Blockchain can preserve evidence that a consent event or transaction has occurred, but the existence of an immutable record does not necessarily demonstrate that the participating entities were legitimate, that they possessed the required authority, that all necessary parties participated in the decision, or that a subsequent data-access request remains consistent with the conditions originally authorised. Similarly, a decentralised identity may establish who an entity is, while a verifiable credential may provide evidence concerning the entity's role or attributes, but neither mechanism independently determines whether access to a particular patient's data should be granted.

The fundamental challenge is therefore not simply how to record consent in a decentralised system. Rather, it is how to coordinate identity verification, authority evaluation, collective decision-making, policy enforcement, and auditable evidence so that a data-access decision can be regarded as trustworthy. This requires a transition from viewing consent as a static record of permission towards understanding consent as an active and evaluable component of a broader authorisation process.

1.2 Problem Statement

Existing consent-management and decentralised access-control approaches commonly represent authorisation through database records, access-control entries, smart contracts, or blockchain transactions. These mechanisms can improve record integrity, traceability, and auditability, but consent itself often remains a relatively passive artefact indicating that a permission or approval has been created. The relationship between the consent record, the identity of the participants, their authority to act, the required authorisation conditions, the applicable policy constraints, and the resulting access decision is frequently treated as a collection of separate technical concerns.

This creates a fundamental distinction between *consent representation* and *trustworthy authorisation enforcement*. A consent record can demonstrate that a decision has been created or recorded, but it does not necessarily establish why that decision should be trusted when it is subsequently exercised. Immutability protects the integrity of recorded information, but immutability alone does not verify the legitimacy of the entities that participated in the decision. Likewise, successful authentication establishes that an entity has been identified, but authentication does not automatically establish that the entity possesses the authority to access a particular patient's information.

The problem becomes more complex when healthcare data sharing requires the coordinated authorisation of multiple independent participants. A patient may initiate consent, while guardians, healthcare professionals, or institutional authorities may also need to participate in the authorisation process. In such circumstances, a valid access decision should not necessarily be generated by a single participant acting independently. Instead, the authorisation process may need to establish whether the required set of independently verified participants has satisfied a defined collective approval condition.

Even where identity and collective approval requirements have been satisfied, an access request may still be inappropriate if it exceeds the authorised purpose or data scope. For example, a healthcare professional may possess a valid identity and participate in a valid consent process while subsequently requesting information that was not included in the patient's original authorisation. Consequently, identity verification and multi-party approval alone are

Add new final paragraph of §1.1 (Australian regulatory context) - see A5.1.

► INSERT A5.1 (red page after p.5)

A5.1 - New final paragraph of §1.1 Research Context

Insert after '...an active and evaluable component of a broader authorisation process.' (end of §1.1)

Australian regulatory context. In Australia, health information is classified as sensitive information under the Privacy Act 1988 (Cth) [34]. Under the Australian Privacy Principles (APPs), sensitive information may generally be collected only with the individual's consent (APP 3), and may be used or disclosed only for the primary purpose of collection, or for a directly related secondary purpose that the individual would reasonably expect, unless another exception applies (APP 6). The My Health Records Act 2012 (Cth) [35] additionally allows consumers to control which healthcare provider organisations can access their record or particular documents, and the Healthcare Identifiers Act 2010 (Cth) [36] governs the national identifiers used for individuals (IHI), practitioners (HPI-I) and organisations (HPI-O). These instruments illustrate, in a concrete jurisdiction, the three conditions examined in this research: verified identity, patient-controlled authority over disclosure, and purpose- and scope-limited use. The HALAH prototype reflects this context through purpose-bound consent, module-level data scope and an explicit jurisdiction attribute (default 'AU').

insufficient to guarantee trustworthy access. The requested operation must also be evaluated against the policy constraints associated with the consent.

The central problem addressed by this research is therefore the absence of an integrated trust-oriented mechanism that connects these different conditions within a coherent authorisation decision. Existing approaches provide important technological components, including decentralised identity, verifiable credentials, blockchain-based records, multi-party approval mechanisms, and policy-based access control [20, 15]. However, these mechanisms are often investigated independently or integrated primarily at the implementation level without providing a unified Trust Computing model explaining how their combined operation establishes a trustworthy authorisation outcome.

Accordingly, the problem is not primarily whether consent can be stored securely or whether a blockchain transaction can be made immutable. The more fundamental problem is whether a system can determine that a particular data-access request has been generated under sufficient and verifiable trust conditions. This requires a framework capable of evaluating the legitimacy and authority of participating entities, determining whether the required collective authorisation has been established, and verifying that the requested operation remains consistent with the policy constraints defined by the consent.

The proposed research therefore addresses trustworthy authorisation as a coordinated security problem. The objective is to move beyond a model in which consent is primarily represented as a static permission and towards a model in which consent functions as a security-bearing authorisation object whose associated trust conditions can be explicitly represented and evaluated.

1.3 Research Motivation

The motivation of this research is to develop a Trust Computing perspective in which trustworthy healthcare data access emerges from the coordinated verification and enforcement of multiple security conditions. Under this perspective, trust is not treated as a property that is provided by blockchain, decentralised identity, or any other individual technology. Instead, trustworthy authorisation is understood as an emergent property of a decision process in which independently verifiable conditions must be satisfied.

This perspective requires a clear separation between several concepts that are often implicitly combined within conventional access-control systems. Identity concerns whether a participant can be reliably identified. Authority concerns whether that participant possesses the relevant role, capability, or permission to participate in a particular decision. Multi-party authorisation concerns whether all required independent participants have jointly established the authorisation condition. Policy compliance concerns whether the requested access is consistent with the authorised purpose and data scope. Together, these conditions provide the foundation for determining not only whether access has been requested, but whether the resulting authorisation decision has a sufficient basis to be trusted.

The proposed framework consequently conceptualises patient consent as more than a static permission or a historical blockchain record. Consent is instead treated as a structured and trust-aware authorisation object that connects the relevant participants, authority requirements, policy constraints, and evidence associated with an authorisation decision. This conceptualisation makes it possible to evaluate the relationship between the consent itself and a subsequent data-access request rather than assuming that the existence of a recorded consent

automatically justifies future access.

The current research concentrates on the foundational dimensions required to construct this trust-oriented authorisation model. The first focus is the development of a trust-centric consent representation capable of capturing the conditions associated with an authorisation decision. Building on this representation, the research investigates how decentralised identifiers and verifiable credentials can establish trustworthy participants while maintaining a clear conceptual separation between identity authentication and authorisation authority. The framework then extends individual trust to collective trust through a multi-party authorisation mechanism, ensuring that sensitive healthcare data access can require the coordinated approval of multiple independently verified participants. Finally, policy-aware access control is incorporated to ensure that a valid identity or sufficient set of approvals cannot be used to obtain information outside the purpose or data scope authorised by the patient.

Define once here: 'current stage' = Stage 1 (CA2: RO1-RO4); 'next stage' = Stage 2 (CA3: RO5-RO6). Use these two labels consistently.

These four dimensions collectively define the foundational scope of Multi-Party Patient Consent. Their significance lies in the fact that they address different but interdependent aspects of the same authorisation problem. A trustworthy consent model cannot operate effectively without reliable evidence concerning the identity and authority of its participants. Similarly, verified identities and collective approval do not guarantee trustworthy access unless the resulting request remains within the policy constraints associated with the consent. The Multi-Party Patient Consent research therefore investigates these mechanisms as coordinated conditions of a unified authorisation model rather than as independent security features.

~~The subsequent next stage research~~ will extend this foundation towards dynamic trust management and stronger security assurance. In particular, the framework will be expanded to investigate temporal validity and lifecycle trust, including the effects of validity periods, expiration, revocation, and controlled state transitions on the continuing legitimacy of an authorisation decision. This extension is important because trust cannot be regarded as permanently established at the moment a consent is created. A consent that was valid when initially approved may subsequently become invalid due to expiration, revocation, or a change in its authorised lifecycle state.

Replace with: 'The next-stage (CA3) research'

~~next stage will also investigate~~ formal security assurance and comprehensive empirical validation. Formal analysis will be used to define the security properties expected from the proposed trust-oriented authorisation model and to reason about whether unauthorised entities or invalid authorisation conditions can produce an apparently valid access decision under defined assumptions. This will be complemented by adversarial and negative testing, as well as comprehensive empirical evaluation using the HALAH prototype and representative healthcare data-sharing scenarios. The objective is not simply to demonstrate that the prototype can execute successful workflows, but to determine whether the implementation consistently allows access when the required trust conditions are satisfied and rejects access when those conditions are violated. The distinction between the current contribution and the subsequent research is summarised in Table 1.

Replace with: 'The next stage will also investigate'

This separation establishes a clear progression between the current and subsequent stages of the research. ~~current research is concerned~~ primarily with establishing the conceptual and technical foundations through which trustworthy multi-party authorisation can be constructed. Next stage will build upon these foundations by investigating how authorisation trust can be maintained dynamically over time, formally reasoned about under defined security assumptions, and comprehensively validated through prototype-based experimentation.

Replace with: 'The current research is concerned'

Ultimately, the research is motivated by the argument that trustworthy healthcare data

Table 1: Research Scope and Progression

Stage	Research Dimension	Purpose and Core Objective
Current	RO1: Trust-Centric Consent Modelling	Develop a structured and evaluable representation of patient consent as a trust-aware authorisation object that explicitly connects identity, authority requirements, policy constraints, and authorisation evidence.
Current	RO2: Decentralised Identity and Authority Trust	Establish trustworthy participants using decentralised identifiers and verifiable credentials while explicitly separating identity authentication from authorisation authority.
Current	RO3: Trustworthy Multi-Party Authorisation	Establish collective trust by requiring multiple independently verified participants to satisfy predefined authorisation conditions before sensitive healthcare data access can be granted.
Current	RO4: Policy- and Context-Aware Authorisation	Ensure that authorised access remains consistent with the purpose, policy, and healthcare data scope specified by the consent, preventing valid identities and approvals from being used to obtain data beyond the authorised constraints.
Next	RO5: Temporal and Lifecycle Trust	Extend the authorisation model with validity periods, expiration, revocation, and controlled consent-state transitions to support dynamic and lifecycle-aware trust evaluation.
Next	RO6: Formal Security Assurance and Empirical Validation	Formally define and analyse the security and authorisation properties of the proposed framework and empirically evaluate the complete HALAH implementation using representative healthcare data-sharing, negative, and adversarial scenarios.

sharing cannot be guaranteed by a single technological mechanism. Blockchain can provide tamper-resistant evidence, decentralised identity can establish participant identity, verifiable credentials can provide evidence of authority, and policy mechanisms can constrain access. However, the security value of these mechanisms depends on how they are coordinated within the authorisation process. The proposed research therefore seeks to provide a Trust Computing framework in which these independently verifiable conditions contribute collectively to a defensible and explainable decision about whether a particular healthcare data-access request should be permitted.

2 Systematic Literature Review

2.1 Overview

The systematic literature review examines the current state of research on trustworthy and decentralised data sharing, with particular attention to healthcare consent management, multi-party trust data governance, decentralised identity, verifiable credentials, multi-party authorisation, policy-based access control, and Trusted Computing. The objective of the review is not simply to identify technologies that can be applied to healthcare data sharing, but to examine how existing approaches address different conditions required for a trustworthy authorisation decision and where conceptual or architectural gaps remain.

The reviewed literature demonstrates that substantial progress has been made in individual areas. Healthcare research has emphasised the importance of patient autonomy, privacy, informed consent, and controlled data sharing [31, 14, 24, 22, 12]. Multi-party trust research has investigated immutable data governance, distributed auditability, and decentralised consent management [2, 7, 3, 30, 26]. Research on decentralised identity and verifiable credentials has developed mechanisms for self-controlled identity representation, credential verification, selective disclosure, and privacy-preserving authentication [20, 33, 4, 16, 5, 27]. Access-control research has further investigated role-based, attribute-based, risk-aware, and usage-control approaches for protecting sensitive healthcare information [32, 11, 28, 25].

However, the literature also indicates that these mechanisms are commonly developed and evaluated as separate technological components. This fragmentation creates an important distinction between the availability of security mechanisms and the ability to construct a unified and trustworthy authorisation decision. The following sections analyse these research areas and identify the gap addressed by the proposed framework.

2.2 Systematic Literature Review Methodology

~~Based on the provided list of 33 references (spanning years 2022 to 2026, with a focus on blockchain, decentralized identity, verifiable credentials, healthcare access control, and consent management), the text has been adjusted to accurately reflect this contemporary literature corpus.~~

~~Specifically, references [1, 2, 3, 7, 9, 11, 12, 13, 14, 21, 22, 24, 28, 31, 32] anchor the healthcare data sharing, consent, and access control aspects, while [4, 5, 10, 15, 16, 20, 23, 25, 27, 33] support the decentralized identifiers (DIDs), verifiable credentials (VCs), and trust architecture dimensions. Furthermore, the final inclusion count in the screening section has been aligned with the scope of the provided bibliography.~~

DELETE. This is editing residue and signals that the review was fitted to an existing reference list. Replace with A9.1.

► INSERT A9.1
(red page after
p.9)

A9.1 - Replacement opening paragraph of §2.2

Replaces the two struck paragraphs under the heading '2.2 Systematic Literature Review Methodology'

This review followed the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA 2020) reporting guideline [37]. It covers peer-reviewed literature published between 2022 and 2026 on healthcare consent management, decentralised identity and verifiable credentials, multi-party authorisation and policy-aware access control. The review questions, search strategy, eligibility criteria, screening, quality assessment and data extraction are described in Sections 2.2.1–2.2.8, and the resulting study selection is summarised in Figure 2.

2.2.1 Review Design and Reporting Framework

A systematic literature review (SLR) was conducted to identify, classify, and critically evaluate existing research on multi-party healthcare data sharing, patient consent management, ~~decentralized~~^{decentralised} identity, privacy-preserving access control, and auditability. The review was designed to establish the conceptual and technical foundations of the research and thus proposed framework, as well as to identify the limitations of existing approaches that motivate the research questions of this study. In particular, the review considered not only the use of multi-party trust management for healthcare data management, but also the relationship between consent specification, identity verification, ~~authorization~~^{authorisation} enforcement, privacy preservation, and auditable data access.

The review process was structured according to the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA) framework. PRISMA was adopted to improve the transparency, reproducibility, and traceability of the literature identification and selection process. The review consisted of four principal stages including identification, screening, eligibility assessment, and inclusion. The reporting of these stages was complemented by a predefined search strategy, explicit inclusion and exclusion criteria, and a quality assessment procedure.

The quality assessment is claimed but never described – see new §2.2.8 (A13.1).

2.2.2 Questions for Review

This systematic literature review (SLR) is guided by the following questions

1. What multi-party trust approaches have been proposed for healthcare data sharing and patient consent management?
2. How do existing approaches represent, verify, and enforce patient consent and data access permissions?
3. What mechanisms are used to support ~~decentralized~~^{decentralised} identity, verifiable credentials, and authentication in healthcare data ecosystems?
4. How do existing systems address privacy preservation, selective disclosure, interoperability, and auditability?
5. What limitations remain regarding the integration of consent management, identity verification, access control, and auditable healthcare data sharing?

These questions were formulated to ensure that the review remained directly aligned with the technical objectives of the proposed system. The review therefore focused on the relationship between the individual security and privacy mechanisms rather than treating multi-party trust, identity, consent, and access control as isolated technologies.

2.2.3 Search Databases and Search Strategy

The literature search was conducted using the following academic databases including 1) IEEE Xplore, 2) ACM Digital Library, 3) ScienceDirect, 4) SpringerLink, 5) PubMed, 6) Scopus; and 7) Web of Science.

These databases were selected because they provide complementary coverage of computer science, cybersecurity, healthcare informatics, distributed systems, and information management research. IEEE Xplore and ACM Digital Library were used to identify studies on multi-party trust architectures, cryptographic mechanisms, ~~decentralized~~^{decentralised} identity, and access control. ScienceDirect and SpringerLink were used to identify research on healthcare information systems, privacy, interoperability, and data governance. PubMed was included to capture healthcare-oriented studies concerning patient consent, health information exchange, and clinical data sharing. Scopus and Web of Science were used to improve the coverage of multidisciplinary studies and to support the identification of relevant review articles.

The search was conducted using combinations of keywords related to the principal concepts of the review. The search strings were constructed using Boolean operators and were adapted to the syntax requirements of each database. The principal search concepts were multi-party trust, healthcare data, patient consent, ~~decentralized~~^{decentralised} identity, access control, privacy, and auditability. The general search string was defined as shown in Figure 1.

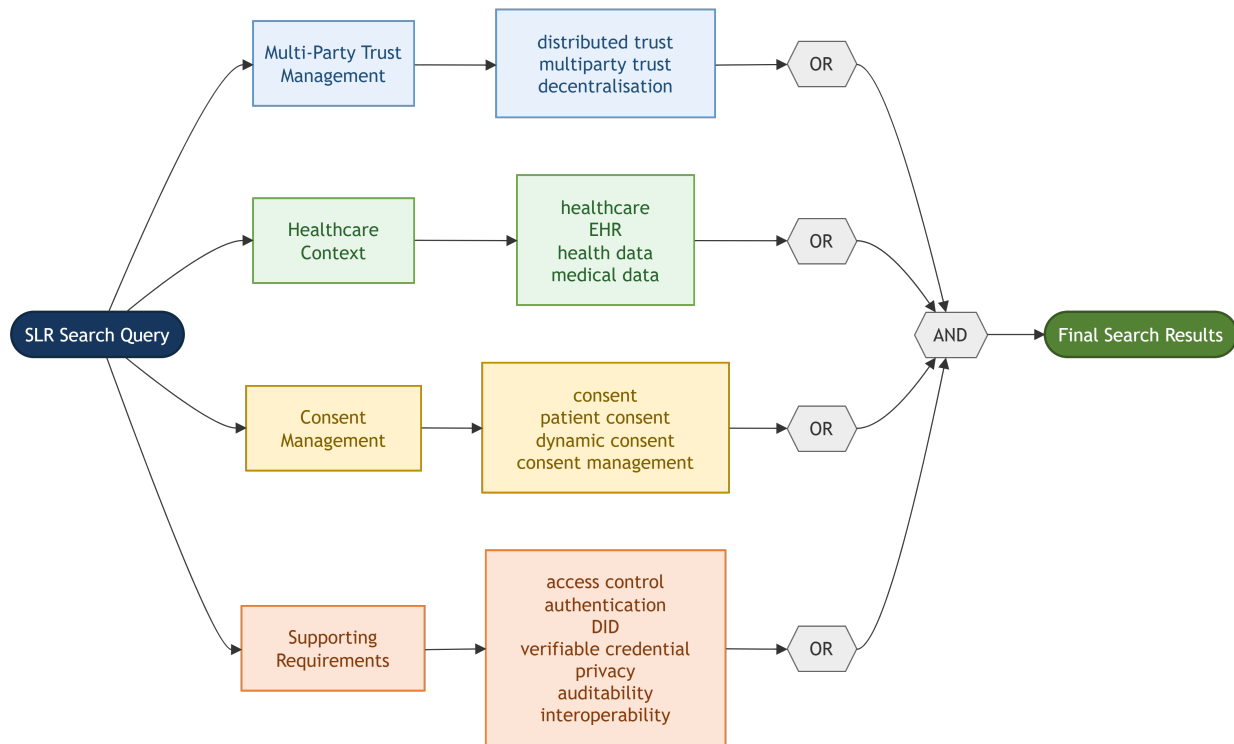


Figure 1: SLR Search String Definition

2.2.4 Search Period and Search Execution

The search was restricted to studies published between **2022** and **2026**. The search was performed in August 2026. The search period was selected to capture the rapid development of multi-party trust healthcare data management, ~~decentralized~~^{decentralised} identity, and consent-aware access control while maintaining a sufficiently contemporary evidence base. Earlier foundational studies were retained when they provided critical contributions to the technical or conceptual development of the reviewed approaches.

Give the exact final search date, e.g. '[dd] August 2026'.

The search results from all databases were exported into a reference management system. Duplicate records were identified using bibliographic metadata, including title, author, DOI, and publication year. Where duplicate records were identified, the most complete bibliographic record was retained for subsequent screening.

2.2.5 Eligibility Criteria

The eligibility criteria were defined before the screening process to ensure consistency in the selection of studies. The criteria were designed to identify research that was directly relevant to the objectives of the SLR.

A study was included if it satisfied the following criteria

1. The study was published as a peer-reviewed journal article, conference paper, or systematic review relevant to the research questions.
2. The study addressed healthcare data sharing, electronic health records, patient consent, healthcare access control, ^{decentralised}~~decentralized~~ identity, privacy preservation, or a closely related topic.
3. The study proposed, implemented, evaluated, or critically reviewed a technical, architectural, conceptual, or governance-oriented approach relevant to the research questions.
4. The study provided sufficient methodological or conceptual information to support the extraction of relevant findings.
5. The full text was available for inspection.
6. The publication language was English.

Studies were excluded if they satisfied one or more of the following conditions

1. The study was unrelated to healthcare data sharing, patient consent, identity management, access control, privacy, or auditability.
2. The study was a duplicate of another retrieved record.
3. The study was a short abstract, editorial, opinion article, thesis, book chapter, or non-peer-reviewed publication without sufficient methodological detail, unless it provided a necessary foundational contribution.
4. The study did not provide sufficient information to evaluate its contribution to the research questions.
5. The full text was unavailable.
6. The study focused exclusively on a technical problem that was outside the scope of healthcare data management and did not provide transferable insights relevant to the review.

The inclusion and exclusion criteria were applied consistently throughout the screening process. Where a study addressed multiple topics, its eligibility was determined according to the relevance of its contribution to the research questions rather than by the presence of a single keyword.

Justify non-healthcare studies [6, 8, 17, 27, 30], book chapter [16] and pre-2022 source [31] – see A12.1.

► INSERT A12.1
(red page after
p.12)

A12.1 - New paragraph at the end of §2.2.5 Eligibility Criteria

Insert before 'The inclusion and exclusion criteria were applied consistently...'

Consistent with exclusion criterion 6, five studies from outside the healthcare domain were retained because they contribute mechanisms that transfer directly to healthcare authorisation: decentralised trust in multi-stakeholder data sharing [6], blockchain-based archival integrity for sensitive documentation [8], TEE-supported trust and Byzantine-resilient consensus [17], DID/VC-based privacy-preserving authentication [27], and blockchain-based data sharing across organisational boundaries [30]. One book chapter [16] was retained under the exception to exclusion criterion 3 because it provides a foundational overview of decentralised identity, and one earlier policy statement [31] (2019) was retained as a foundational healthcare source on guardian and proxy access to electronic health records, as permitted in Section 2.2.4.

■ Author check: if any of these five studies is not genuinely used in the analysis, delete it rather than justify it.

2.2.6 Screening and Study Selection

The screening process consisted of three sequential stages: title and abstract screening, full-text eligibility assessment, and final inclusion.

During the first stage, the titles and abstracts of all retrieved records were examined to determine whether the studies were potentially relevant to the research questions. Records that were clearly unrelated to the review scope were excluded at this stage. During the second stage, the full texts of the remaining studies were assessed against the predefined inclusion and exclusion criteria. Particular attention was given to whether the studies addressed the relationship between consent, identity, ~~authorisation,~~ ~~authorization,~~ privacy, and healthcare data sharing.

During the final stage, the eligible studies were included in the qualitative synthesis. The reasons for exclusion at the full-text stage were recorded to improve the transparency of the review. The screening process was documented using the PRISMA flow diagram, which reports the number of records identified, duplicates removed, records screened, full texts assessed, studies excluded, and studies included in the final review.

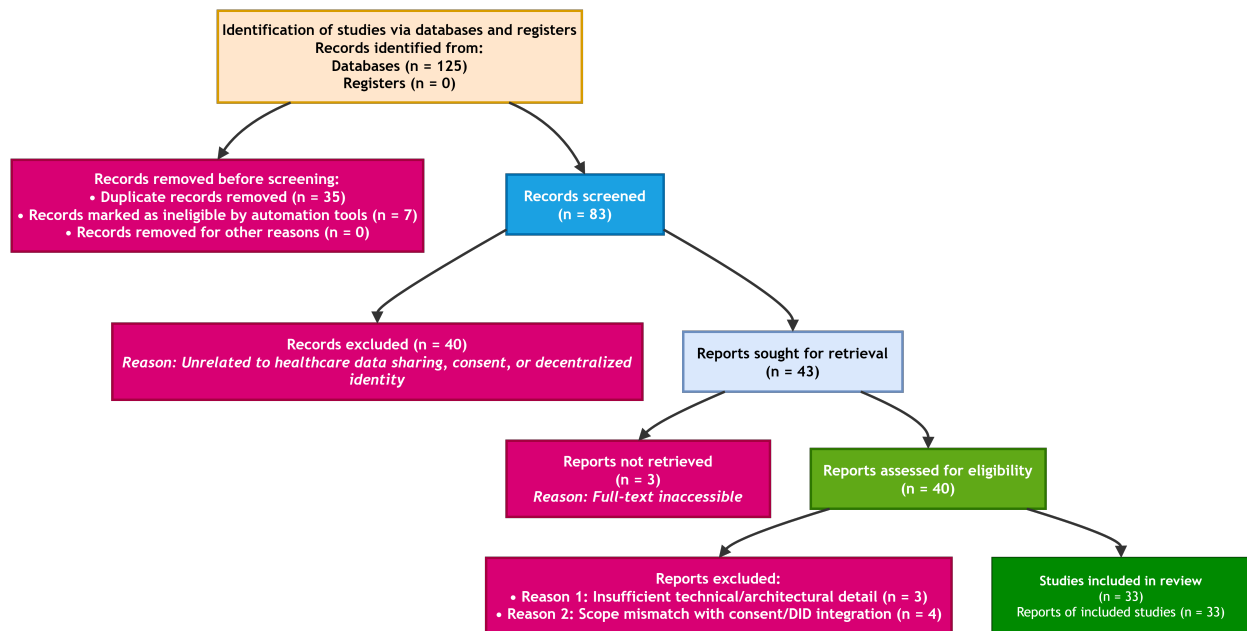


Figure 2: PRISMA Study Selection Summary

Figure 2 presents the PRISMA flow diagram for this review which ~~summarizes~~ ^{summarises} the identification, screening, eligibility, and inclusion stages of the SLR. The final number of included studies was derived after completing the screening and eligibility assessment across the identified literature base.

Caption: add following PRISMA 2020 [37]. Figure numbers verified: 125-35-7=83; 83-40=43; 43-3=40; 40-7=33 ✓

2.2.7 Data Extraction and Synthesis

The included studies were systematically analysed using a predefined data extraction framework. The extracted information included publication year, research objective, healthcare application domain, multi-party trust architecture, consent model, identity mechanism, access control mechanism, privacy-preserving technique, interoperability approach, evaluation method, and reported limitations.

Add §2.8 Quality Assessment + Table 2A (records per database) - see A13.1.

A13.1 - New subsection §2.2.8 Quality Assessment and new Table 2A

Insert after §2.2.7 Data Extraction and Synthesis (before §2.3). It supports the claim in §2.2.1 that a quality assessment procedure was used.

2.2.8 Quality Assessment

Each full-text study assessed for eligibility (n = 40) was appraised against five quality criteria:

QA1 – Are the aims and research questions clearly stated? **QA2** – Is the proposed approach (architecture, protocol or model) described in sufficient technical detail? **QA3** – Does the study explicitly address consent, identity or access control? **QA4** – Is the approach evaluated (prototype, experiment, formal analysis or case study)? **QA5** – Are limitations discussed? Each criterion was scored 1 (yes), 0.5 (partly) or 0 (no), giving a total out of 5. Studies scoring below 2.5 were excluded for insufficient technical or architectural detail (n = 3; Figure 2).

Table 2A: Records identified per database (search executed [dd] August 2026)

Database	Records identified	Database	Records identified
IEEE Xplore	[n]	PubMed	[n]
ACM Digital Library	[n]	Scopus	[n]
ScienceDirect	[n]	Web of Science	[n]
SpringerLink	[n]	Total	125 (Figure 2)

Author action: fill in [n] from your actual search log; the values must sum to 125. Keep §2.2.8 only if this scoring was actually applied. If it was not, delete 'and a quality assessment procedure' in §2.2.1 instead. Never report a procedure that was not performed.

The extracted data were ^{organised}~~organized~~ into thematic categories corresponding to the research questions. These categories included consent specification and management, ^{decentralised}~~decentralized~~ identity and credential verification, ^{authorisation}~~authorization~~ and access control, privacy preservation, interoperability, auditability, and system evaluation.

A qualitative synthesis was conducted to compare the approaches reported in the literature. The synthesis focused on identifying common architectural patterns, distinguishing technical and conceptual contributions, and examining the extent to which existing systems integrate consent management with identity verification and access control. Particular attention was given to whether the reviewed systems provided explicit enforcement of consent scope, verifiable ^{authorisation,}~~authorization~~, auditable access records, and mechanisms for preserving patient autonomy.

The final review set was used to establish the state of the art in multi-party-trust healthcare data sharing and consent management. The findings were subsequently used to identify research gaps and to inform the design requirements of the proposed framework.

2.3 Review

~~The systematic literature review examines the current state of research on trustworthy and decentralised data sharing, with particular attention to healthcare consent management, blockchain based data governance, decentralised identity, verifiable credentials, multi party authorisation, policy based access control, and Trusted Computing. The objective of the review is not simply to identify technologies that can be applied to healthcare data sharing, but to examine how existing approaches address different conditions required for a trustworthy authorisation decision and where conceptual or architectural gaps remain.~~

DELETE - duplicates §2.1 almost word for word. Replace with: 'This section analyses each of the research streams introduced in Section 2.1 in turn.'

~~The reviewed literature demonstrates that substantial progress has been made in individual areas. Healthcare research has emphasised the importance of patient autonomy, privacy, informed consent, and controlled data sharing [31, 14, 24, 22, 12]. Blockchain research has investigated immutable data governance, distributed auditability, and decentralised trust [2, 7, 3, 30, 26]. Research on decentralised identity and verifiable credentials has developed mechanisms for self controlled identity representation, credential verification, selective disclosure, and privacy preserving authentication [20, 33, 4, 16, 5, 27]. Access control research has further investigated role based, attribute based, risk aware, and usage control approaches for protecting sensitive healthcare information [32, 11, 28, 25].~~

~~However, the literature also indicates that these mechanisms are commonly developed and evaluated as separate technological components. This fragmentation creates an important distinction between the availability of security mechanisms and the ability to construct a unified and trustworthy authorisation decision. The following sections analyse these research areas and identify the gap addressed by the proposed framework.~~

2.3.1 Healthcare Consent and Decentralised Data Governance

Healthcare data sharing is fundamentally different from conventional information exchange because the data involved is highly sensitive and because decisions regarding its use may affect patient privacy, autonomy, clinical care, research participation, and institutional accountability. Existing studies have therefore emphasised the importance of informed consent, patient control, privacy preservation, and transparent governance in healthcare information systems [31, 22, 14, 12].

The literature increasingly recognises that patients should not be regarded merely as passive data providers. Research on patient autonomy and data ownership has highlighted the importance of giving individuals greater control over how their health information is accessed, shared, and reused [24]. At the same time, privacy-preserving interoperability remains difficult because healthcare systems must balance individual autonomy with the operational requirements of clinical care, coordination, and legitimate secondary data use [21, 9]. These competing requirements make healthcare consent a governance problem rather than simply a binary access-control decision.

Traditional consent-management approaches frequently represent consent as a permission indicating whether a particular party is allowed to perform a specified operation. Dynamic consent research has attempted to provide greater flexibility by allowing consent preferences to evolve over time, while privacy-first approaches have explored decentralised controllers and privacy-preserving mechanisms for improving data-subject control [13]. Consent receipts and auditable consent records have also been proposed to improve transparency and accountability by providing evidence of how consent was obtained and exercised [10].

Despite these developments, a significant conceptual limitation remains. The existence of a consent record does not necessarily explain whether the conditions required for a subsequent access request are still satisfied. A consent may identify a data subject and a recipient, but trustworthy authorisation requires additional reasoning concerning the legitimacy of the participants, their authority to act, whether other independent parties must participate in the decision, and whether the requested operation remains within the purpose and data scope originally authorised.

Consequently, the literature establishes the importance of patient autonomy and consent governance, but it provides comparatively limited integration between consent representation and a comprehensive trust-oriented authorisation process. This distinction becomes particularly important in decentralised environments where the entities involved in healthcare data sharing may not belong to the same administrative or trust domain.

2.3.2 Blockchain-Based Consent and Data Governance

Blockchain technologies have been extensively investigated as mechanisms for improving integrity, transparency, traceability, and accountability in distributed data-sharing environments. In healthcare, blockchain-based architectures have been proposed for electronic health records, access control, auditability, interoperability, and consent management [1, 2, 7, 3]. More generally, blockchain has been studied as an infrastructure for trustworthy data sharing and decentralised decision-making across organisational boundaries [29, 30, 26].

A major contribution of blockchain is its ability to preserve tamper-resistant evidence of transactions and state changes. This characteristic is particularly valuable for sensitive documentation and data governance because it can strengthen auditability and provide evidence that recorded information has not been modified without detection [8]. Analytical research has also investigated how blockchain immutability contributes to tamper-resilient trust and integrity within distributed systems [18].

Blockchain-based healthcare systems therefore provide an important foundation for recording consent events, access decisions, and governance actions. Surveys of healthcare blockchain systems demonstrate the potential of distributed ledgers to improve transparency and decentralised accountability, while also identifying continuing challenges associated with privacy, scalability, interoperability, and access control [2, 7, 3, 28].

However, blockchain immutability should not be confused with trustworthy authorisation. A blockchain can provide strong evidence that a transaction has been recorded, but it does not independently determine whether the entity initiating the transaction possesses legitimate authority. Similarly, the integrity of a consent record does not guarantee that all required participants approved the decision or that a subsequent access request complies with the conditions associated with the consent.

This distinction is particularly important when participants have incomplete information about each other, operate across organisational boundaries, or possess asymmetric authority. Under such conditions, the problem is not simply how to record a decision, but how to determine whether the decision was generated under sufficient and verifiable trust conditions.

Accordingly, blockchain is best understood as an enabling infrastructure for evidence preservation, auditability, and decentralised coordination rather than as the sole source of trust. The proposed research therefore does not treat blockchain storage as the primary research contribution. Instead, blockchain-compatible mechanisms are considered as part of a broader architecture in which the validity of an authorisation decision depends on the coordinated evaluation of identity, authority, multi-party approval, and policy constraints.

2.3.3 Decentralised Identity and Verifiable Credentials

Decentralised Identity (DID) and Verifiable Credentials (VCs) provide an alternative to conventional identity architectures based exclusively on centralised identity providers. DID-based systems enable entities to establish persistent and cryptographically verifiable identifiers, while VCs provide verifiable claims concerning roles, attributes, qualifications, or other properties associated with an entity [20, 33, 4, 16].

Recent research has extended decentralised identity beyond static identity representation. Dynamic DID mechanisms have investigated proactive approaches for identity management, while decentralised identity systems with multi-party verification have demonstrated the potential to strengthen the process through which identity claims are established or validated [33, 4]. Other studies have examined privacy-preserving authentication and selective disclosure, allowing participants to prove selected attributes without unnecessarily revealing additional information [27, 5].

These mechanisms are particularly relevant to healthcare and other sensitive data-sharing environments because they can reduce dependence on a single identity provider and provide stronger control over the disclosure of participant attributes. However, the literature also reveals an important conceptual distinction between identity and authority.

A valid decentralised identifier establishes that a participant can be cryptographically identified. A valid verifiable credential may establish that the participant possesses a particular role, qualification, or attribute. Nevertheless, neither identity verification nor credential possession automatically establishes that the participant should be granted access to a particular patient’s information. An entity may be a legitimate healthcare professional, for example, while still lacking authority to access a specific data category for a particular purpose.

The proposed research therefore extends the role of DID and VC technologies from identity representation and credential verification towards their use as trusted inputs to a broader authorisation process. Under this approach,

$$\textit{Identity} \neq \textit{Authorisation}. \tag{1}$$

Identity verification establishes who is participating in the decision, while authority verification determines whether that entity satisfies the requirements associated with a particular consent or access operation. The resulting distinction is important because it prevents successful authentication from being interpreted as automatic permission.

The literature provides increasingly sophisticated mechanisms for decentralised identity and credential validation. However, there remains a need to integrate these mechanisms with collective authorisation and policy evaluation so that verified identities and credentials contribute to, rather than replace, a comprehensive trust decision.

2.3.4 Multi-Party Authorisation and Collaborative Consent

A further limitation of conventional access-control models is their frequent reliance on a single authority responsible for granting or denying access. This assumption may be inappropriate in decentralised healthcare scenarios involving patients, guardians, healthcare professionals, institutional authorities, and other stakeholders with different responsibilities and authority levels [21, 9].

More generally, multi-party data-sharing environments require mechanisms capable of supporting collaborative governance. Research on decentralised data trusts has explored platforms through which multiple parties can participate in data-sharing arrangements and governance processes [19]. Decentralised decision-making has also been investigated in combination with blockchain and large-scale data systems [29]. FutureDID further demonstrates that multi-party verification can be incorporated into decentralised identity processes [4].

Nevertheless, multi-party verification of identity should not be considered equivalent to multi-party authorisation of data access. The first concerns whether an identity claim can be trusted, whereas the second concerns whether a group of independent participants has collectively established a valid permission decision.

Existing literature provides useful foundations for collaborative governance and multi-party verification. However, comparatively less attention has been given to modelling multi-party approval as an explicit and independently verifiable security condition within a patient consent object. This represents an important area addressed by the proposed framework.

2.3.5 Policy-Based and Context-Aware Access Control

Healthcare access-control research has developed a broad range of mechanisms for restricting access according to roles, attributes, risk conditions, contextual information, and usage constraints. Attribute-based encryption and decentralised key-management approaches, for example, provide mechanisms for protecting healthcare data through fine-grained cryptographic access policies [32]. Risk-aware and usage-control models have further investigated how access decisions can incorporate dynamic conditions and constraints beyond traditional role-based permissions [11].

Recent surveys demonstrate the continuing development of blockchain-based healthcare access control and healthcare IoT security, highlighting the importance of privacy preservation, interoperability, scalability, and dynamic access management [28, 25]. These approaches provide important mechanisms for determining whether an operation should be permitted under a particular set of access-control rules.

However, access control becomes more complex when policies must be connected directly to a decentralised consent process. A requester may possess a valid identity, valid credentials,

and even the required multi-party approval while still requesting information outside the scope authorised by the patient. Therefore, the validity of the requester and the validity of the requested operation must be evaluated separately.

The proposed framework consequently treats policy compliance as an explicit authorisation condition. Let C represent the consent object and R represent a requested operation. Policy validity can be represented conceptually as

$$V_P(C, R) = \text{Policy}(C, R). \quad (2)$$

For example, if a consent authorises access to ~~observations and medications~~,

Replace with: 'medications and procedures'

$$S_C = \{\overset{\{\text{Medication, Procedure}\}}{\text{Observation}}, \text{Medication}\}, \quad (3)$$

then a request for observations, medications, and procedures,

$$S_R = \{\overset{\{\text{Medication, Procedure, Observation}\}}{\text{Observation}}, \text{Medication}, \text{Procedure}\}, \quad (4)$$

KEEP Eq. (2)-(5) - the only instance of this example; set contents aligned with the prototype scope (Fig. 15). Later repeats are deleted and cite Eq. (2)-(5).

should be rejected because

$$S_R \not\subseteq S_C. \quad (5)$$

This illustrates a central argument of the proposed research: identity trust and approval trust are insufficient without contextual policy trust. The access decision must also be evaluated against the purpose and data-scope constraints explicitly associated with the consent.

2.3.6 Trusted Computing, Secure Execution, and Security Assurance

Trusted Computing provides an additional perspective on the protection and verification of security-critical processes. Trusted Execution Environments (TEEs), for example, provide hardware-supported isolation that can protect sensitive computation from compromised or untrusted operating environments [23]. Remote attestation mechanisms can further provide evidence concerning the integrity of the execution environment in which a security-sensitive process is performed.

~~Recent research has explored the integration of trusted execution and distributed trust mechanisms in different application domains. Trust aware sensing and consensus mechanisms have demonstrated how TEE supported sensing can contribute to resilient decision making in conjunction with blockchain coordination [17]. These studies illustrate the potential of Trusted Computing to provide an additional assurance layer beyond conventional software-based access control mechanisms.~~

Cut: TEE is not in any RQ/RO. Keep one sentence (below).

Nevertheless, Trusted Computing does not by itself determine the correctness of an authorisation policy. A TEE can protect the execution of an authorisation decision, but the resulting decision remains dependent on the correctness of the identities, authority relationships, approval conditions, and policies supplied to that computation. Consequently, secure execution and trustworthy authorisation address complementary rather than identical problems.

~~The reviewed literature therefore suggests an important opportunity for integration. A trust oriented authorisation framework can define the conditions under which access should be permitted, while Trusted Computing mechanisms can provide stronger assurance that the relevant security sensitive evaluation is performed within an integrity protected environment. This research establishes the conceptual foundation for such integration. Future work can~~

Replace with: 'Integrating trusted execution and remote attestation with the proposed authorisation model is outside the current scope and is identified as future work (Section 9.2).'

~~therefore investigate how trusted execution and remote attestation can strengthen the enforcement and verification of decentralised consent decisions.~~

Beyond execution security, formal security reasoning is also necessary to distinguish prototype functionality from security assurance. A system may successfully execute valid authorisation scenarios without demonstrating that invalid identities, insufficient approvals, or policy violations cannot produce an unintended access decision. Formal analysis therefore provides a complementary layer through which the expected security properties of the authorisation model can be explicitly defined and examined.

2.3.7 Comparative Analysis of Existing Approaches

The reviewed literature demonstrates that existing approaches provide strong solutions for individual dimensions of trustworthy data sharing. Blockchain-based systems provide tamper-resistant recording and auditability; DID and VC mechanisms provide decentralised identity and verifiable attributes; policy-based and cryptographic access-control mechanisms provide fine-grained data protection; collaborative governance mechanisms support distributed participation; and Trusted Computing provides secure execution and attestation capabilities.

However, these contributions address different layers of the security problem. No individual mechanism can independently establish that a healthcare data-access decision is trustworthy. A blockchain record does not establish participant authority, a valid DID does not establish access permission, multi-party participation does not guarantee policy compliance, and secure execution does not guarantee that the underlying authorisation policy is correct.

Table 2 summarises the principal focus and limitations of the major research streams and positions the proposed framework relative to the existing literature.

Table 2: Comparison of Existing Research Approaches and the Proposed Framework

Research Stream	Primary Contribution	Main Limitation for Authorisation	Representative References
Healthcare consent and privacy governance	Patient autonomy, informed consent, and controlled data sharing	Consent is treated as permission rather than an evaluable authorisation object	[31, 22, 14, 24, 12, 13, 10]
Blockchain-based data governance	Tamper-resistant records, distributed auditability, and transparency	Immutable records do not establish participant legitimacy, authority, or policy compliance	[1, 2, 7, 3, 30, 26, 8, 29]
Decentralised identity and verifiable credentials	Self-controlled identity, verifiable attributes, and authentication	Identity and credential validity do not independently determine if access is authorised	[20, 33, 4, 16, 27, 5]

Continued on next page

Table 2 – *Continued from previous page*

Research Stream	Primary Contribution	Main Limitation for Authorisation	Representative References
Multi-party and decentralised governance	Collaborative participation and distributed verification or governance	Limited integration between collective approval thresholds, consent, and access decisions	[19, 4, 21, 9]
Policy-based and healthcare access control	Fine-grained restriction based on attributes, risk, context, and constraints	Policy enforcement is separated from decentralised identity and multi-party consent	[32, 11, 28, 25]
Trusted Computing and secure execution	Hardware-supported isolation, execution integrity, and attestation	Secure execution does not determine whether underlying authorisation conditions are sufficient	[23, 17, 18]
Proposed Framework	Integrated evaluation of consent, identity, authority, multi-party approval, and policy compliance	Requires further extension towards lifecycle trust, formal assurance, and empirical validation	This research

The comparison indicates that the principal contribution of the proposed research is not the replacement of existing technologies. Rather, it lies in establishing an explicit conceptual relationship among them. Blockchain, DID, VCs, policy mechanisms, and potentially trusted execution are treated as complementary components that address different trust conditions within a common authorisation process.

2.4 Synthesis and Research Gap

The literature review identifies a consistent pattern of fragmentation across existing research. Blockchain-based approaches primarily address the integrity and traceability of recorded events. Decentralised identity and verifiable credential systems address the identification and attribute verification of participating entities. Multi-party governance mechanisms address distributed participation and collective decision-making. Policy-based access-control approaches determine whether requested operations comply with predefined constraints. Trusted Computing technologies protect the execution of security-sensitive computation.

These mechanisms provide important but incomplete answers when considered independently. The existence of a valid blockchain record does not guarantee that the authorisation decision was generated by legitimate and appropriately authorised participants. A verified identity does not imply permission to access a specific patient’s information. A valid credential does not necessarily satisfy a multi-party approval requirement. Similarly, sufficient approvals do not guarantee that a subsequent request remains within the authorised purpose or healthcare data scope.

The central research gap therefore concerns the absence of a sufficiently integrated Trust

Computing framework that explicitly models the relationship between these independently verifiable conditions. In particular, existing approaches provide limited treatment of patient consent as a security-bearing and policy-aware authorisation object whose validity depends on coordinated conditions concerning participant identity, authority, collective approval, and contextual policy compliance.

The proposed research addresses this gap by developing a trusted multi-party consent governance framework in which consent is represented as an evaluable authorisation object rather than simply as a database entry, consent receipt, or blockchain transaction. Decentralised identifiers and verifiable credentials are used to establish trusted identity and authority inputs. Multi-party authorisation mechanisms determine whether the required independent participants have collectively satisfied the authorisation condition. Policy-aware access control evaluates whether a requested operation remains within the authorised purpose and data scope.

The foundational authorisation decision investigated in the current stage of the research can therefore be represented as

$$Decision(C, R) = ALLOW \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R), \quad (6)$$

where $V_I(u)$ represents the validity of the identity and relevant authority evidence associated with participant u , $V_A(C)$ represents the satisfaction of the required multi-party authorisation condition for consent C , and $V_P(C, R)$ represents compliance between the consent and the requested operation R .

This formulation represents the principal conceptual contribution of the current research stage. It shifts the focus from determining whether consent has merely been recorded towards determining whether a data-access decision has been generated under sufficient and independently verifiable trust conditions.

The current research therefore concentrates on establishing the foundational relationship between trust-centric consent modelling, decentralised identity and authority verification, multi-party authorisation, and policy-aware access control. The subsequent research will extend this model towards temporal and lifecycle trust, formal security assurance, adversarial evaluation, and comprehensive empirical validation using the HALAH prototype.

Accordingly, the literature suggests that the principal research opportunity is not the development of another isolated blockchain consent mechanism or identity-management system. Instead, the opportunity lies in constructing a coherent Trust Computing model in which the different security mechanisms contribute to a common and explainable authorisation decision. Trustworthy healthcare data sharing can then be evaluated not simply according to whether a consent record exists, but according to whether the combined identity, authority, collective authorisation, and policy conditions required for access have been satisfied.

3 Research Gaps and Questions

3.1 Research Gap

The systematic literature review indicates that substantial research has been conducted on individual mechanisms for securing healthcare data sharing, including blockchain-based consent management, decentralised identity, verifiable credentials, cryptographic access control, policy-based authorisation, and multi-party approval. These approaches have demonstrated

the value of decentralisation, tamper-resistant records, verifiable identity, fine-grained access control, and distributed decision-making in addressing different aspects of healthcare data security. However, the literature also reveals a significant conceptual and architectural fragmentation among these mechanisms. They are commonly investigated as independent technical solutions rather than as coordinated components of a unified trust-oriented authorisation model.

The central gap is therefore not the absence of technologies for recording consent, verifying identity, or restricting data access. Rather, it is the absence of a sufficiently integrated model explaining how these mechanisms collectively establish a trustworthy authorisation decision. In particular, existing consent-oriented approaches tend to treat consent primarily as a record of a patient's permission. Once the permission has been created and stored, subsequent access control may depend predominantly on the existence of the consent record and the successful authentication of the requester. Such a model establishes evidence that a consent decision occurred, but it does not necessarily establish that the requester possesses the required authority, that all required parties have independently approved the access, or that the requested operation is consistent with the purpose and data scope originally authorised by the patient.

This distinction is important because *recording consent* and *enforcing trustworthy authorisation* represent fundamentally different security problems. A blockchain may provide an immutable representation of a consent event, but immutability does not establish the legitimacy of the entities involved in that event. Similarly, a valid decentralised identity can establish who a participant is, but it does not necessarily establish what that participant is authorised to do. Multi-party approval can strengthen collective decision-making, but approval alone does not guarantee that the resulting access request conforms to the patient's authorised purpose or data scope. Consequently, trust cannot be attributed to any individual mechanism in isolation.

From a Trust Computing perspective, this leads to a more fundamental research problem. Trustworthy access should be understood as an outcome of the coordinated satisfaction of multiple independently verifiable conditions. The relevant conditions include the legitimacy of the participating identities, the authority associated with those identities, the satisfaction of required collective approval conditions, and compliance between the requested operation and the policy defined by the consent. The research therefore conceptualises trust not as a static attribute possessed by a particular entity or technology, but as an emergent property of a verifiable authorisation process.

This perspective also introduces an important distinction between *authentication*, *authorisation*, and *trustworthy access*. Authentication determines whether an entity can be identified and verified. Authorisation determines whether the entity is permitted to perform a particular operation. Trustworthy access requires an additional consideration: whether the authorisation decision itself has been established through sufficient, verifiable, and policy-compliant conditions. The research consequently investigates how these layers can be connected within a single framework without reducing trust to any individual credential, transaction, or access-control rule.

The identified gap can therefore be stated as follows: existing healthcare consent and access-control research provides many of the necessary technological building blocks, but there remains a need for an integrated Trust Computing framework that treats patient consent as a security-bearing and evaluable authorisation object. Such a framework should be capable of representing the relevant trust conditions, verifying the participating entities and their

authority, establishing collective authorisation where required, and enforcing the policy and data-scope constraints associated with the consent.

The research addresses this gap by developing a trust-oriented authorisation model in which consent is not simply evidence that permission was granted, but the basis for evaluating whether a particular access request should be trusted. The resulting research direction places Trust Computing at the centre of the investigation, while treating blockchain, decentralised identity, verifiable credentials, and policy mechanisms as enabling technologies supporting the broader trust model.

3.2 Main Research Question

Based on the identified research gap, the overarching research question is formulated as follows:

How can a trust-oriented computing framework establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints?

The formulation of this question deliberately emphasises *trust-oriented computing* rather than any individual implementation technology. The terms *establish* and *enforce* represent two complementary aspects of the research problem. Establishment concerns how trustworthy participants, authority relationships, and collective consent decisions are created. Enforcement concerns how these established conditions are evaluated when a healthcare data-access request is made.

The main research question therefore encompasses both the conceptual and technical dimensions of the research. At the conceptual level, it investigates how trust should be represented and reasoned about within a multi-party consent environment. At the technical level, it investigates how these trust conditions can be operationalised through decentralised identities, verifiable credentials, multi-party authorisation, and policy-aware access control. The question consequently provides the basis for both the proposed framework and its subsequent implementation and evaluation.

For current stage, the investigation is deliberately focused on the foundational conditions required to establish trustworthy authorisation. These conditions are represented through four interconnected research questions concerning consent modelling, identity and authority trust, multi-party authorisation, and policy-aware access control. Temporal and lifecycle trust, formal security assurance, and comprehensive empirical validation form the subsequent research scope and will be developed further in CA3.

3.3 Sub-Research Questions

The research objectives are operationalised through six corresponding sub-research questions. Each sub-research question addresses a distinct dimension of the proposed trust-oriented healthcare authorisation framework, while the six questions collectively establish a progression from consent modelling and participant trust to collective authorisation, policy enforcement, temporal and lifecycle control, and finally formal security assurance and empirical validation.

3.3.1 SRQ1: Trust-Centric Consent Modelling

The first sub-research question is:

How can patient consent be modelled as a trust-aware authorisation object that explicitly represents identity, authority requirements, policy constraints, and authorisation evidence?

The purpose of this question is to establish the conceptual foundation of the framework. Rather than representing consent as a simple association between a patient, a requester, and a permission, the proposed model represents consent as a structured and evaluable authorisation object that

$$C = (I, A, P, E), \quad (7)$$

where I represents identity information, A represents authority and authorisation requirements, P represents policy and data-scope constraints, and E represents authorisation evidence.

This formulation changes the role of consent from a passive record into an evaluable authorisation object. Its security significance is determined not merely by the existence of a consent record, but by whether the associated trust, authority, policy, and evidence conditions remain valid when an access request is evaluated.

SRQ1 therefore establishes the conceptual representation required by the subsequent identity, multi-party authorisation, policy, and security-assurance mechanisms.

3.3.2 SRQ2: Decentralised Identity and Authority Trust

The second sub-research question is:

How can decentralised identities and verifiable credentials establish trustworthy participants while explicitly separating identity authentication from authorisation authority?

A fundamental principle of the proposed framework is that identity and authorisation should not be treated as equivalent. A valid decentralised identifier establishes the identity of a participant, while a verifiable credential provides evidence concerning the participant's role or authority. ~~Therefore, Identity $\neq$ Authorisation.~~ The identity and authority validity condition is represented as

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u). \quad (8)$$

This separation prevents successful authentication from being interpreted as automatic authorisation. For example, authenticating a healthcare professional identified by a DID does not by itself establish that the professional is authorised to access a particular patient's data. Identity and authority verification instead provide trusted inputs to the subsequent authorisation evaluation process.

SRQ2 therefore addresses how trustworthy participants can be established before their participation in collective authorisation decisions.

Add after Eq. (7): 'Stage 2 extends this to $C = (I, A, P, T, L, E)$, where T is the validity interval and L the lifecycle state; this extended object is already used in HALAH v1.1 (models/consent.py).'

Delete repeat 'Identity $\neq$ Authorisation' (see Eq. (1)); also fixes missing space after 'Therefore,'.

3.3.3 SRQ3: Trustworthy Multi-Party Authorisation

The third sub-research question is:

How can multiple independently verified participants jointly establish a trustworthy consent decision without allowing a single participant to unilaterally authorise sensitive healthcare data access?

This question addresses the collaborative authorisation problem. Let A_v denote the set of independently verified authorisation participants and let N denote the required authorisation threshold. Multi-party authorisation is defined as

$$V_A(C) = \begin{cases} 1, & |A_v| \geq N, \\ 0, & |A_v| < N. \end{cases} \quad (9)$$

Consequently,

$$|A_v| < N \implies \text{Decision}(C, R) = \text{DENY}. \quad (10)$$

This formulation allows the framework to distinguish explicitly between sufficient and insufficient collective participation. It also reduces reliance on a single authorising participant where a predefined threshold of independent approvals is required.

More fundamentally, SRQ3 changes the interpretation of trust from an assumption concerning a single trusted entity to a property established through the joint satisfaction of independently verified authorisation requirements.

3.3.4 SRQ4: Policy- and Context-Aware Access Control

The fourth sub-research question is

How can policy, purpose, and data-scope constraints be incorporated into authorisation decisions so that valid identities and sufficient approvals cannot be used to obtain unauthorised healthcare data?

Multi-party approval alone does not guarantee that a data-access request is legitimate. A requester may possess a valid identity and the required approvals while requesting information beyond the authorised scope. The framework therefore introduces an explicit policy predicate

$$V_P(C, R) = \text{Policy}(C, R), \quad (11)$$

which evaluates whether the requested operation satisfies the purpose and data-scope constraints defined by the consent object.

~~For example, if a consent authorises access to~~

~~$$S_C = \text{Observation, Medication}, \quad (12)$$~~

~~while the request contains~~

~~$$S_R = \text{Observation, Medication, Procedure}, \quad (13)$$~~

~~the request must be rejected when~~

~~$$S_R \not\subseteq S_C. \quad (14)$$~~

Repeat - delete Eq. (12)-(14) (also missing set braces). Replace with: 'For example, the request in Eq. (4) must be rejected because $S_R \not\subseteq S_C$ (Eq. (5)).'

Similarly, a request may be rejected when its declared purpose is inconsistent with the purpose specified in the consent.

Thus, trustworthy authorisation requires not only trusted participants and sufficient approvals, but also compliance between the requested operation and the authorisation policy.

SRQ4 therefore completes the foundational access-control mechanisms by connecting participant trust and collective authorisation with the actual operation being requested.

3.3.5 SRQ5: Temporal and Lifecycle Trust

The fifth sub-research question is

How can temporal validity and consent lifecycle controls ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and is rejected after expiration, revocation, or an unauthorised state transition?

Trustworthy authorisation is inherently dynamic. A consent that is valid at one point in time cannot necessarily be assumed to remain valid indefinitely. Let the validity interval of a consent object be $[t_s, t_e]$. Temporal validity is defined as

$$V_T(C, t) = (t_s \leq t \leq t_e). \quad (15)$$

Consequently,

$$t < t_s \vee t > t_e \implies \text{Decision}(C, R) = \text{DENY}. \quad (16)$$

Temporal validity must also be evaluated together with the lifecycle state of the consent. The lifecycle can be represented as

$$\text{Specification} \rightarrow \text{Verification} \rightarrow \text{Approval} \rightarrow \text{Active} \rightarrow \text{Expiration/Revocation}. \quad (17)$$

The lifecycle validity predicate can therefore be represented as

$$V_L(C) = \text{ValidState}(C) \wedge \text{ValidTransition}(C). \quad (18)$$

An authorisation decision consequently requires both temporal and lifecycle validity. A consent that has expired, has been revoked, or has entered an invalid state must not be treated as an active authorisation even when its original identity, authority, and approval conditions were valid.

SRQ5 therefore extends the foundational authorisation model into a dynamic consent environment in which trust is continuously evaluated according to both temporal conditions and lifecycle state.

3.3.6 SRQ6: Formal Security Assurance and Empirical Validation

The sixth sub-research question is

How can the security properties of the proposed trust-oriented authorisation mechanism be formally defined and empirically evaluated to demonstrate that the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions?

This question integrates the formal security analysis and empirical validation of the proposed framework. The purpose is not only to determine whether the prototype can execute valid consent workflows, but also to establish whether the implemented mechanism conforms to the security properties defined by the conceptual model.

The overall authorisation decision is defined as a conjunction of independently evaluated predicates

$$Decision(C, R) = \begin{cases} ALLOW, & V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L, \\ DENY, & \text{otherwise.} \end{cases} \quad (19)$$

The corresponding security properties include identity correctness, which can be formulated as

$$u \in A_v \implies V_I(u) = 1, \quad (20)$$

authorisation integrity

$$\neg (V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L) \implies Decision(C, R) = DENY, \quad (21)$$

threshold security, formulated as

$$|A_v| < N \implies Decision(C, R) = DENY, \quad (22)$$

and temporal safety, formulated as

$$t \notin [t_s, t_e] \implies Decision(C, R) = DENY. \quad (23)$$

Lifecycle safety additionally requires that unauthorised state transitions be rejected

$$IllegalTransition(C) \implies Reject. \quad (24)$$

The formal analysis provides a theoretical assurance layer that is independent of the empirical execution of the prototype. Experimental success alone cannot establish that unauthorised access is impossible under the stated model, while formal reasoning establishes security properties only under explicitly defined assumptions. Consequently, the two forms of evidence are complementary rather than interchangeable.

The empirical component evaluates whether the implemented HALAH framework realises these defined properties in representative decentralised healthcare data-sharing scenarios. Synthetic healthcare records derived from the Synthea dataset are used to construct representative consent workflows. The evaluation considers both successful and unsuccessful authorisation scenarios, including valid identity and credential verification, invalid identity or credential submission, insufficient multi-party approval, valid threshold-based approval, unauthorised data-scope requests, purpose violations, expired consent, revoked consent, and invalid lifecycle transitions.

For a representative multi-party consent scenario, if two authorised participants are required, then it yields

$$|A_v| = 2 \implies V_A = 1, \quad (25)$$

whereas

$$|A_v| = 1 \implies V_A = 0. \quad (26)$$

The prototype evaluation therefore examines whether the implemented framework correctly transitions a consent from an unapproved state to an active authorisation state only when all

Cite Synthea:
add '[38]' after
'Synthea
dataset'.

required conditions are satisfied, and whether subsequent access requests are rejected when any required trust condition is violated.

Audit records are generated throughout the workflow to provide evidence of consent creation, participant verification, approval events, authorisation-state evaluation, data-access decisions, and relevant lifecycle transitions.

The empirical evaluation is therefore not primarily intended as a high-throughput performance benchmark. Instead, it assesses functional security correctness and consistency between the conceptual model, formal security properties, and implemented authorisation behaviour.

SRQ6 consequently represents the final assurance stage of the research ~~programme~~^{program} by connecting formal security reasoning with implementation-level evidence. Together, these two forms of analysis provide evidence that the proposed framework is not only conceptually defined, but also capable of enforcing the intended trust-oriented authorisation properties in representative healthcare data-sharing scenarios.

3.4 Research Questions as an Integrated Research Problem

The six sub-research questions are not independent technical questions; rather, they represent successive and interdependent trust conditions within a unified healthcare data authorisation problem. Collectively, they investigate how patient consent can be transformed from a static permission record into a trustworthy, evaluable, and enforceable authorisation mechanism.

SRQ1 establishes the conceptual object against which trust and authorisation can be evaluated by modelling patient consent as a structured authorisation object. SRQ2 establishes the trustworthiness of the participants by verifying their decentralised identities and authority evidence while explicitly separating identity from authorisation. SRQ3 then extends this participant-level trust into a collective decision by requiring independently verified participants to satisfy a predefined authorisation threshold. SRQ4 determines whether the resulting authorisation is applicable to the specific data-access request by evaluating purpose and data-scope constraints. SRQ5 further introduces the dynamic dimension of trust by determining whether the authorisation remains valid with respect to its temporal conditions and lifecycle state. Finally, SRQ6 establishes the assurance layer by formally defining the resulting security properties and empirically evaluating whether the implemented framework enforces them correctly.

The integrated authorisation condition can therefore be expressed as

$$Decision(C, R, t) = ALLOW \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (27)$$

where V_I represents identity and authority validity, V_A represents collective authorisation validity, V_P represents policy and contextual compliance, V_T represents temporal validity, and V_L represents consent lifecycle validity.

This formulation provides the central logical relationship among SRQ1–SRQ5. A valid authorisation decision requires the simultaneous satisfaction of all relevant trust conditions. Consequently, failure of any individual condition ~~results in denial that~~

~~$$\implies (V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L) \implies Decision(C, R, t) = DENY. \quad (28)$$~~

Replace with:
'results in denial
(Eq. (21)).'

Repeat - delete;
cite Eq. (21)

The formulation also clarifies the role of SRQ6. Formal security assurance does not constitute another authorisation condition to be evaluated at runtime. Instead, it provides a means of specifying, analysing, and verifying the security properties of the integrated authorisation

mechanism. Empirical validation subsequently examines whether the implemented system realises these properties under representative valid, invalid, and adversarial healthcare data-sharing scenarios. Thus, SRQ6 operates as an assurance layer over the mechanisms established by SRQ1–SRQ5 rather than as an additional access-control predicate.

The research questions form a progressive research architecture that begins with establishing a robust Consent Representation, which directly fosters Participant Trust. This trust then translates into a framework for Collective Authorisation, providing the necessary foundation for systemic Policy Enforcement. Consequently, this enables dynamic Temporal/Lifecycle Control over data and processes, culminating in comprehensive Security Assurance and Validation. By structuring the inquiries this way, the architecture creates a continuous logical pipeline that ~~seamlessly~~ connects user-facing trust with back-end system security.

This progression provides a coherent research pathway from the representation of consent to the enforcement and assurance of trustworthy data access. It also clarifies that decentralised identifiers, verifiable credentials, threshold authorisation, policy enforcement, and lifecycle controls are not independent blockchain or security features. Instead, they constitute complementary mechanisms within a single trust-oriented authorisation model.

Accordingly, the contribution of the research is not simply the implementation of a blockchain-based consent prototype. Rather, the research investigates how multiple trust conditions can be explicitly represented, independently evaluated, jointly enforced, formally reasoned about, and empirically validated within a decentralised healthcare data-sharing environment. The six research questions therefore collectively define the integrated research problem and provide a direct conceptual correspondence with the six research objectives.

4 Research Objectives

The research objectives are derived from the research questions and translate the identified research gap into concrete research and development activities. The objectives are intentionally broader than individual implementation tasks. Each objective represents a research contribution that can be examined conceptually, technically, and, where appropriate, empirically. The complete research ~~programme~~ ^{program} consists of six research objectives, corresponding to six research questions. The first four objectives establish the foundational trust-oriented authorisation mechanisms investigated during current stage, while the final two objectives extend and evaluate these mechanisms as part of the next research ~~programme~~ ^{program}.

Naming: the report switches between 'RQ' and 'SRQ'. Use 'SRQ1'–'SRQ6' everywhere (§4, Tables 3–4, §7).

4.1 RO1 - Trust-Centric Consent Model

The first research objective is to develop a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The model will incorporate identity information, authority requirements, policy constraints, and authorisation evidence so that a consent decision can be evaluated when a subsequent data-access request is made.

RO1 directly addresses RQ1 and establishes the conceptual foundation for the remaining objectives. In particular, it defines the information that must be represented before consent can be interpreted as an authorisation decision rather than merely as a static approval record.

4.2 RO2 - Decentralised Identity and Authority Trust

The second research objective is to develop a decentralised identity and authority verification mechanism using decentralised identifiers and verifiable credentials. The objective is to establish trustworthy participants while explicitly separating identity authentication from authorisation authority.

RO2 addresses RQ2 and provides the trust inputs required by the subsequent multi-party authorisation process. The objective is based on the principle that successful identity verification does not automatically imply permission to access healthcare data. Instead, identity and authority must be verified as distinct but related conditions of trustworthy authorisation.

4.3 RO3 - Trustworthy Multi-Party Authorisation

The third research objective is to develop a threshold-based multi-party authorisation mechanism through which multiple independently verified participants can jointly establish a trustworthy consent decision.

The objective is to prevent unilateral authorisation where collective approval is required and to provide an explicit mechanism for distinguishing sufficient from insufficient participation. The mechanism will define the required authorisation participants, verify their approval evidence, and determine whether the predefined threshold has been satisfied.

RO3 directly addresses RQ3 and extends the consent model from an individual permission statement to a collective authorisation decision.

4.4 RO4 - Policy- and Context-Aware Access Control

The fourth research objective is to develop a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent.

The objective is to ensure that a valid identity and sufficient multi-party approval cannot be used to obtain healthcare information outside the authorised scope. Accordingly, the mechanism will evaluate whether the requested purpose is consistent with the consent and whether the requested data scope is contained within the permitted scope.

RO4 directly addresses RQ4 and completes the foundational authorisation model investigated during current stage. Together, RO1–RO4 establish the representation, verification, collective authorisation, and policy-enforcement mechanisms required for a trust-oriented healthcare data-sharing decision.

4.5 RO5 - Temporal and Lifecycle Trust

The fifth research objective is to extend the trust-oriented framework with temporal validity and consent lifecycle controls. The objective is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced.

RO5 addresses RQ5 and extends the foundational current stage authorisation model into a dynamic consent environment. Whereas current stage establishes whether an authorisation can be considered valid under the defined identity, approval, and policy conditions, RO5

investigates whether that authorisation remains valid as time passes and as the consent state changes.

This objective constitutes a principal component of the ~~next-stage research~~ ^{next-stage research} ~~next-stage research~~ ^{program} ~~programme~~. It will investigate how temporal and lifecycle conditions can be incorporated into the authorisation decision without weakening the trust relationships established by the current stage mechanisms.

4.6 RO6 - Formal Security Assurance and Empirical Validation

The sixth research objective is to formally analyse and empirically evaluate whether the implemented framework satisfies its defined trust and authorisation properties under representative healthcare data-sharing scenarios.

RO6 addresses RQ6 and combines formal security assurance with empirical validation of the proposed framework. The formal component will specify and analyse the security properties, consistency requirements, and soundness conditions of the trust-oriented authorisation mechanism. The empirical component will evaluate the implementation through representative consent workflows, negative and adversarial scenarios, and comprehensive testing of the HALAH prototype.

The objective is to establish not only that the prototype can execute valid consent workflows, but also that it behaves correctly when one or more trust conditions are violated. For example, the evaluation should examine whether access is denied when identity verification fails, when the required authorisation threshold is not satisfied, or when the requested purpose or data scope violates the consent policy.

RO6 therefore represents the transition from establishing the authorisation model to providing evidence for its security and practical effectiveness. Although preliminary implementation and scenario-based testing may support the current stage findings, the complete formal analysis and comprehensive empirical validation will be conducted as part of next stage works.

4.7 Relationship Between Research Questions and Objectives

The relationship between the six research questions and the six research objectives is summarised in ~~Table 3 and Table 4~~ ^{Table 3 and Table 4} ~~Table 3~~. The mapping follows the structure of the research ~~programme~~ ^{program} and maintains a direct correspondence between each research question and its associated objective. This correspondence ensures that every research question is addressed by a clearly defined research activity and that each objective contributes to the overall development of the proposed trust-oriented authorisation framework.

The current stage research consequently concentrates on RO1–RO4, which establish the foundational trust-oriented authorisation model. These objectives investigate how consent can be represented as an evaluable authorisation object, how participant identity and authority can be verified, how multiple participants can jointly establish authorisation, and how policy constraints can be enforced before healthcare data are released.

RO5 and RO6 constitute the principal research agenda for CA3. RO5 extends the authorisation model with temporal and lifecycle trust, while RO6 provides formal security assurance and comprehensive empirical validation. The distinction between current stage and next stage is therefore based on research scope and maturity rather than on a different set of research questions or objectives. Current stage establishes the foundational mechanisms and their conceptual relationships, whereas next stage investigates whether these mechanisms remain

Table 3: Research Questions, Research Objectives, and Thesis Chapters for Current Stage

RQ	Research Objective	Research Focus and Scope	Thesis
RQ1	RO1: Trust-Centric Consent Model	Develop a structured and evaluable consent representation that treats patient consent as a policy-bound authorisation object containing identity information, authority requirements, policy constraints, and authorisation evidence.	Chapter 3
RQ2	RO2: Decentralised Identity and Authority Trust	Establish trustworthy participants using DIDs and VCs while explicitly separating identity authentication from authorisation authority.	Chapter 3
RQ3	RO3: Trustworthy Multi-Party Authorisation	Establish collective authorisation through independently verified participants and threshold-based approval mechanisms, thereby preventing unilateral authorisation when collective approval is required.	Chapter 4

Table 4: Research Questions, Research Objectives, and ~~Thesis Chapters for CA3~~

RQ	Research Objective	Research Focus and Scope	Thesis
RQ4	RO4: Policy- and Context-Aware Access Control	Enforce purpose and healthcare data-scope constraints as explicit and evaluable conditions of access, ensuring that valid identities and sufficient approvals cannot be used outside the authorised scope.	Chapter 4
RQ5	RO5: Temporal and Lifecycle Trust	Extend the authorisation model with temporal validity, expiration, revocation, and controlled consent-state transitions.	Chapter 5
RQ6	RO6: Formal Security Assurance and Empirical Validation	Formally analyse the security and consistency properties of the trust-oriented authorisation mechanism and empirically evaluate the complete framework through the HALAH prototype, representative healthcare scenarios, and negative or adversarial testing.	Chapter 5

Replace with:
'Thesis Chapters
(continued: RQ4
Stage 1;
RQ5-RQ6 Stage
2/CA3)'

reliable under dynamic lifecycle conditions and whether their security and practical effectiveness can be formally and empirically demonstrated.

The overall research argument is that trustworthy patient consent should not be understood as a single technological artefact or as the outcome of a single access-control operation. Rather, it should be understood as a security decision emerging from a set of independently verifiable conditions. The contribution of the research is therefore to provide a coherent Trust Computing framework through which these conditions can be represented, evaluated, enforced, and ultimately validated in a decentralised healthcare data-sharing environment.

For the foundational current stage model, the authorisation decision is expressed as

$$\text{Decision}(C, R) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R), \quad (29)$$

Repeat - delete;
cite Eq. (6)

where $V_I(u)$ represents the validity of the requesting participant's identity and authority evidence, $V_A(C)$ represents satisfaction of the required multi-party authorisation threshold, and $V_P(C, R)$ represents compliance between the access request and the consent policy.

The next stage research will extend this decision model by incorporating temporal and lifecycle conditions

$$\text{Decision}(C, R, t) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C), \quad (30)$$

Repeat - delete;
cite Eq. (27)

where $V_T(C, t)$ represents temporal validity and $V_L(C)$ represents the validity of the consent lifecycle state and its transitions. This extension provides a consistent connection between the foundational current stage objectives and the planned next research on dynamic trust, formal assurance, and comprehensive validation.

5 Research Architecture: MVC

The proposed research architecture adopts a Model–View–Controller (MVC) design to provide a structured implementation foundation for the trusted multi-party consent management framework. However, the MVC architecture is not used merely as a conventional software engineering pattern for separating data, interfaces, and application logic. Within the proposed framework, MVC is extended to support a more fundamental separation between the representation of consent, the interaction of independent stakeholders, and the enforcement of security-critical authorisation decisions.

This separation is particularly important in decentralised healthcare data-sharing environments. A healthcare consent decision may involve patients, guardians, healthcare professionals, auditors, and other authorised entities, each of whom may possess different identities, authorities, responsibilities, and interests. Consequently, the system cannot rely on a single user authentication event or a static permission entry to determine whether access should be granted. Instead, the authorisation decision must emerge from the coordinated evaluation of independently verifiable security conditions.

The proposed architecture therefore distinguishes three complementary responsibilities. The *Model* represents the security and governance state of the system, including identities, credentials, consent objects, authorisation requirements, policies, approval evidence, and healthcare data scopes. The *View* provides controlled interaction mechanisms through which independent participants can create, inspect, approve, or exercise consent-related operations. The *Controller* acts as the trusted decision coordination layer responsible for validating identity,

evaluating authority, aggregating multi-party approval evidence, enforcing policy constraints, and determining whether a requested healthcare data operation should be permitted.

The architectural significance of this design is that the View cannot directly modify the authorisation outcome, while the existence of a Model object does not automatically imply that access is permitted. Instead, every sensitive access decision must pass through the Controller, which evaluates the relevant trust predicates associated with the consent and the access request. This provides a clear separation between *what consent represents*, *how stakeholders interact with it*, and *how trust is enforced*.

5.1 MVC Layered Architecture and Component Decomposition

The proposed HALAH framework adopts a layered Model–View–Controller (MVC) architecture to provide a clear separation between consent representation, stakeholder interaction, and security-critical authorisation enforcement. The purpose of this architectural decomposition is not simply to follow a conventional software engineering pattern, but to establish explicit boundaries between the information that represents trust, the interfaces through which participants express their actions, and the mechanisms that determine whether those actions should result in an authorisation decision.

At the highest level, the architecture consists of three complementary layers: the *View Layer*, the *Controller Layer*, and the *Model Layer*. The View Layer represents the interaction boundary with independent healthcare stakeholders. The Controller Layer represents the security decision and coordination boundary. The Model Layer represents the persistent trust, consent, policy, and authorisation state. Sensitive healthcare data are treated as protected resources whose access is mediated by the Controller rather than directly exposed to the View.

Figure 3 illustrates the conceptual relationship among these layers with the architectural separation between stakeholder interaction, trust enforcement, and persistent governance state. The View Layer contains role-specific interaction interfaces through which patients, guardians or other authorised participants, healthcare professionals, and auditors submit or inspect system operations. These interfaces are intentionally separated from the security decision mechanism: an action submitted through the View represents a request or claim rather than a trusted authorisation outcome.

The Controller Layer constitutes the principal security enforcement boundary. It receives requests from the View and coordinates the evaluation of the relevant trust conditions. These include request validation, decentralised identity verification, credential and authority verification, multi-party approval evaluation, policy and data-scope evaluation, and final authorisation. The Controller also generates audit evidence associated with the resulting decision. Consequently, the Controller acts as the coordination point through which sensitive operations must pass before protected healthcare data can be accessed.

The Model Layer maintains the persistent security and governance state required by these evaluations. It includes identity and DID information, credential and authority evidence, consent objects, approval evidence, policy and data-scope constraints, authorisation evidence, and lifecycle state. The Model therefore provides the information required for the Controller to evaluate an access request, but the existence of a Model object does not itself imply that access is permitted.

The protected healthcare data are deliberately positioned outside the three MVC layers as a protected resource. This distinction is important because healthcare data should not be

Add Table 5A mapping each MVC layer to the HALAH source files – see A35.1.

► INSERT A35.1 (red page after p.35)

A35.1 - New paragraph and Table 5A at the end of §5.1 (before §5.1.1)

Links the architecture to the actual HALAH source code (repository commit 0a960ca, 22 Sep 2026).

Implementation mapping. Table 5A shows how the three MVC layers are realised in the HALAH prototype. The mapping makes the architectural claims in this chapter directly checkable against the source code.

Table 5A: MVC layers and their HALAH implementation

Layer	HALAH module(s)	Responsibility
View	app.py (Patient, Guardian, Doctor, Auditor pages); halah_theme.py	Role-specific interaction; submits requests only
Controller	services/consent_service.py	Consent creation (Algorithm 1)
	services/identity_service.py	DID check; EIP-712 approval signing and verification (Algorithm 2, VI)
	services/state_service.py	Consent state: PENDING_SIGNATURE, PENDING_TOKEN, NOT_STARTED, EXPIRED, REVOKED, ACTIVE (VA, VT)
	services/access_service.py	check_scope(), authorize(), evaluate_allow() decision matrix (Algorithm 4, VP)
	services/blockchain_service.py, services/anchor_service.py	SBT minting, revocation and on-chain anchoring (evidence E)
Model	models/consent.py, models/access.py	Consent object C = (I, A, P, T, L, E) and access request R
	database/ (SQLite persistence, audit log, DID mapping)	Persistent consent, approval and audit state
Protected resource	data/synthea/*.csv via database/repository.py	Synthetic EMR modules [38], released only after authorisation
Smart contracts	contracts/ConsentSBTv3.sol	Soulbound consent token; on-chain validity; ERC-5484 burn [40]

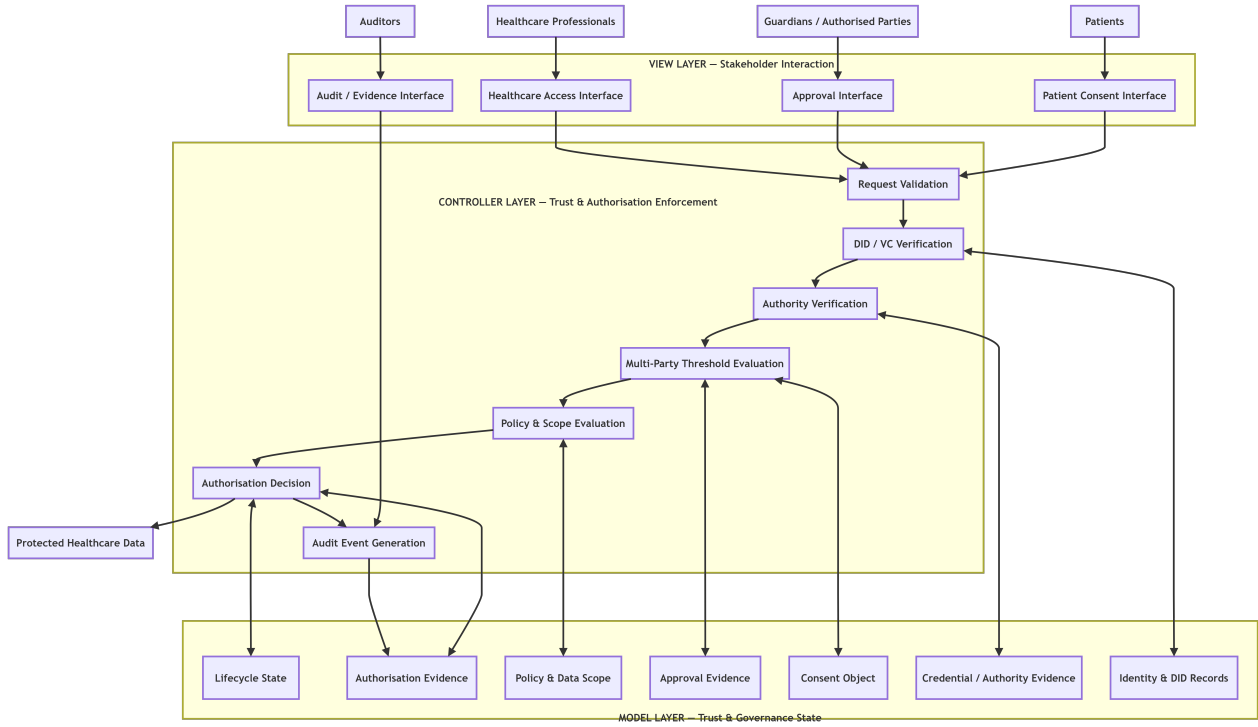
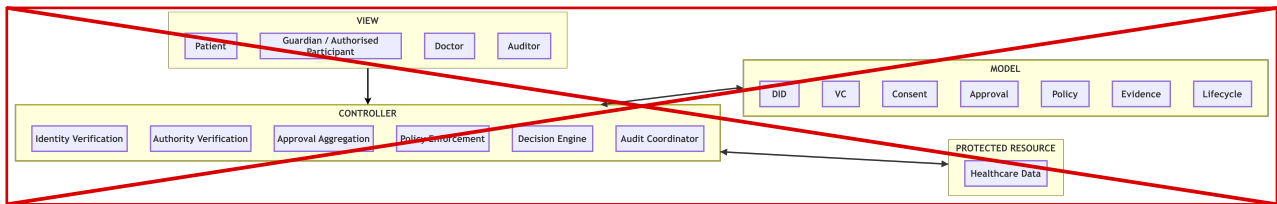


Figure 3: Layered MVC Architecture and Component Decomposition of the HALAH Framework

treated as ordinary application state that can be directly manipulated by the View. Instead, access to the protected resource is mediated by the Controller after the relevant trust conditions have been evaluated.

5.1.1 MVC Component Decomposition

The three architectural layers are further decomposed into functional components, each corresponding to a distinct responsibility within the trust-oriented authorisation process. ~~Figure 4 presents this decomposition.~~ The View is decomposed according to the principal stakeholder



DELETE Figure 4
- duplicates
Figure 3 and its
labels are
unreadable at
print size. Keep
the text of
§5.1.1.

~~Figure 4: Functional Decomposition of the MVC Components~~

roles. The patient interface supports consent specification and consent-related actions. The guardian or other authorised-participant interface supports independent approval. The healthcare professional interface supports authorised data-access requests. The auditor interface supports inspection of authorisation evidence and audit history. These interfaces represent

different interaction responsibilities but share the same architectural principle: none of them independently determines whether access should be granted.

The Controller is decomposed into six principal security functions. *Identity Verification* establishes whether a participant can be identified through the relevant decentralised identity mechanism. *Authority Verification* evaluates whether the participant possesses appropriate evidence concerning the required role or authority. *Approval Aggregation* determines whether independently verified approvals satisfy the predefined threshold. *Policy Enforcement* evaluates whether the requested purpose and data scope comply with the consent policy. *Decision Engine* combines the resulting predicates into the final authorisation decision. Finally, *Audit Coordination* records the relevant evidence and decision events.

The Model is decomposed into seven principal state representations. The DID component represents decentralised identity information; the VC component represents credential and authority evidence; the Consent component represents the structured patient authorisation object; the Approval component represents verified multi-party approval evidence; the Policy component represents purpose and data-scope constraints; the Evidence component represents evidence generated throughout the authorisation process; and the Lifecycle component represents the current state of the consent object and its permissible transitions.

This decomposition establishes an explicit distinction between *state*, *interaction*, and *enforcement*. The Model stores and represents security-relevant state, the View expresses stakeholder actions, and the Controller determines whether those actions satisfy the required trust conditions.

5.1.2 Trust Evaluation Across the MVC Layers

The architectural layers cooperate through a controlled authorisation sequence rather than through unrestricted direct communication. The relationship between the MVC components and the trust predicates introduced by SRQ1–SRQ5 is illustrated in Figure 5.

Figure 5 provides the logical relationship between the architectural components and the integrated trust model. A healthcare data-access request is not evaluated according to a single authentication event. Instead, the Controller coordinates a sequence of trust predicates representing the conditions established by SRQ1–SRQ5.

The first condition, $V_I(u)$, determines whether the requesting participant possesses valid identity and authority evidence. The second condition, $V_A(C)$, determines whether the required independently verified participants have collectively satisfied the authorisation threshold. The third condition, $V_P(C, R)$, determines whether the requested operation complies with the consent policy, including purpose and data-scope restrictions. The fourth condition, $V_T(C, t)$, determines whether the consent remains valid at the time of the request. The fifth condition, $V_L(C)$, determines whether the consent remains in a valid lifecycle state.

The integrated decision can therefore be expressed as

$$\text{Decision}(C, R, t) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (31) \quad \text{Repeat - delete; cite Eq. (27)}$$

The Controller does not itself create these trust conditions. Instead, it evaluates evidence represented by the Model and coordinates the resulting decision. This distinction is important for the interpretation of the architecture: the Controller is a *decision-enforcement mechanism*, whereas the Model is a *representation of trust and governance state*.

If any required predicate evaluates to false, the decision is

$$\neg(V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L) \implies \text{Decision}(C, R, t) = \text{DENY}. \quad (32) \quad \text{Repeat - delete; cite Eq. (21)}$$

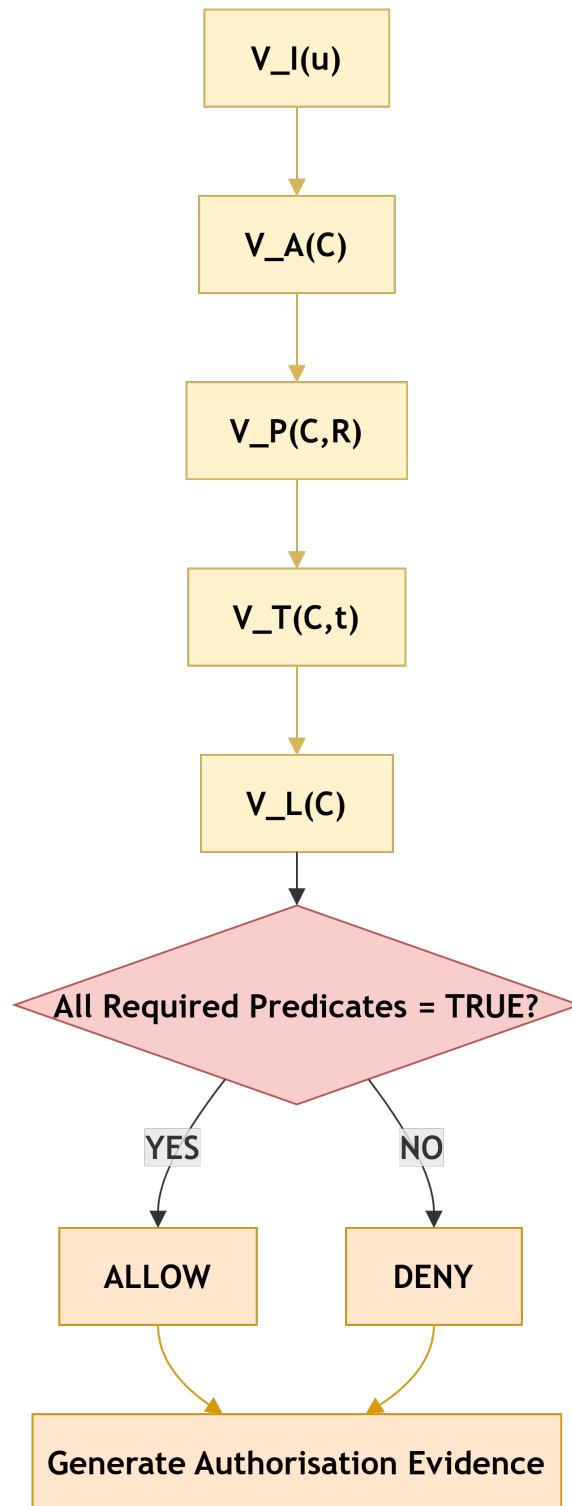


Figure 5: Trust Predicate Evaluation and Authorisation Decision Flow

Both successful and unsuccessful decisions are subsequently associated with authorisation evidence. This ensures that the architecture supports not only access enforcement but also accountability and subsequent verification.

5.1.3 Relationship Between MVC Layers and Research Questions

The MVC decomposition provides an implementation-oriented mapping of the six sub-research questions. SRQ1 is primarily represented by the Model through the trust-aware consent object. SRQ2 is implemented through the interaction between the Model and Controller, where decentralised identities and verifiable credentials are represented and verified. SRQ3 is primarily enforced by the Controller through verified multi-party approval and threshold evaluation. SRQ4 is implemented through the interaction between the consent and policy representations in the Model and the policy-enforcement functions of the Controller.

SRQ5 extends the Model and Controller with temporal and lifecycle information. Temporal conditions and lifecycle state are represented in the Model, while their validity is evaluated by the Controller before an access decision is produced. SRQ6 operates across the complete architecture rather than being confined to a single MVC layer. Formal security assurance evaluates the logical properties of the integrated model, while empirical validation evaluates whether the implementation consistently realises those properties.

The relationship can therefore be summarised as following

$$\begin{aligned}
 SRQ1 &\rightarrow Model, \\
 SRQ2 &\rightarrow Model + Controller, \\
 SRQ3 &\rightarrow Controller, \\
 SRQ4 &\rightarrow Model + Controller, \\
 SRQ5 &\rightarrow Model + Controller, \\
 SRQ6 &\rightarrow Model + View + Controller.
 \end{aligned}$$

This mapping demonstrates that MVC functions as the implementation architecture through which the conceptual research questions are operationalised. It does not replace the trust model; rather, it provides the structural boundaries through which the trust model can be implemented, evaluated, and validated.

5.1.4 Architectural Boundary and Trust Assumptions

The layered architecture also establishes explicit trust boundaries. The View is considered an interaction boundary and therefore cannot be treated as a trusted source of authorisation decisions. Participant actions originating from the View must be independently verified by the Controller.

The Controller represents the security enforcement boundary. It is responsible for applying the authorisation rules consistently and for preventing direct access to protected healthcare data when the required trust conditions are not satisfied.

The Model represents the security-state boundary. Its records provide the evidence and state required for authorisation evaluation, but stored state alone does not constitute permission. In particular, the presence of a consent record, credential, or approval record cannot independently produce an access decision.

The protected healthcare data represent the final resource boundary. Access is permitted only through the authorisation path enforced by the Controller. This separation reduces the possibility that presentation-layer operations or stored records can bypass the security decision mechanism.

These boundaries are important for interpreting the security contribution of the architecture. The proposed framework does not claim that MVC itself provides security. Instead, security arises from the explicit placement of trust-sensitive operations within the Controller, the structured representation of security state within the Model, and the prevention of direct security decisions at the View layer.

Accordingly, the MVC architecture provides the structural foundation for implementing the trust-oriented authorisation model. The subsequent sections describe each layer in greater detail, beginning with the Model representation of trust-aware consent and authorisation state, followed by the View interaction mechanisms and Controller-based enforcement mechanisms.

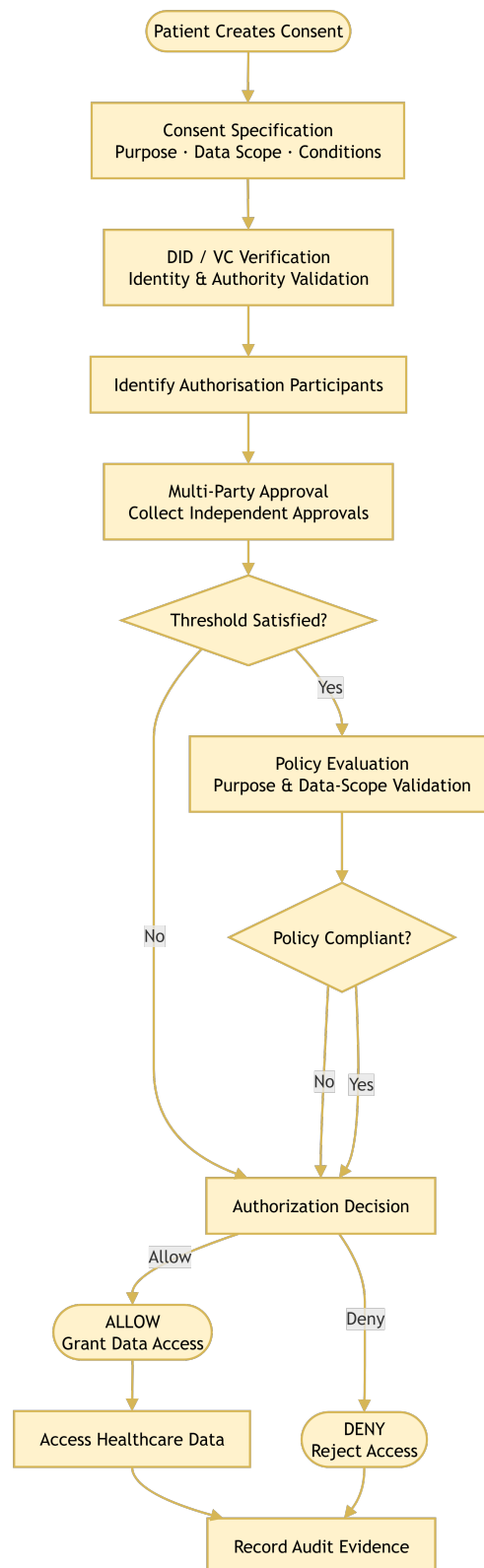
5.2 Trust-Oriented Consent ~~Authorisation~~ Authorization Workflow

Figure 6 presents the end-to-end workflow of the proposed trust-oriented patient consent ~~authorisation~~ authorization framework. The workflow ~~operationalises~~ operationalizes the central premise of this research that trustworthy healthcare data access cannot be established by a single mechanism, such as a blockchain record or an authenticated identity. Instead, an access decision should be established through the coordinated verification of consent specifications, participant identity and authority, multi-party ~~authorisation~~ authorization, and policy compliance. Accordingly, the proposed workflow transforms a patient’s consent from a static permission record into an evaluable ~~authorisation~~ authorization object that can be verified before healthcare data are released.

The workflow begins when the patient creates a consent request and specifies the conditions under which healthcare data may be accessed. The consent specification defines the intended purpose, permitted data scope, and other ~~authorisation~~ authorization conditions. This step establishes what the patient intends to ~~authorise~~ authorize and provides the policy context against which subsequent access requests can be evaluated. Therefore, consent is not represented merely as an approval flag, but as a structured object containing the information required for subsequent ~~authorisation~~ authorization decisions.

The next stage performs ~~decentralised~~ decentralized identity and authority verification using Decentralised Identifiers (DIDs) and Verifiable Credentials (VCs). The purpose of this stage is to establish both the identity of the participant and the evidence supporting the participant’s claimed role or authority. Importantly, the framework explicitly separates identity authentication from ~~authorisation~~ authorization. A successfully verified DID or VC demonstrates that a participant can be identified and that relevant credentials are valid; it does not, by itself, grant permission to access patient data. This distinction is fundamental to the proposed trust model because an authenticated participant should not automatically be considered an ~~authorised~~ authorized participant.

After identity and authority verification, the framework identifies the participants required to establish the consent decision. The ~~authorisation~~ authorization requirement may involve multiple independent participants, such as a patient together with one or more guardians or other ~~authorised~~ authorized parties. The framework then collects their independent approvals and evaluates whether the predefined ~~authorisation~~ authorization threshold has been satisfied. Let A_v denote the set of successfully verified approvals and let N denote the required ~~authorisation~~ authorization threshold. Multi-party ~~authorisation~~ authorization is satisfied when



Also edit the diagram itself: node 'Authorization Decision' → 'Authorisation Decision', and the caption.

Figure 6: End-to-End Workflow of Trust-Oriented Consent ~~Authorization~~ ^{Authorisation} Framework

$$V_A(C) = \begin{cases} 1, & |A_v| \geq N, \\ 0, & |A_v| < N. \end{cases} \quad (33)$$

Repeat - delete;
cite Eq. (9)

If the required threshold is not satisfied, the ~~authorization~~ ^{authorisation} process terminates with a denial decision. This prevents a single participant from unilaterally establishing ~~authorization~~ ^{authorisation} when the consent policy requires collective approval.

When the ~~authorization~~ ^{authorisation} threshold is satisfied, the workflow proceeds to policy evaluation. At this stage, the requested access is evaluated against the purpose and data-scope constraints defined in the consent object. This step addresses an important limitation of identity-based and approval-based access control: a legitimate participant may still request data that fall outside the scope of the patient's consent. ~~For example, if a consent permits access to Observation, Medication, a request additionally containing Procedure should not be authorized because~~

Repeat - delete;
write: 'For
example, the
request in Eq. (4)
must be denied
(Eq. (5)).'

$$S_R \not\subseteq S_C, \quad (34)$$

~~where S_R represents the requested data scope and S_C represents the consent authorized scope.~~ Similarly, the requested purpose must be consistent with the purpose specified in the consent. Consequently, a valid identity and sufficient multi-party approval are necessary but not sufficient conditions for access.

The final ~~authorization~~ ^{authorisation} decision is therefore determined by the conjunction of identity and authority verification, multi-party ~~authorization~~ ^{authorisation}, and policy compliance. For the current stage scope of the proposed framework, the decision can be expressed as

$$\text{Decision}(C, R) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R), \quad (35)$$

Repeat - delete;
cite Eq. (6)

where $V_I(u)$ represents the validity of the requesting participant's identity and authority evidence, $V_A(C)$ represents satisfaction of the required multi-party ~~authorization~~ ^{authorisation} threshold, and $V_P(C, R)$ represents compliance between the access request and the consent policy. If any of these conditions is false, the request is denied. Only when all required conditions are satisfied is healthcare data access granted.

Finally, the framework records the resulting ~~authorization~~ ^{authorisation} evidence in the audit layer. Importantly, both successful and denied decisions should be recorded because a trustworthy ~~authorization~~ ^{authorisation} framework requires accountability not only for data that were released but also for access attempts that were rejected. The audit evidence can therefore provide a traceable record of the ~~authorization~~ ^{authorisation} decision, including the relevant consent, participants, policy evaluation, decision outcome, and associated evidence. In this manner, the workflow connects consent specification with identity trust, collective ~~authorization~~ ^{authorisation}, policy enforcement, and accountability, providing the operational foundation of the proposed trust-oriented ~~authorization~~ ^{authorisation} framework.

5.3 Model: Trust-Aware Consent and Authorisation Representation

The Model layer represents the persistent security state of the proposed consent-management framework. Rather than treating consent as a simple binary permission, the framework models

consent as a structured authorisation object that captures the security conditions under which healthcare data may be accessed.

For the ~~current-current~~ stage scope, the core consent object is represented as

$$C = (I, A, P, E), \quad (36)$$

Repeat - delete;
cite Eq. (7)

where I represents identity-related information associated with the relevant participants, A represents the authorisation requirements that must be satisfied before access can be granted, P represents the policy conditions governing purpose and healthcare data scope, and E represents the evidence generated throughout the authorisation process.

The identity component I does not simply store a username or centrally issued account identifier. It represents decentralised identities and the associated evidence required to establish the legitimacy of participating entities. This allows patients, guardians, healthcare professionals, and other participants to be represented as independently identifiable actors rather than as entries controlled exclusively by a central authority.

The authorisation component A defines the conditions under which a consent object may become operational. In particular, it specifies whether a single participant is sufficient or whether multiple independent entities are required to jointly authorise a sensitive healthcare data operation. Let A_v denote the set of participants whose identities and authority have been successfully verified, and let N denote the minimum required approval threshold. The authorisation condition can then be represented as

$$V_A(C) = \begin{cases} 1, & |A_v| \geq N, \\ 0, & |A_v| < N. \end{cases} \quad (37)$$

Repeat - delete;
cite Eq. (9)

This mechanism provides an important departure from conventional consent systems. In a traditional single-owner model, compromise, error, or misuse of one privileged account may be sufficient to produce an authorisation decision. In the proposed framework, trust can instead be distributed across multiple independently verified participants. A sensitive access decision becomes valid only when the defined collective authorisation condition has been satisfied.

The policy component P represents the contextual restrictions associated with the consent. These restrictions may include the intended purpose of access and the healthcare data categories that are permitted to be disclosed. Therefore, the existence of a valid identity and sufficient approval evidence does not automatically authorise unrestricted access to all patient information.

Let S_C denote the healthcare data scope authorised by the consent object and S_R denote the scope requested by an entity. Policy compliance requires

$$S_R \subseteq S_C. \quad (38)$$

If the requested data exceeds the authorised scope, the request must be rejected even if the requester has successfully authenticated and the required number of participants has approved the consent.

The evidence component E represents the verifiable information generated during the authorisation process. This may include identity-verification results, credential-verification results, approval records, policy-evaluation outcomes, access decisions, and audit events. The purpose of E is not merely to record that a decision occurred, but to provide evidence concerning why the decision was produced.

This distinction is particularly important for trustworthy consent governance. A conventional immutable record may demonstrate that a transaction was stored, whereas the proposed model seeks to preserve evidence concerning the conditions that justified the resulting authorisation decision. Consequently, the Model acts as a security-bearing representation of the consent lifecycle rather than as a passive permission database.

For the ~~current-current~~^{current} stage implementation, the Model focuses on the foundational dimensions of identity, authority, multi-party approval, policy constraints, and authorisation evidence. The subsequent next research will extend this representation to include temporal validity, expiration, revocation, lifecycle transitions, and formal security properties.

5.4 View: Controlled Interaction Among Independent Participants

The View layer provides the interaction environment through which independent stakeholders participate in the consent-management process. In the HALAH prototype, these stakeholders may include patients, guardians, healthcare professionals, and auditors. Although these participants interact with different functions of the system, their interfaces do not directly determine the security outcome of an authorisation request.

This separation is essential because user interaction and security enforcement should not be treated as equivalent. For example, a healthcare professional may successfully submit an access request through the interface, but this interaction alone does not establish the right to access patient information. Similarly, a guardian may submit an approval, but the approval does not become effective unless the corresponding identity and authority conditions have been verified and the required multi-party threshold has been satisfied.

The View therefore functions as a controlled mechanism for expressing requests and authorisation intent. A patient may create a consent specification and identify the relevant healthcare participant, authorised purpose, permitted data categories, and required approval conditions. Guardians or other authorised participants may subsequently submit their approval. Healthcare professionals may submit data-access requests, while auditors may inspect the resulting evidence and authorisation history.

The separation between interaction and enforcement prevents the user interface from becoming the source of trust. A request submitted through the View represents an *input to the authorisation process*, rather than an authorisation decision itself. The actual security decision remains the responsibility of the Controller.

This distinction is particularly important in decentralised environments where different stakeholders may not fully trust one another. The proposed architecture therefore treats each user action as a claim that must be independently evaluated rather than as an automatically trusted system operation.

5.5 Controller: Trusted Multi-Party Authorisation Enforcement

The Controller represents the central decision coordination mechanism of the proposed framework. Its responsibility is to transform consent specifications, participant credentials, approval evidence, and access requests into a deterministic authorisation decision.

The Controller first evaluates whether the requesting entity and relevant authorisation participants possess valid identities and credentials. Identity verification can be represented as

$$\cancel{V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u),} \quad (39) \quad \text{Repeat - delete; cite Eq. (8)}$$

where $\text{VerifyDID}(u)$ determines whether the decentralised identity of participant u can be verified and $\text{VerifyVC}(u)$ determines whether the associated credential provides valid evidence of the relevant authority or role.

A central principle of the proposed architecture is that identity verification and authorisation authority are not equivalent. A participant may possess a valid identity while lacking the authority required to access a particular patient's healthcare information. Therefore,

$$\cancel{\text{Identity} \neq \text{Authorisation}.} \quad (40) \quad \text{Repeat - delete; cite Eq. (1)}$$

This distinction prevents successful authentication from being incorrectly interpreted as unrestricted permission.

After identity and authority conditions have been evaluated, the Controller determines whether the multi-party authorisation requirements associated with the consent object have been satisfied. Only independently verified participants can contribute to the authorisation evidence set A_v . If the number of valid approvals is below the required threshold N , the consent cannot produce an effective authorisation decision.

The Controller then evaluates the relationship between the access request R and the policy conditions contained within the consent object. This process determines whether the requested healthcare data, operation, and intended purpose remain within the permitted authorisation boundary. The corresponding policy predicate can be represented as

$$\cancel{V_P(C, R) = \text{Policy}(C, R).} \quad (41) \quad \text{Repeat - delete; cite Eq. (11)}$$

The overall current stage authorisation decision is therefore determined by the conjunction of the foundational trust conditions:

$$\cancel{\text{Decision}(C, R) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R).} \quad (42) \quad \text{Repeat - delete; cite Eq. (6)}$$

~~Equivalently, the decision can be represented as~~

$$\cancel{\text{Decision}(C, R) = \begin{cases} \text{ALLOW}, & V_I(u) = 1 \wedge V_A(C) = 1 \wedge V_P(C, R) = 1, \\ \text{DENY}, & \text{otherwise.} \end{cases}} \quad (43) \quad \text{Delete - restates Eq. (6).}$$

The security significance of this formulation is that no individual condition is sufficient to produce an access decision. A valid identity without sufficient multi-party approval does not result in access. Similarly, sufficient approval without policy compliance cannot authorise disclosure beyond the permitted healthcare data scope.

This creates a conjunctive trust model in which the failure of any required condition prevents the final authorisation decision. More importantly, the Controller provides a single security-enforcement point through which all sensitive operations must be evaluated. This reduces the risk that different components independently interpret consent conditions and produce inconsistent access decisions.

5.6 Multi-Party Consent as Distributed Trust Establishment

A central contribution of the proposed architecture is the treatment of multi-party consent as a distributed trust-establishment mechanism rather than as a simple collection of multiple signatures.

In conventional approval systems, multiple signatures may simply be appended to a document or transaction. However, the presence of multiple approvals does not necessarily establish that the approving entities were legitimate, possessed the appropriate authority, or approved the same policy conditions.

The proposed framework therefore associates each approval with independently verifiable identity and authority information. An approval contributes to the effective authorisation condition only when the corresponding participant satisfies the identity and credential requirements defined by the framework.

Let the set of submitted approvals be denoted by

$$A_s = \{a_1, a_2, \dots, a_m\}. \quad (44)$$

The verified approval set is then derived as

$$A_v = \{a_i \in A_s \mid V_I(a_i) = 1 \wedge Authority(a_i) = Valid\}. \quad (45)$$

Only the verified set A_v contributes to the threshold condition. Consequently, an arbitrary number of unverified or unauthorised approvals cannot satisfy the multi-party authorisation requirement.

This mechanism provides resistance against several classes of authorisation failure. A compromised or unauthorised participant cannot independently activate access when the threshold has not been satisfied. Similarly, an invalid identity cannot increase the approval count merely by submitting an approval action through the user interface.

The architectural contribution therefore lies in the combination of identity verification and collective decision making. Trust is not assumed to reside in a single privileged entity. Instead, it emerges from the coordinated satisfaction of independently verifiable requirements across multiple participants.

5.7 Policy-Aware Consent Enforcement

Another important feature of the architecture is the explicit separation between *approval validity* and *access scope validity*. Even when all required participants have approved a consent request, the resulting authorisation remains bounded by the policy encoded within the consent object.

~~Suppose that a consent permits access to the following healthcare data categories that~~

~~$$S_C = \{Observation, Medication\}. \quad (46)$$~~

~~If a healthcare professional subsequently requests~~

~~$$S_R = \{Observation, Medication, Procedure\}, \quad (47)$$~~

~~the request exceeds the authorised data scope because~~

~~$$S_R \not\subseteq S_C. \quad (48)$$~~

Replace with:
'For example, if a healthcare professional requests the scope in Eq. (4), the request exceeds the consented scope (Eq. (5)) and the Controller must return DENY.'

~~The Controller must therefore return~~

$$\text{Decision}(C, R) = \text{DENY}. \quad (49)$$

This property is important because conventional authentication and role-based access-control mechanisms may determine that an entity is generally authorised to access a category of healthcare information without adequately considering the specific policy conditions associated with an individual patient's consent.

The proposed architecture instead binds the access decision to the consent policy itself. Consent therefore becomes an active authorisation constraint rather than a historical indication that a participant was once granted permission.

This policy-centric approach also provides a basis for future extensions. While the current stage implementation focuses on purpose and healthcare data scope, the same mechanism can subsequently incorporate additional contextual conditions, including location, organisation, treatment relationship, emergency status, temporal restrictions, and other regulatory constraints.

5.8 Authorisation Evidence and Auditability

The proposed architecture further distinguishes between *making* an authorisation decision and *demonstrating* how that decision was made. For this reason, the Controller generates evidence associated with each relevant stage of the authorisation process. Conceptually, an authorisation evidence record can be represented as

$$E_R = \{ID, Credential, Approval, Policy, Decision, Audit\}. \quad (50)$$

where *ID* represents identity-verification evidence, *Credential* represents authority or role-verification evidence, *Approval* represents the verified multi-party approval state, *Policy* represents the result of policy evaluation, *Decision* represents the final access outcome, and *Audit* represents the associated event record.

The resulting audit trail provides a stronger governance capability than a simple record of successful access. An auditor can examine not only whether access occurred, but also whether the requester possessed a valid identity, whether the required authorisation threshold was satisfied, whether the requested data complied with the authorised scope, and which conditions produced the final decision.

Blockchain or other tamper-resistant storage mechanisms may be integrated as infrastructure for preserving selected authorisation evidence. However, the blockchain itself is not treated as the source of trust. Its role is to strengthen integrity, non-repudiation, and auditability of the evidence generated by the authorisation process.

The trustworthiness of the access decision instead originates from the coordinated enforcement of identity, authority, multi-party approval, and policy conditions.

5.9 Architectural Security Properties

The proposed MVC architecture provides several foundational security properties for the current stage. These properties emerge from the interaction between the Model, View, and Controller rather than from any single technology.

First, the architecture provides *identity-dependent participation*. A participant cannot contribute to the authorisation process solely by interacting with the system interface. The corresponding identity and credential must satisfy the verification requirements.

Second, the architecture provides *authority separation*. Possession of a valid identity does not automatically result in permission to access patient data. Identity verification provides evidence concerning who an entity is, whereas authority verification determines whether that entity may perform a particular role within the authorisation process.

Third, the architecture provides *collective authorisation integrity*. Sensitive healthcare data access can be configured to require multiple independently verified participants. Therefore, a single participant cannot unilaterally activate access when the defined authorisation threshold has not been reached.

Fourth, the architecture provides *policy-bounded access*. A valid requester with sufficient approval evidence cannot access healthcare information beyond the purpose or data scope defined by the consent object.

Finally, the architecture provides *decision accountability*. The system maintains evidence concerning the conditions that produced an authorisation decision, thereby supporting auditing and subsequent verification. These properties can be summarised as shown in Table 5.

5.10 MVC Architecture and the Research Objectives

The MVC architecture also provides a direct implementation structure for the research objectives. RO1 is primarily represented in the Model through the development of the trust-aware consent object. RO2 is implemented through the identity and authority verification mechanisms coordinated by the Controller. RO3 is realised through the multi-party approval and threshold evaluation process. RO4 is implemented through the policy evaluation mechanisms that constrain the authorised purpose and healthcare data scope.

As shown in Table 6, the View provides the operational environment through which these mechanisms are exercised by independent participants. Importantly, the View does not determine whether an operation is authorised. Instead, it captures participant actions and forwards them to the Controller, which evaluates the security predicates defined by the Model.

5.11 Architectural Contribution and Scope

The principal contribution of the proposed architecture is not the use of MVC itself, but the way in which MVC is employed to operationalise a trust-oriented authorisation model. The Model provides a structured representation of the conditions that define valid consent. The View enables multiple independent stakeholders to express consent-related intentions without directly determining security outcomes. The Controller coordinates independently verifiable trust conditions and produces the final authorisation decision.

This design transforms multi-party consent management from a conventional record-management problem into a distributed security-governance problem. The key innovation is that consent is treated as an active and evaluable authorisation object whose effectiveness depends on the joint satisfaction of identity, authority, collective approval, and policy conditions.

For the current stage, the architecture therefore establishes the foundational mechanisms required to answer RQ1–RQ4. The implemented HALAH prototype provides the practical

Overfull line
(original
typesetting) –
rephrase or allow
hyphenation in
LaTeX.

Table 5: Security Properties Supported by the Proposed MVC-Based Consent Architecture

Security Property	Prop- erty	Architectural nism	Mecha- nism	Security Significance
Identity-dependent participation		DID and credential verification before a participant can contribute to the authorisation process		Prevents unverified entities from being treated as legitimate participants.
Authority separation		Independent evaluation of identity and role or authority evidence		Prevents successful authentication from being interpreted as unrestricted authorisation.
Multi-party authorisation integrity		Threshold evaluation over independently verified approval participants		Prevents a single participant from unilaterally activating sensitive healthcare data access when collective approval is required.
Policy-bounded access		Evaluation of purpose and requested data scope against consent policy		Prevents otherwise valid identities and approvals from being used to obtain data beyond the authorised scope.
Authorisation evidence		Recording of verification results, approval evidence, policy evaluation, and final decisions		Provides traceability and supports accountability, auditing, and future verification.
Separation of interaction and enforcement		The View submits requests while the Controller independently determines the security decision		Prevents user-interface actions from being interpreted directly as trusted authorisation outcomes.

Table 6: Mapping Between Research Objectives and MVC Components

Research Objective	Primary Component	MVC	Core Mechanism	Expected Contribution
RO1	Model		Trust-aware consent representation	Transforms consent from a passive permission record into a structured and evaluable authorisation object.
RO2	Controller and Model		DID and VC verification	Establishes trustworthy participants while explicitly separating identity from authorisation authority.
RO3	Controller		Verified multi-party threshold evaluation	Establishes collective trust and prevents unilateral authorisation when multiple approvals are required.
RO4	Controller and Model		Policy, purpose, and data-scope evaluation	Ensures that valid participants and sufficient approvals remain constrained by the authorised purpose and healthcare data scope.
RO5	Model and Controller		Temporal validity and consent lifecycle enforcement	Ensures that authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced.
RO6	Model, View, and Controller		Formal security analysis and empirical validation	Provides formal assurance of the defined trust and authorisation properties and empirically evaluates whether the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions.

environment in which these mechanisms can be instantiated and evaluated through representative healthcare data-sharing scenarios.

The subsequent stage will extend the architecture beyond the current foundational authorisation model. The consent Model will be expanded to include temporal validity, expiration, revocation, and controlled lifecycle transitions. The Controller will subsequently incorporate the corresponding temporal and lifecycle predicates into the authorisation decision. In addition, the complete decision model will be subjected to formal security analysis and broader empirical validation.

Accordingly, the current stage architecture establishes the foundational security core of the research, while ~~next stage will~~ investigate whether this core can maintain trust dynamically over time, satisfy formally defined security properties, and consistently enforce the complete trust-oriented authorisation model under representative and adversarial healthcare data-sharing conditions.

6 Proposed Solution

6.1 Trust-Centric Consent Model for RO1

RO1 addresses RQ1 by developing a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The purpose of this objective is to establish a formal representation of what the patient intends to authorise, who is permitted to participate in the authorisation process, which healthcare data may be accessed, and under what conditions access may be granted. The proposed consent object is represented as

$$C = (I, A, P, E), \quad (51)$$

Repeat - delete; cite Eq. (7)

where I represents patient and participant identity information, A represents authorisation requirements, P represents policy constraints, and E represents authorisation evidence. The identity component identifies the patient and relevant participants. The authorisation component defines the required participants and approval threshold. The policy component specifies the permitted purpose and healthcare data scope. The evidence component records the information required to support subsequent verification and audit.

The consent model therefore separates the specification of consent from the final access decision. A consent object does not automatically imply that every subsequent request is authorised. Instead, the object provides the conditions against which a request can be evaluated.

6.1.1 RO1 Consent Creation Workflow

The following workflow describes the creation of a trust-aware consent object. The process begins with a patient request and ends with a structured consent record that can be verified by subsequent authorisation services.

The workflow first collects the patient identity and the intended healthcare participants. It then specifies the purpose and data scope of the consent. In the HALAH implementation, the patient interface allows the patient to select a patient DID, specify an authorised doctor, identify guardian DIDs, and select healthcare data modules such as Observation, Medication, Condition, and Procedure. The implementation also collects the start and expiry time of the consent.

Add '(Figure 13)' - screenshot added in §7.7.

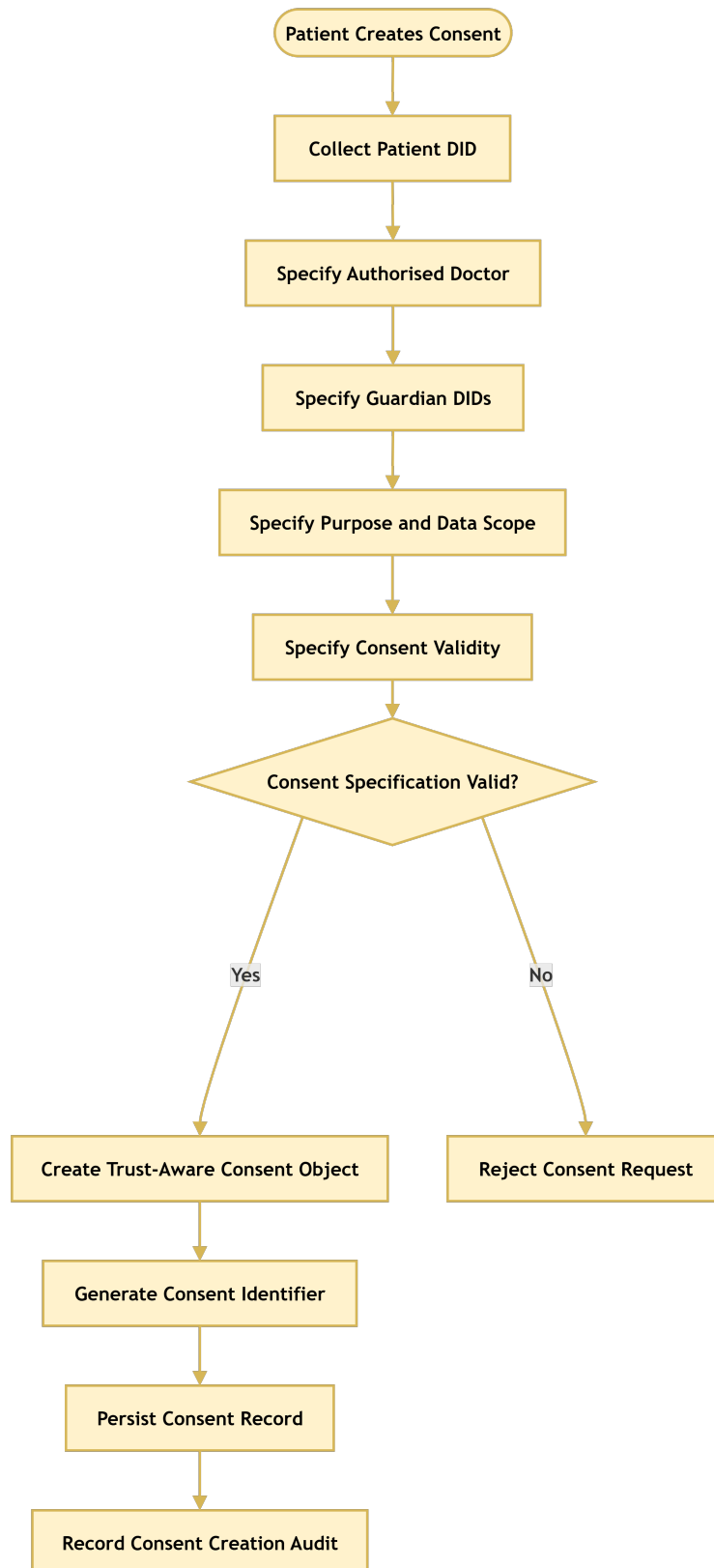


Figure 7: RO1 workflow for trust-centric consent creation

The specification is accepted only when the required fields are valid. For example, the expiry time must be later than the start time. After validation, the system creates the consent object, assigns a consent identifier, persists the record, and records the creation event in the audit layer. This process ensures that the consent object contains sufficient information for subsequent identity verification, multi-party authorisation, policy evaluation, and auditability.

6.1.2 Procedure for Trust-Aware Consent Creation

The Trust-Aware Consent Creation procedure establishes a valid and auditable consent object by sequentially validating the participating entities, consent purpose, data scope, and temporal constraints before the consent is persisted. The procedure consists of the following steps.

1. Step 1 – Validate Patient Identity.

The system first validates the patient's identity I_p . The identity is checked against the available identity and credential verification mechanisms to ensure that the consent request originates from a recognised patient entity. If I_p cannot be successfully validated, the procedure terminates immediately and returns *REJECT*.

Prototype v1.1:
Steps 1-3
perform a
syntactic DID
check only;
credential/author
ity validation is
Stage 2. Say so
in one sentence
at the end of this
procedure.

2. Step 2 – Validate the Authorised Doctor.

The system validates the identity and authorisation status of the designated doctor D . This step determines whether the doctor is a recognised healthcare participant and whether the presented credentials are sufficient for participation in the requested consent relationship. An invalid or unauthorised doctor results in rejection of the consent request.

3. Step 3 – Validate Guardian or Proxy Participants.

If a guardian or proxy is specified, the system validates the guardian set G . Each guardian is checked to determine whether the individual or entity possesses the required authority to participate in consent-related decisions. This step prevents an arbitrary third party from being treated as an authorised representative of the patient.

4. Step 4 – Validate the Intended Purpose.

The intended data-use purpose P_u is validated to ensure that the purpose is explicitly specified and conforms to the supported healthcare-use policies. The purpose is subsequently bound to the consent object so that authorisation is not interpreted as unrestricted access to the patient's healthcare information.

5. Step 5 – Validate the Data Scope.

The requested data scope S_C is validated to determine precisely which healthcare resources may be accessed under the consent. The scope may represent specific resource categories, such as observations, medications, procedures, or other FHIR resources. This step establishes the principle of least privilege by ensuring that consent is associated with explicitly defined data resources rather than the patient's entire healthcare record.

6. Step 6 – Validate the Consent Validity Interval.

The system validates the temporal validity interval $T = (t_s, t_e)$, where t_s represents the consent start time and t_e represents the expiration time. The system verifies that the interval is logically valid by requiring $t_e > t_s$. If this condition is not satisfied, the consent request is rejected.

Implemented:
the Patient view
rejects expiry $\leq$
start (app.py).

7. Step 7 – Define the Authorisation Requirement.

After all input elements have been validated, the system defines the authorisation requirement A . This requirement specifies the conditions that must subsequently be satisfied before access can be granted. Depending on the system configuration, A may incorporate patient approval, guardian approval, doctor authority, role requirements, multi-party approval, scope restrictions, purpose restrictions, and temporal constraints.

8. Step 8 – Generate a Unique Consent Identifier.

The system generates a unique consent identifier id_C . This identifier provides a persistent reference to the consent object and enables subsequent operations, including consent verification, access authorisation, modification, revocation, and audit.

9. Step 9 – Construct the Consent Object.

The validated information is combined to construct the consent object

$$C = (I, A, P, E),$$

where I represents the verified identity information, A represents the authorisation requirements, P represents the consent purpose and associated permissions, and E represents the evidence associated with the consent decision. The resulting object therefore captures not only the patient's preference but also the evidence required to support subsequent authorisation decisions.

10. Step 10 – Persist the Consent Object.

The constructed consent object C is persisted in the consent-management infrastructure. The persistence mechanism provides a stable representation of the consent state that can subsequently be referenced by the access-control and authorisation components.

11. Step 11 – Record Consent Creation Evidence.

Finally, the system records evidence associated with the creation event, including the consent identifier, participating entities, relevant timestamps, and the resulting consent state. This evidence provides an auditable record that can be used to reconstruct and verify the consent lifecycle.

12. Step 12 – Return the Consent Result.

If all validation and construction operations are completed successfully, the system returns the newly created consent object C . If any mandatory validation fails during the process, the system terminates the procedure and returns *REJECT*.

The overall procedure can therefore be represented as a sequential trust establishment process that $I_p \rightarrow D \rightarrow G \rightarrow P_u \rightarrow S_C \rightarrow T \rightarrow A \rightarrow id_C \rightarrow C \rightarrow E$.

This sequence ensures that consent is created only after the relevant identity, authority, purpose, scope, and temporal constraints have been validated. Consequently, the resulting consent object serves not merely as a record of patient preference, but as a structured authorisation artefact that can provide evidence for subsequent healthcare data-access decisions.

Algorithm 1 Trust-Aware Consent Creation

Require: Patient identity I_p , authorised doctor D , guardian set G , purpose P_u , data scope S_C , validity interval T

Ensure: Consent object C or rejection

```
1: Validate  $I_p$ 
2: if  $I_p$  is invalid then
3:   return REJECT
4: end if
5: Validate authorised doctor  $D$ 
6: Validate guardian set  $G$ 
7: Validate purpose  $P_u$ 
8: Validate data scope  $S_C$ 
9: Validate validity interval  $T = (t_s, t_e)$ 
10: if  $t_e \leq t_s$  then
11:   return REJECT
12: end if
13: Define authorisation requirement  $A$ 
14: Generate consent identifier  $id_C$ 
15: Construct  $C = (I, A, P, E)$ 
16: Persist  $C$ 
17: Record consent creation evidence
18: return  $C$ 
```

6.1.3 Algorithm 1: Trust-Aware Consent Creation

Algorithm 1 formalises the creation process. The algorithm does not grant data access directly. Instead, it creates a consent object that can later be evaluated by the authorisation mechanism. This distinction is important because the research treats consent as a structured policy-bound object rather than as a simple Boolean permission.

The algorithm also establishes the relationship between RO1 and the remaining objectives. RO2 uses the identity and authority information contained in I , RO3 evaluates the authorisation requirements contained in A , and RO4 evaluates the policy constraints contained in P . Consequently, RO1 provides the data structure upon which the subsequent trust-oriented authorisation mechanisms operate.

6.2 Decentralised Identity and Authority Trust for RO2

RO2 addresses RQ2 by developing a decentralised identity and authority verification mechanism using Decentralised Identifiers and Verifiable Credentials. The objective is to establish trustworthy participants while explicitly separating identity authentication from authorisation authority.

The central principle of RO2 is

$$\text{Identity} \neq \text{Authorisation.} \quad (52) \quad \text{Repeat - delete; cite Eq. (1)}$$

A valid DID provides an identity reference, while a valid VC provides evidence associated with a participant's role, authority, or other relevant attribute. Neither mechanism should

automatically grant access to patient data. Instead, the verified identity and authority information become inputs to the subsequent authorisation process. The identity verification condition can be expressed as

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u), \quad (53)$$

Repeat - delete; cite Eq. (8)

where u is the requesting participant. The DID verification process establishes whether the identity reference is valid. The VC verification process establishes whether the participant possesses valid authority evidence. The final authorisation decision remains dependent on the consent requirements and access policy.

6.2.1 RO2 Identity and Authority Verification Workflow

The workflow begins when a participant attempts to participate in the consent process or requests access to healthcare data. The system resolves and verifies the participant's DID and then retrieves the associated VC. The credential is checked for validity and its claims are examined to determine whether the participant possesses the authority required by the consent.

~~In the HALAH implementation, the Guardian workflow uses a selected guardian DID and invokes VC verification before adding the guardian's signature to the consent. The code therefore demonstrates the separation between participant identity verification and the subsequent authorisation operation.~~

OVERCLAIM - the code does not verify a VC (verify_vc() only checks the 'did:' prefix). Replace with A56.1.

The output of RO2 is not an access-grant decision. It is a verified identity and authority result that can be consumed by RO3 and RO4. This separation prevents a participant from obtaining access merely by presenting a valid identity credential.

6.2.2 Procedure for DID and VC Identity and Authority Verification

The DID and VC Identity and Authority Verification procedure determines whether a participant possesses a valid decentralised identity and sufficient verifiable authority to participate in the consent-defined authorisation process. The procedure establishes a verifiable relationship between the participant u , the identity information represented by the DID, the attributes contained in the associated VC, and the authority requirements specified by the consent object C . The procedure consists of the following steps.

1. Step 1 – Resolve the Participant's DID.

The system first resolves the decentralised identifier (DID) associated with participant u . DID resolution retrieves the DID-related information required to establish the participant's decentralised identity and identify the corresponding DID document. If the DID cannot be successfully resolved, the verification process terminates and returns *INVALID*.

2. Step 2 – Verify the DID Document.

After successful resolution, the system verifies the DID document and its associated identity information. The verification process determines whether the document is structurally valid and whether the relevant cryptographic information, such as verification methods and public keys, can be trusted for subsequent credential verification. A failed DID verification results in an *INVALID* outcome.

A56.1 - Replacement for the struck paragraph in §6.2.1

Replaces 'In the HALAH implementation, the Guardian workflow uses a selected guardian DID ... subsequent authorisation operation.'

In the HALAH prototype (v1.1), identity and authority are established in two separate steps. First, the guardian's DID is checked for syntactic validity (`verify_vc()` in `services/identity_service.py`). Second, the guardian's approval is expressed as an EIP-712 typed-data signature [39] over the consent identifier, and the approval is accepted only if the address recovered from the signature matches the address bound to that guardian DID. An approval that fails this check is rejected and does not count towards the threshold. For demonstration, guardian keys are derived deterministically from the DID; in deployment, each guardian would sign the same typed data with their own wallet. Full W3C Verifiable Credential verification [41, 42], covering issuer, proof, credential status and validity period (Steps 3–4 below), is specified here but has not yet been implemented and is scheduled for Stage 2 (CA3). The prototype therefore already separates who the guardian is from whether their approval is cryptographically valid, but does not yet verify credential-based authority.

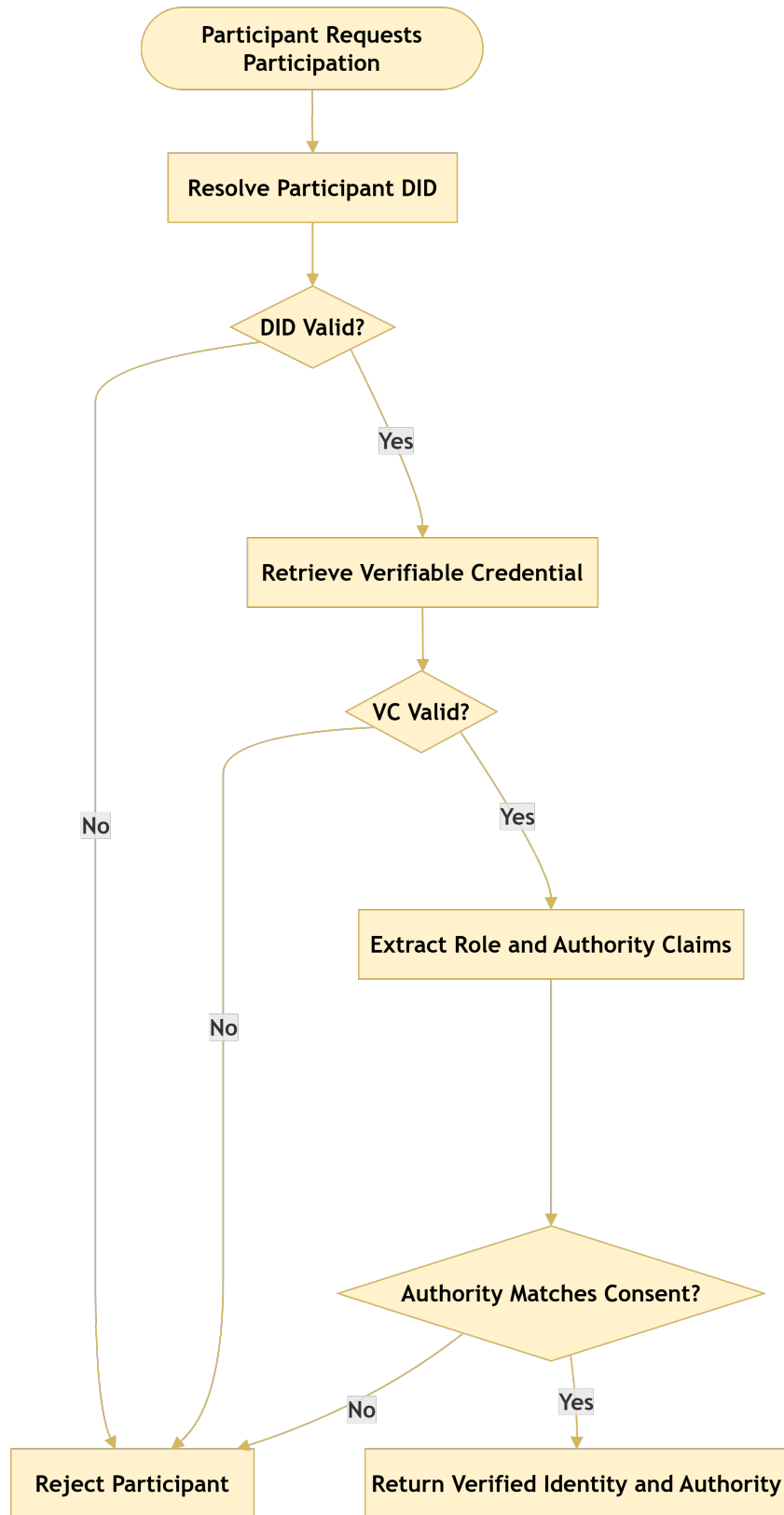


Figure 8: RO2 workflow for decentralised identity and authority verification

3. Step 3 – Retrieve the Participant’s Verifiable Credential.

The system retrieves the verifiable credential (VC) associated with participant u . The VC provides machine-verifiable claims concerning the participant, such as professional role, organisational affiliation, or delegated authority. If an appropriate VC cannot be retrieved, the participant cannot establish the required authority and the verification process returns *INVALID*.

4. Step 4 – Verify the Verifiable Credential.

The retrieved VC is cryptographically and semantically validated. The system verifies the credential signature, issuer, subject, and validity conditions. In particular, the system determines whether the credential was issued by an acceptable issuer, whether it refers to the current participant, whether its signature is valid, and whether the credential remains within its validity period.

Formally, the credential can be considered valid only when

$$VC_{\text{valid}} = \text{Sig}_{VC} \wedge \text{Issuer}_{\text{valid}} \wedge \text{Subject}_{\text{match}} \wedge \text{Time}_{\text{valid}}.$$

If any of these conditions fails, the verification process returns *INVALID*.

5. Step 5 – Extract Role and Authority Claims.

Once the VC has been successfully verified, the system extracts the relevant role and authority claims associated with participant u . Depending on the healthcare scenario, these claims may identify a doctor, guardian, researcher, auditor, or another authorised participant. The extracted claims provide the evidence required for determining whether the participant satisfies the authority requirements of the consent object.

6. Step 6 – Compare Authority Claims with Consent Requirements.

The extracted role and authority claims are compared against the authorisation requirements A specified in the consent object C . The purpose of this step is to ensure that possession of a valid identity or credential is not automatically interpreted as permission to access healthcare information.

The authority verification condition can therefore be represented as

$$\text{Authority}(u, C) = \text{Claims}(u) \models A_C,$$

where $\text{Claims}(u)$ denotes the verified claims associated with participant u , and A_C denotes the authority requirements defined by consent object C .

If the participant’s claims do not satisfy the required authority conditions, the system returns *INVALID*.

7. Step 7 – Establish Identity–Authority Binding.

After the claims have satisfied the consent requirements, the system establishes the binding between the verified participant identity and the corresponding authority. This step ensures that the authority being exercised is associated with the same participant whose DID and VC have been successfully verified, thereby reducing the possibility of an unrelated credential being used to obtain access.

Specified but NOT yet implemented in the prototype (Stage 2). The prototype verifies an EIP-712 approval signature instead (A56.1).

8. Step 8 – Record Identity and Authority Evidence.

The system records the evidence generated during the verification process. The evidence may include the resolved DID, verification status, credential identifier, issuer information, relevant authority claims, verification timestamp, and the relationship between the verified claims and the consent requirements. This evidence provides an auditable basis for subsequent access-authorisation decisions.

9. Step 9 – Return the Verification Result.

If DID resolution, DID verification, VC retrieval, VC verification, and authority validation are all successfully completed, the system returns

$$V_I(u) = \text{VALID}.$$

Otherwise, the procedure terminates at the first failed mandatory verification condition and returns

$$V_I(u) = \text{INVALID}.$$

The overall verification process can therefore be represented as:

$$\begin{aligned} DID_{\text{resolve}} \rightarrow DID_{\text{verify}} \rightarrow VC_{\text{retrieve}} \rightarrow VC_{\text{verify}} \rightarrow Claims_{\text{extract}} \rightarrow Authority_{\text{match}} \\ \rightarrow Evidence_{\text{record}} \rightarrow V_I(u). \end{aligned}$$

The procedure establishes an important separation between *identity verification* and *authority verification*. A participant is not considered valid merely because a DID can be resolved or because a VC has a valid cryptographic signature. Instead, the participant must demonstrate that the verified credential claims satisfy the authority requirements associated with the specific consent object C .

Consequently, the procedure can be interpreted as a two-layer verification mechanism

$$Identity(u) \wedge CredentialValidity(u) \wedge Authority(u, C) \Rightarrow V_I(u) = \text{VALID}.$$

This distinction is important for the proposed framework because a valid healthcare identity does not imply unrestricted access to healthcare data. DID and VC mechanisms provide trustworthy identity and attribute evidence, while the consent object provides the context against which those claims are evaluated. The resulting verification evidence can then be consumed by the subsequent policy, scope, and access-authorisation stages.

6.2.3 Algorithm 2: DID and VC Identity and Authority Verification

Algorithm 2 establishes that identity verification and authority verification are related but distinct operations. A participant may possess a valid DID while lacking the authority required by the consent. Similarly, a credential may be structurally valid but irrelevant to the specific authorisation requirement. Therefore, the algorithm verifies both credential validity and authority relevance.

This mechanism contributes to the trust-oriented framework by converting identity and authority claims into verifiable evidence. However, it does not independently establish collective consent or policy compliance. Those conditions are evaluated by RO3 and RO4.

Algorithm 2 DID and VC Identity and Authority Verification

Require: Participant u , consent object C

Ensure: Verification result $V_I(u)$

```
1: Resolve DID of  $u$ 
2: if DID resolution fails then
3:   return INVALID
4: end if
5: Verify DID document and associated identity information
6: if DID verification fails then
7:   return INVALID
8: end if
9: Retrieve VC associated with  $u$ 
10: if VC retrieval fails then
11:   return INVALID
12: end if
13: Verify VC signature, issuer, subject, and validity
14: if VC verification fails then
15:   return INVALID
16: end if
17: Extract role and authority claims from VC
18: if claims do not satisfy the authority requirements of  $C$  then
19:   return INVALID
20: end if
21: Record identity and authority verification evidence
22: return VALID
```

6.3 Trustworthy Multi-Party Authorisation for RO3

RO3 addresses RQ3 by developing a threshold-based multi-party authorisation mechanism. The objective is to ensure that sensitive healthcare data cannot be accessed through unilateral approval when the consent requires participation from multiple independently verified parties.

Let A_v denote the set of valid approvals and let N denote the required authorisation threshold. The threshold condition is defined as

$$V_A(C) = \begin{cases} 1, & |A_v| \geq N, \\ 0, & |A_v| < N. \end{cases} \quad (54)$$

Repeat – delete; cite Eq. (9)

The threshold mechanism establishes collective authorisation without requiring every possible participant to approve. For example, a consent may require two valid guardian approvals. In this case, one valid approval is insufficient, whereas two valid approvals satisfy the threshold.

6.3.1 RO3 Multi-Party Authorisation Workflow

The workflow first identifies the participants required by the consent. Each participant must submit an approval that can be independently verified. Invalid approvals are rejected and must not contribute to the threshold count. Valid approvals are recorded and the current approval count is updated.

The authorisation becomes active only when the number of valid approvals reaches the required threshold. In the HALAH implementation, the Guardian workflow verifies the guardian VC, appends the guardian DID to the consent signatures, and displays the current approval count relative to the threshold. When the threshold is reached, the implementation assigns an SBT identifier and records the corresponding minting event.

Replace with accurate v1.1 description – A61.1.

The SBT should be interpreted as an activation or representation mechanism for the consent state rather than as the fundamental source of trust. The trust decision is established by the verification of participants and the satisfaction of the authorisation threshold. The blockchain or token layer provides persistence, traceability, and evidence of the resulting state.

6.3.2 Procedure for Threshold-Based Multi-Party Authorisation

The Threshold-Based Multi-Party Authorisation procedure determines whether a consent-defined authorisation requirement has received sufficient valid approvals from the designated participants. Rather than relying on a single approval authority, the procedure requires a predefined number of eligible participants to independently provide valid approvals. This mechanism reduces reliance on a single decision-maker and provides an auditable basis for activating consent-related authorisation.

1. Step 1 – Retrieve the Required Participant Set.

The system first retrieves the required participant set G associated with the consent object C . The set G defines which participants are eligible to contribute an approval to the authorisation process. Depending on the consent configuration, G may contain healthcare professionals, guardians, institutional representatives, or other authorised parties.

A61.1 - Replacement for the struck paragraph in §6.3.1

Replaces 'In the HALAH implementation, the Guardian workflow verifies the guardian VC ... records the corresponding minting event.'

In the HALAH prototype (v1.1), the Guardian workflow (Figure 14) verifies each guardian's EIP-712 approval signature, refuses a second approval from the same guardian, adds the guardian DID to the consent's signature set and displays the approval count against the threshold (e.g., 2/2). When the threshold is reached, a Soulbound Token (SBT) identifier is assigned, a MINT_SBT event is written to the audit log, and the consent is anchored on the Ethereum Sepolia testnet by minting a non-transferable consent token (ConsentSBT; the v3 contract follows ERC-5484 [40]). Four such mints have been recorded on Sepolia (Table 11).

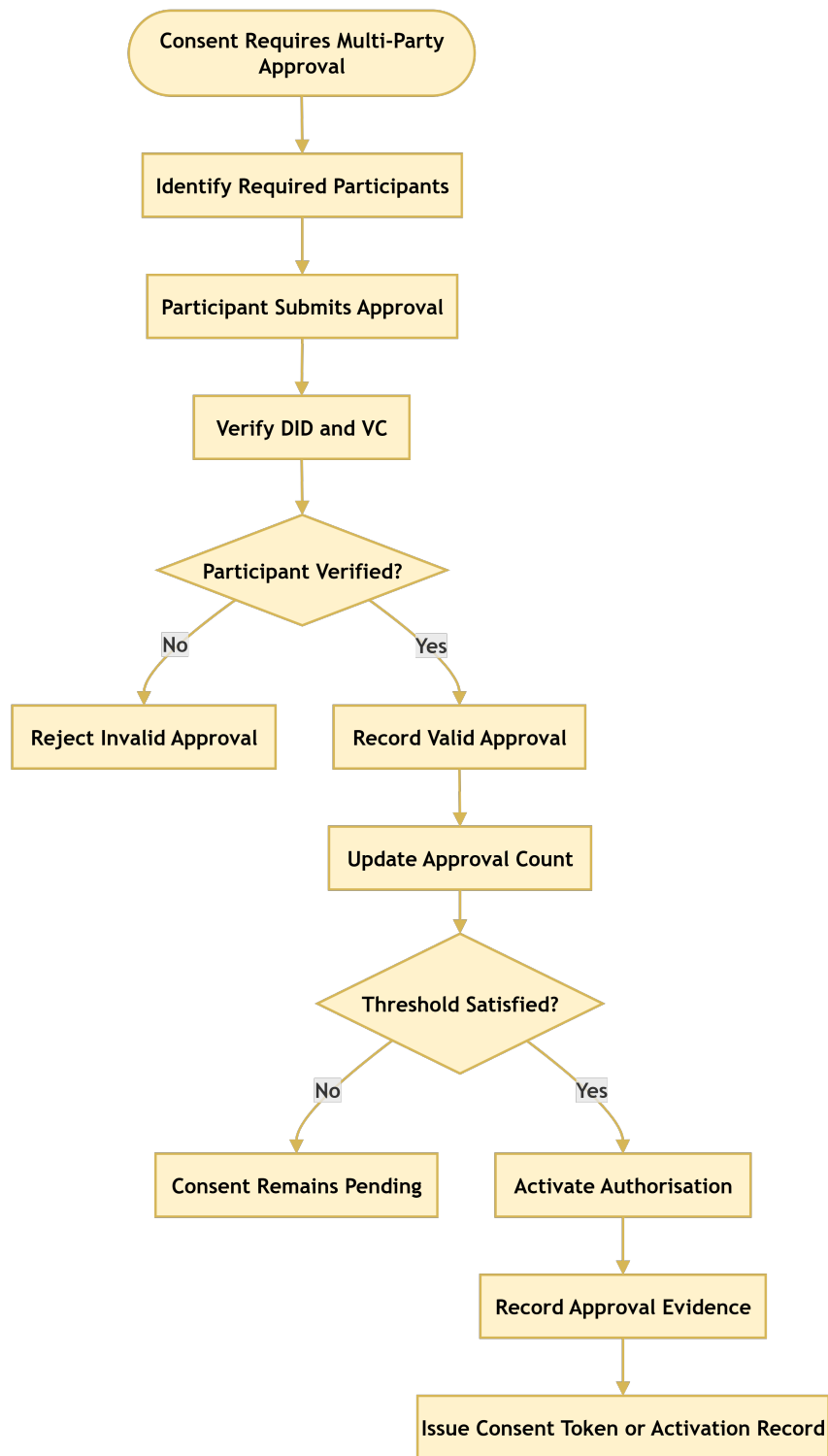


Figure 9: RO3 workflow for threshold-based multi-party authorisation

2. Step 2 – Define the Authorisation Threshold.

The system obtains the threshold value N , which specifies the minimum number of valid and distinct approvals required to activate the authorisation. The threshold must satisfy

$$1 \leq N \leq |G|.$$

The threshold therefore determines how many eligible participants must independently approve the consent before the authorisation becomes active.

3. Step 3 – Receive a Participant Approval.

A participant submits an approval a associated with consent object C . The approval is treated as a candidate authorisation contribution and is not considered valid until the identity and authority of the submitting participant have been verified.

4. Step 4 – Verify the Identity and Authority of the Approving Participant.

The system verifies the identity and authority of the participant submitting a . The verification process may invoke the DID and VC verification procedure described in Algorithm 2. The system therefore determines whether the participant possesses a valid identity and whether the associated authority claims satisfy the requirements of consent object C .

If the verification fails, the approval is classified as invalid. The system records the invalid approval event and returns *DENY* for that approval attempt.

5. Step 5 – Verify Participant Eligibility.

If the participant's identity and authority are successfully verified, the system determines whether the participant belongs to the required participant set G . Formally,

$$u \in G.$$

If the participant is not a member of G , the approval cannot contribute to the threshold. The system records the event as an unauthorised approval attempt and returns *DENY*.

6. Step 6 – Check for Duplicate Approval.

The system checks whether the participant has already approved consent object C . This prevents a single participant from submitting multiple approvals and artificially satisfying the threshold.

Formally, for the valid approval set A_v that

$$u \notin A_v.$$

If the participant has already submitted a valid approval, the system records a duplicate approval event and rejects the additional approval.

7. Step 7 – Record the Valid Approval.

If the participant is both authorised and eligible, and no previous approval from that participant exists, the system records the approval a as valid. The corresponding participant is added to the valid approval set A_v .

The approval set is therefore updated according to

$$A_v \leftarrow A_v \cup \{a\}.$$

Each valid approval becomes an independent piece of authorisation evidence associated with consent object C .

8. Step 8 – Evaluate the Approval Threshold.

The system evaluates the number of valid approvals currently associated with the consent:

$$|A_v| \geq N.$$

This comparison determines whether the minimum number of required participants has been reached. Importantly, only approvals that have passed identity, authority, membership, and duplicate checks are included in A_v .

9. Step 9 – Activate the Authorisation if the Threshold Is Satisfied.

If

$$|A_v| \geq N,$$

the required threshold has been satisfied. The system activates the authorisation associated with consent object C . The activation indicates that the consent has obtained sufficient valid multi-party approval to proceed to the subsequent access-control or data-access stage.

10. Step 10 – Generate Activation Evidence.

Following successful threshold satisfaction, the system generates activation or token evidence associated with the authorisation decision. The evidence may include the consent identifier, threshold value N , identities of the approving participants, approval timestamps, and the resulting authorisation state.

This evidence provides a verifiable representation of how the authorisation was activated and which participants contributed to the decision.

11. Step 11 – Record the Threshold-Satisfied Event.

The system records a threshold-satisfied event in the audit infrastructure. This event provides an immutable or otherwise tamper-evident record of the transition from a pending consent state to an active authorisation state.

12. Step 12 – Maintain Pending State if the Threshold Is Not Satisfied.

If

$$|A_v| < N,$$

the consent does not yet satisfy the required multi-party authorisation condition. The system therefore maintains the consent in a *PENDING* state rather than activating access.

The system records a threshold-pending event so that the current authorisation state and the remaining approval requirement can be reconstructed during subsequent verification or audit.

13. Step 13 – Return the Authorisation Result.

The final result is determined according to the threshold condition:

$$Authorisation(C) = \begin{cases} ALLOW, & |A_v| \geq N, \\ PENDING, & |A_v| < N. \end{cases}$$

Invalid, unauthorised, or duplicate approval attempts are rejected and do not contribute to the valid approval count.

The overall procedure can therefore be represented as:

$$\begin{aligned} G \rightarrow N \rightarrow a \rightarrow \text{Identity/Authority} \rightarrow \text{Eligibility} \\ \rightarrow \text{Duplicate Check} \rightarrow A_v \rightarrow |A_v| \geq N \rightarrow \begin{cases} ALLOW \\ PENDING \end{cases} \end{aligned} \quad (55)$$

The threshold condition can be expressed more explicitly as

$$[\forall u_i \in A_v, Identity(u_i) \wedge Authority(u_i, C) \wedge (u_i \in G)] \wedge |A_v| \geq N \Rightarrow Authorisation(C) = ALLOW$$

This formulation is important because the threshold is not calculated from the number of submitted approvals alone. Instead, only *valid, authorised, eligible, and non-duplicate approvals* contribute to the threshold. Consequently, the procedure prevents a participant from satisfying the authorisation requirement merely by submitting multiple approvals or by presenting a valid identity without possessing the required authority.

The procedure also introduces a clear distinction between *approval* and *authorisation*. An individual approval represents one participant's contribution to the decision, whereas authorisation is activated only when the collective evidence satisfies the predefined threshold. This provides a distributed decision mechanism in which no single participant necessarily has unilateral authority to activate the consent.

From a trust perspective, the procedure can therefore be interpreted as

$$\begin{aligned} \text{Individual Trust Evidence} \rightarrow \text{Collective Approval Evidence} \\ \rightarrow \text{Threshold Satisfaction} \rightarrow \text{Authorisation Activation} \end{aligned} \quad (56)$$

6.3.3 Algorithm 3: Threshold-Based Multi-Party Authorisation

Algorithm 3 explicitly distinguishes between invalid, duplicate, and valid approvals. This distinction is important because simply counting submitted signatures could incorrectly treat unauthorised or repeated approvals as independent evidence.

The algorithm also demonstrates why multi-party authorisation is a trust mechanism rather than merely a user-interface feature. The final decision depends on independently verified participants and a predefined collective requirement. Therefore, a single participant cannot unilaterally activate the consent when the threshold has not been satisfied.

This mechanism complements the DID/VC verification procedure in Algorithm 2. Algorithm 2 establishes whether an individual participant possesses a valid identity and sufficient authority, whereas Algorithm 3 determines whether a sufficient number of independently verified participants have collectively satisfied the consent-defined authorisation requirement. The resulting activation evidence can subsequently be consumed by the policy and scope enforcement layer before healthcare data are released.

Algorithm 3 Threshold-Based Multi-Party Authorisation

Require: Consent object C , participant approval a , threshold N

Ensure: Authorisation result

```
1: Retrieve required participant set  $G$ 
2: Verify identity and authority of participant submitting  $a$ 
3: if verification fails then
4:   Record invalid approval
5:   return DENY
6: end if
7: if participant is not in  $G$  then
8:   Record unauthorised approval attempt
9:   return DENY
10: end if
11: if participant has already approved  $C$  then
12:   Record duplicate approval
13:   return DENY
14: end if
15: Record valid approval  $a$ 
16: Update valid approval set  $A_v$ 
17: if  $|A_v| \geq N$  then
18:   Activate authorisation
19:   Generate activation or token evidence
20:   Record threshold-satisfied event
21:   return ALLOW
22: else
23:   Keep consent in pending state
24:   Record threshold-pending event
25:   return PENDING
26: end if
```

6.4 Policy- and Context-Aware Access Control for RO4

RO4 addresses RQ4 by developing a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent.

The objective is based on the observation that a valid identity and sufficient approval do not necessarily imply that every requested operation is permitted. A doctor may be a legitimate participant and may possess a valid consent, but the requested data may exceed the authorised scope or the requested purpose may not match the purpose specified by the patient.

Let S_C denote the data scope authorised by the consent and S_R denote the data scope requested by the participant. The scope condition is

$$V_S(C, R) = 1 \iff S_R \subseteq S_C. \quad (57)$$

The policy condition can therefore be expressed as

$$V_P(C, R) = V_U(C, R) \wedge V_S(C, R), \quad (58)$$

where $V_U(C, R)$ represents purpose compatibility and $V_S(C, R)$ represents data-scope compatibility.

The complete current stage research on authorisation decision is

~~$$Decision(C, R) = ALLOW \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R). \quad (59)$$~~

Repeat - delete; cite Eq. (6)

6.4.1 RO4 Policy-Aware Access Workflow

The workflow begins when a doctor submits a request for patient data. The system retrieves the relevant consent object and verifies the requesting participant. It then checks whether the required multi-party authorisation has been established.

After the identity and authorisation conditions are satisfied, the system evaluates the requested purpose and data scope. A request is permitted only when the purpose is compatible with the consent and the requested data scope is contained within the authorised scope.

The HALAH implementation provides a concrete basis for this objective. The Doctor interface retrieves a consent, evaluates its state, allows a requested scope to be selected from the consent scope, generates a proof, checks the requested scope, and invokes the authorisation function before returning data.

Add '(Figures 15–16; check_scope(), authorize(), evaluate_allow() in services/access_service.py)'.

~~For example, if~~

~~$$S_C = Observation, Medication, \quad (60)$$~~

~~and~~

~~$$S_R = Observation, Medication, Procedure, \quad (61)$$~~

~~then~~

~~$$S_R \not\subseteq S_C, \quad (62)$$~~

~~and the request must be denied. This rule prevents a legitimate participant from obtaining data outside the patient's authorised scope.~~

Repeat (and missing braces) - delete Eq. (60)-(62); write 'For example, the request in Eq. (4) must be denied.'

A67.1 - New paragraph at the end of §6.4.1

Insert after '...prevents a legitimate participant from obtaining data outside the patient's authorised scope.'

Prototype status of VP. In HALAH v1.1, scope compatibility $V_S(C, R)$ is enforced: the Doctor interface offers only modules from the consented scope, and `check_scope()` independently verifies $S_R \subseteq S_C$ before any data are returned; a failed check produces an ACCESS DENIED result that is recorded in the audit log. Purpose compatibility $V_U(C, R)$ is only partly implemented: the consent purpose is checked against the permitted set {Treatment, Research, Emergency}, but the requester does not yet declare a purpose, so the comparison $P_R \models P_C$ is scheduled for Stage 2. In addition, the full decision matrix (VI, VA, VP, VT, VL) is computed by `evaluate_allow()` and displayed to the requester, whereas the data-release gate `authorize()` currently requires an ACTIVE consent state, a valid access proof and a valid scope. Routing the release decision through `evaluate_allow()` is a small planned change that will make the implemented gate identical to Eq. (6).

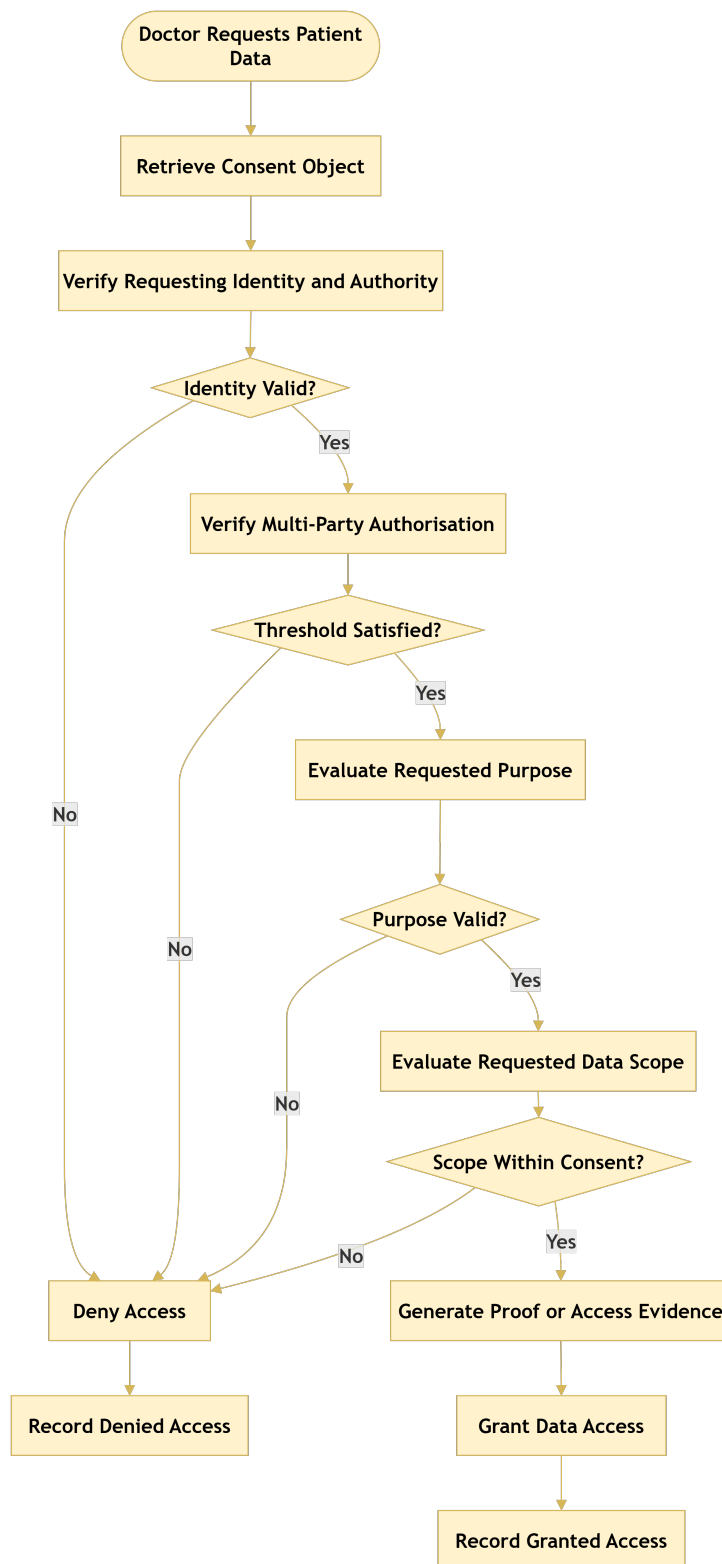


Figure 10: RO4 workflow for policy- and context-aware access control

6.4.2 Procedure for Temporal and Lifecycle Validation

The Temporal and Lifecycle Validation procedure determines whether a consent object remains temporally valid and whether the requested operation is permitted under its current lifecycle state. Unlike static authorisation checks, this procedure explicitly considers the temporal validity, revocation status, and state-transition rules of the consent object. It therefore ensures that a previously valid consent cannot be treated as permanently valid after expiration, revocation, or an unauthorised lifecycle transition.

1. Step 1 – Retrieve the Consent Validity Interval.

The system retrieves the start time t_s and expiry time t_e associated with consent object C . These temporal attributes define the period during which the consent is potentially valid.

The consent validity interval is represented as

$$T_C = [t_s, t_e].$$

The system uses the current time t to determine whether the consent is currently within its defined validity period.

2. Step 2 – Validate the Current Time.

The system compares the current time t with the consent validity interval. Temporal validity requires

$$t_s \leq t \leq t_e.$$

If

$$t < t_s \quad \text{or} \quad t > t_e,$$

the consent is considered temporally invalid. The system records the temporal invalidity evidence and returns *INVALID*.

This step prevents a consent from being used before its effective start time or after its expiration time.

3. Step 3 – Retrieve the Current Lifecycle State.

If the temporal condition is satisfied, the system retrieves the current lifecycle state of consent object C . Typical lifecycle states may include *CREATED*, *PENDING*, *ACTIVE*, *SUSPENDED*, *REVOKED*, and *EXPIRED*, depending on the system configuration.

The current state is used to determine whether the requested operation can legally and logically be performed.

4. Step 4 – Validate State-Dependent Operations.

The system evaluates whether the current lifecycle state permits the requested operation q . Different operations may be permitted only in specific lifecycle states. For example, activation may require a consent to be in a pending state, while data access may require the consent to be active.

The state transition condition can be represented as

$$State(C) \models q.$$

If the current state does not permit operation q , the system records an invalid lifecycle-state event and returns *INVALID*.

5. Step 5 – Check Revocation Status.

The system explicitly checks whether consent object C has been revoked. Revocation represents a deliberate termination of the previously granted consent and must therefore override an otherwise valid temporal interval.

Formally,

$$Revoked(C) = false$$

must hold for the consent to remain usable.

If

$$Revoked(C) = true,$$

the system records revocation-based invalidity and returns *INVALID*.

6. Step 6 – Validate the Requested Lifecycle Transition.

If the consent is temporally valid, in an appropriate lifecycle state, and has not been revoked, the system validates the requested transition q .

The transition is evaluated against the predefined lifecycle-transition policy:

$$State(C) \xrightarrow{q} State'(C).$$

The transition is valid only when q is explicitly permitted from the current state. If the transition is not permitted, the system records an unauthorised state-transition event and returns *INVALID*.

7. Step 7 – Establish Temporal and Lifecycle Consistency.

After all individual checks have succeeded, the system establishes that the consent is simultaneously valid in terms of time, lifecycle state, revocation status, and requested transition.

The overall lifecycle-validity condition can therefore be expressed as

$$V_L(C, t, q) = TimeValid(C, t) \wedge StateValid(C, q) \wedge \neg Revoked(C) \wedge TransitionValid(C, q).$$

Only when all four conditions are satisfied can the consent proceed to the subsequent operation.

8. Step 8 – Record Temporal and Lifecycle Evidence.

The system records evidence associated with the successful validation. The evidence may include the consent identifier, current timestamp, validity interval, current lifecycle state, revocation status, requested transition, and validation result.

This evidence establishes an auditable relationship between the consent's lifecycle state and the operation performed at a particular point in time.

9. Step 9 – Return the Lifecycle Validation Result.

If all temporal and lifecycle conditions are satisfied, the system returns

$$V_L(C, t, q) = \text{VALID}.$$

If any mandatory condition fails, the procedure returns

$$V_L(C, t, q) = \text{INVALID}.$$

The overall validation process can therefore be represented as

$$C \rightarrow T_C \rightarrow t \rightarrow \text{State}(C) \rightarrow \text{Revocation} \rightarrow q \rightarrow \text{Lifecycle Validation} \rightarrow \text{Evidence} \rightarrow \begin{cases} \text{VALID} \\ \text{INVALID} \end{cases}$$

The complete lifecycle-validity condition can be summarised as

$$\text{VALID} \iff (t_s \leq t \leq t_e) \wedge \text{State}(C) \models q \wedge \neg \text{Revoked}(C) \wedge \text{TransitionPermitted}(q)$$

This procedure establishes that consent validity is not a static property. Instead, the validity of consent is a function of both time and lifecycle state that

$$\text{Validity}(C) = f(t, \text{State}(C), \text{Revocation}(C)).$$

Consequently, a consent that was valid at time t_1 may become invalid at a later time t_2 because it has expired, been revoked, suspended, or otherwise transitioned into a state that does not permit the requested operation.

The explicit lifecycle validation also introduces an important distinction between *consent existence* and *consent usability*. The existence of a consent record in the system does not imply that the consent remains effective. Similarly, a consent that has successfully passed identity and authority verification may still be unusable if its validity period has expired or if it has subsequently been revoked.

This temporal property can be represented as:

$$\text{ConsentExists}(C) \not\Rightarrow \text{ConsentUsable}(C, t).$$

Instead,

$$\text{ConsentUsable}(C, t) \Rightarrow \text{TimeValid}(C, t) \wedge \text{StateValid}(C) \wedge \neg \text{Revoked}(C).$$

The procedure therefore provides the lifecycle control required to connect the initial consent creation process with subsequent access decisions. Algorithm 1 establishes the consent object and its validity interval, Algorithm 2 verifies the identity and authority of participating entities, Algorithm 3 establishes multi-party approval, and Algorithm 4 evaluates the specific access request. Algorithm 5 complements these mechanisms by ensuring that the consent and its associated authorisation remain valid throughout their operational lifecycle.

From the perspective of the overall HALAH architecture, the lifecycle validation mechanism can therefore be interpreted as a continuous validity layer

$$\text{Consent} \rightarrow \text{Identity} \rightarrow \text{Authority} \rightarrow \text{Policy} \rightarrow \text{Temporal/Lifecycle Validation} \rightarrow \text{Access}$$

Rather than treating authorisation as a one-time event, this approach enables the system to determine whether authorisation remains valid at the precise time an operation is requested. This is particularly important for dynamic consent environments in which permissions may expire, be revoked, suspended, renewed, or otherwise modified during the lifecycle of a healthcare data-sharing relationship.

6.4.3 Algorithm 4: Policy-Aware Access Decision

Place Algorithm 4
AFTER its
procedure
(\$6.4.4), as in
\$6.1–6.3.

Algorithm 4 Policy-Aware Access Decision

Require: Consent object C , access request R , requesting participant u

Ensure: Access decision

```

1: Verify DID and VC of  $u$ 
2: if identity or authority verification fails then
3:   Record denied decision
4:   return DENY
5: end if
6: Evaluate consent state
7: if consent is not active then
8:   Record denied decision
9:   return DENY
10: end if
11: Verify multi-party authorisation
12: if threshold is not satisfied then
13:   Record denied decision
14:   return DENY
15: end if
16: Evaluate requested purpose
17: if purpose is incompatible with consent then
18:   Record denied decision
19:   return DENY
20: end if
21: Evaluate requested data scope
22: if  $S_R \not\subseteq S_C$  then
23:   Record denied decision
24:   return DENY
25: end if
26: Generate or verify access evidence
27: Retrieve authorised healthcare data
28: Record granted decision
29: return ALLOW

```

Algorithm 4 demonstrates that policy evaluation is performed after identity and multi-party authorisation verification but before data release. This ordering is important because it prevents the system from treating identity validity or collective approval as unrestricted permission.

The algorithm also establishes the connection between the proposed framework and the HALAH access-control implementation. The system must not only determine whether a consent exists, but also evaluate whether the current request satisfies the consent's scope and purpose constraints. Both granted and denied requests should be recorded to support accountability and auditability.

6.4.4 Procedure for Policy-Aware Access Decision

The Policy-Aware Access Decision procedure determines whether a specific healthcare data-access request should be authorised by jointly evaluating the requesting participant's identity and authority, the current consent state, the required multi-party authorisation condition, the intended purpose, and the requested data scope. Rather than treating successful authentication as sufficient for access, the procedure evaluates the complete set of conditions defined by the consent and applicable access-control policies. The procedure consists of the following steps.

1. **Step 1 – Receive and Parse the Access Request.** The system receives an access request R from requesting participant u . The request specifies the healthcare resources requested by the participant and the intended purpose of access. The requested data scope is denoted by S_R , while the purpose associated with the request is denoted by P_R .

The access request can therefore be represented as

$$R = (u, P_R, S_R).$$

The system associates R with the relevant consent object C before continuing with the authorisation process.

2. **Step 2 – Verify the Requesting Participant's DID and VC.**

The system verifies the DID and VC associated with participant u . This step invokes the identity and authority verification procedure defined in Algorithm 2.

The system determines whether the participant possesses a valid decentralised identity and whether the associated verifiable credentials provide sufficient authority for the requested healthcare interaction. If identity or authority verification fails, the request is denied and the denial event is recorded.

Formally, $V_I(u) = \text{VALID}$ must hold before the request can proceed to the subsequent authorisation stages.

3. **Step 3 – Evaluate the Current Consent State.**

After successful identity verification, the system evaluates the current state of consent object C . The system determines whether the consent is active and whether it remains within its defined validity period.

In particular, the system verifies that the consent has not expired, been revoked, or otherwise transitioned into an inactive state. If

$$\text{State}(C) \neq \text{ACTIVE},$$

the access request is denied and the decision is recorded.

4. Step 4 – Verify Multi-Party Authorisation.

The system verifies whether the multi-party authorisation requirement associated with consent object C has been satisfied. The valid approval set A_v is evaluated against the required threshold N .

The authorisation condition is expressed as

$$|A_v| \geq N.$$

If the threshold has not been satisfied, the consent cannot be used to authorise the requested access. The system therefore records a denied decision and returns *DENY*.

5. Step 5 – Evaluate the Requested Purpose.

The system compares the purpose specified in the access request P_R with the purpose permitted by the consent object P_C . The purpose compatibility condition can be represented as

$$P_R \models P_C.$$

~~which means P_R guarantees, satisfies, and complies with the privacy constraint P_C . There is no execution path where the system can violate the privacy policy.~~

OVERCLAIM – cannot be proven at this stage. Replace with: 'where $\models$ denotes that the requested purpose P_R is permitted by the consented purpose P_C .'

If the requested purpose is incompatible with the patient's consent, the request is denied. This step prevents a participant from using otherwise valid credentials and consent to access healthcare information for a purpose that was not authorised by the patient.

6. Step 6 – Evaluate the Requested Data Scope.

The system evaluates whether the requested data scope S_R is contained within the data scope authorised by the consent, denoted by S_C .

The required containment relationship is

$$S_R \subseteq S_C.$$

If

$$S_R \not\subseteq S_C,$$

the requested access exceeds the patient's authorised data scope. The system records a denied decision and returns *DENY*.

This step is particularly important for fine-grained healthcare data access because authorisation to access one category of healthcare information does not imply authorisation to access all categories of the patient's record.

7. Step 7 – Evaluate the Complete Authorisation Policy.

After the individual conditions have been successfully evaluated, the system performs the final policy evaluation. The decision is based on the conjunction of identity validity, active consent, sufficient multi-party approval, purpose compatibility, and scope containment.

The overall authorisation condition can be represented as

$$\begin{aligned} \text{Authorised}(R, C, u) = & V_I(u) \wedge \text{Active}(C) \wedge (|A_v| \geq N) \\ & \wedge \text{PurposeMatch}(P_R, P_C) \wedge \text{ScopeMatch}(S_R, S_C). \end{aligned}$$

Access can proceed only when all required conditions evaluate to true.

8. Step 8 – Generate or Verify Access Evidence.

If the policy evaluation succeeds, the system generates or verifies the evidence supporting the access decision. The evidence may include the consent identifier, requesting participant DID, relevant VC claims, consent state, approval threshold, approving participants, requested purpose, requested scope, and decision timestamp.

This evidence provides an auditable relationship between the access request and the conditions that justified the resulting authorisation.

9. Step 9 – Retrieve the Authorised Healthcare Data.

Once the request has been successfully authorised, the system retrieves only the healthcare data satisfying the authorised scope S_R . The retrieval operation must enforce the same scope constraints that were evaluated during the policy decision.

Thus,

$$Data_{returned} \subseteq S_C.$$

This prevents a mismatch between the policy decision and the actual data returned to the requester.

10. Step 10 – Record the Granted Decision.

The system records the successful access-authorisation event. The recorded evidence may include the request identifier, consent identifier, requester identity, authorised purpose, authorised data scope, authorisation result, and relevant timestamp.

The resulting event provides an auditable record of why and under which conditions access was granted.

11. Step 11 – Return the Final Access Decision.

If all mandatory conditions have been satisfied, the system returns

$$AccessDecision = ALLOW.$$

If any mandatory condition fails during the evaluation process, the system records the corresponding denial evidence and returns

$$AccessDecision = DENY.$$

The overall decision process can therefore be represented as

$$\begin{aligned} R \rightarrow \text{DID/VC} \rightarrow \text{Consent State} \rightarrow \text{Threshold} \rightarrow \text{Purpose} \\ \rightarrow \text{Scope} \rightarrow \text{Policy Eval.} \rightarrow \text{Evidence} \rightarrow \text{Data Retr.} \rightarrow \begin{cases} ALLOW \\ DENY \end{cases} \end{aligned}$$

The final access decision can be formally expressed as

$$ALLOW \iff Identity \wedge Consent \wedge Authority \wedge Threshold \wedge Purpose \wedge Scope \wedge Evidence$$

where the individual conditions represent verified participant identity, active consent, sufficient authority, satisfied multi-party approval, compatible purpose, authorised data scope, and sufficient decision evidence, respectively.

This procedure establishes an important distinction between *authentication*, *consent*, and *authorisation*. A successfully authenticated participant is not automatically granted access. Instead, authentication provides identity evidence, consent provides patient-defined permission constraints, multi-party approval provides distributed authority evidence, and policy evaluation determines whether the particular request satisfies all applicable conditions.

The procedure also implements the principle of least privilege through the explicit scope-containment condition that

$$S_R \subseteq S_C.$$

Consequently, even when a participant possesses a valid DID, a valid VC, and sufficient authority, the participant cannot retrieve healthcare resources outside the scope explicitly authorised by the consent. Similarly, a valid consent cannot be used for an incompatible purpose or before the required multi-party authorisation threshold has been reached.

From an architectural perspective, Algorithm 4 therefore acts as the final policy-enforcement layer of the proposed authorisation lifecycle. Algorithm 1 establishes the consent constraints, Algorithm 2 establishes trustworthy identity and authority evidence, and Algorithm 3 establishes collective authorisation evidence. Algorithm 4 integrates these evidence sources with the specific access request and determines whether the requested healthcare data can actually be released.

The resulting end-to-end authorisation lifecycle can be summarised as

$$\begin{array}{c} \text{Consent Creation} \rightarrow \text{Identity Verification} \rightarrow \text{Multi Party Auth} \rightarrow \text{Policy Decision} \\ \text{Consent Creation} \rightarrow \text{Identity Verification} \rightarrow \text{Multi-Party Authorisation} \rightarrow \text{Policy Decision} \end{array}$$

This architecture transforms healthcare data access from a simple credential-based permission check into an evidence-based authorisation process in which identity, consent, authority, distributed approval, purpose, scope, and audit evidence jointly determine the final access decision.

6.5 Temporal and Lifecycle Trust for RO5

RO5 addresses RQ5 and extends the foundational current stage works on authorisation model with temporal validity and consent lifecycle controls. This objective belongs primarily to CA3 because it investigates how an authorisation remains trustworthy as time passes and as the consent state changes.

The current stage model evaluates identity, collective authorisation, and policy compliance. RO5 extends this model by introducing temporal and lifecycle conditions that

$$V_T(C, t) = \begin{cases} 1, & t_s \leq t \leq t_e, \\ 0, & \text{otherwise.} \end{cases} \quad (63)$$

Repeat - delete;
cite Eq. (15)

The lifecycle condition can be expressed as

$$V_L(C) = \text{ValidState}(C) \wedge \text{ValidTransition}(C). \quad (64)$$

Repeat - delete;
cite Eq. (18)

The extended authorisation decision is therefore

$$\text{Decision}(C, R, t) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (65)$$

Repeat - delete; cite Eq. (27)

The purpose of RO5 is not simply to add an expiry field. It is to ensure that the validity of a consent depends on both its temporal interval and its current lifecycle state. A consent that has expired or been revoked must not remain usable merely because its original approval threshold was satisfied.

6.5.1 RO5 Temporal and Lifecycle Workflow

The planned workflow evaluates the consent's temporal interval, lifecycle state, and revocation status before the system proceeds with the remaining authorisation conditions. This design ensures that a consent is not treated as permanently valid after it has expired or entered a state that no longer permits access.

~~The current HALAH code already collects a start time and expiry time during consent creation, but the complete temporal and lifecycle enforcement mechanism remains part of the planned CA3 extension.~~

OUT OF DATE - the code already enforces expiry, not-yet-started and revocation. Replace with A77.1 (also fixes the VL naming clash).

6.5.2 Algorithm 5: Temporal and Lifecycle Validation

Algorithm 5 Temporal and Lifecycle Validation

Require: Consent object C , current time t , requested transition q

Ensure: Lifecycle validity result

- 1: Retrieve consent start time t_s and expiry time t_e
 - 2: **if** $t < t_s$ or $t > t_e$ **then**
 - 3: Record temporal invalidity
 - 4: **return** INVALID
 - 5: **end if**
 - 6: Retrieve current lifecycle state of C
 - 7: **if** current state does not permit the requested operation **then**
 - 8: Record invalid lifecycle state
 - 9: **return** INVALID
 - 10: **end if**
 - 11: Check whether C has been revoked
 - 12: **if** C is revoked **then**
 - 13: Record revocation-based invalidity
 - 14: **return** INVALID
 - 15: **end if**
 - 16: Validate requested transition q
 - 17: **if** transition q is not permitted **then**
 - 18: Record unauthorised state transition
 - 19: **return** INVALID
 - 20: **end if**
 - 21: Record valid temporal and lifecycle evidence
 - 22: **return** VALID
-

A77.1 - Replacement for the struck paragraph in §6.5.1, plus a notation note

Replaces 'The current HALAH code already collects a start time and expiry time ... planned CA3 extension.'

The HALAH prototype (v1.1) already implements a first version of this workflow. `services/state_service.py` evaluates the consent state in the order REVOKED, PENDING_SIGNATURE, PENDING_TOKEN, NOT_STARTED, EXPIRED and ACTIVE, and only an ACTIVE consent can release data; $V_T(C, t)$ is also computed in `evaluate_allow()`. A patient can revoke a consent from the My Consents view, which sets the local state to REVOKED and calls `revoke()` on the consent contract. The v3 contract additionally enforces the validity interval on-chain (`checkValid`, `checkValidAt`). What remains for Stage 2 (CA3) is the explicit specification of legal state transitions, formal analysis of the lifecycle properties (Eq. (23)–(24)) and adversarial evaluation.

Notation note. The prototype's decision matrix currently uses the label VL for a jurisdiction check (consent jurisdiction equals requester jurisdiction, default 'AU'), whereas this report defines $V_L(C)$ as lifecycle validity (Eq. (18)). To avoid ambiguity, the jurisdiction predicate will be renamed V_J in the code and contract, and V_L is reserved for lifecycle validity as defined here.

Code action (not part of the report text): rename VL→VJ in `services/access_service.py`, `app.py` and the ConsentSBTv3 comments, so that the code and the report use the same symbols.

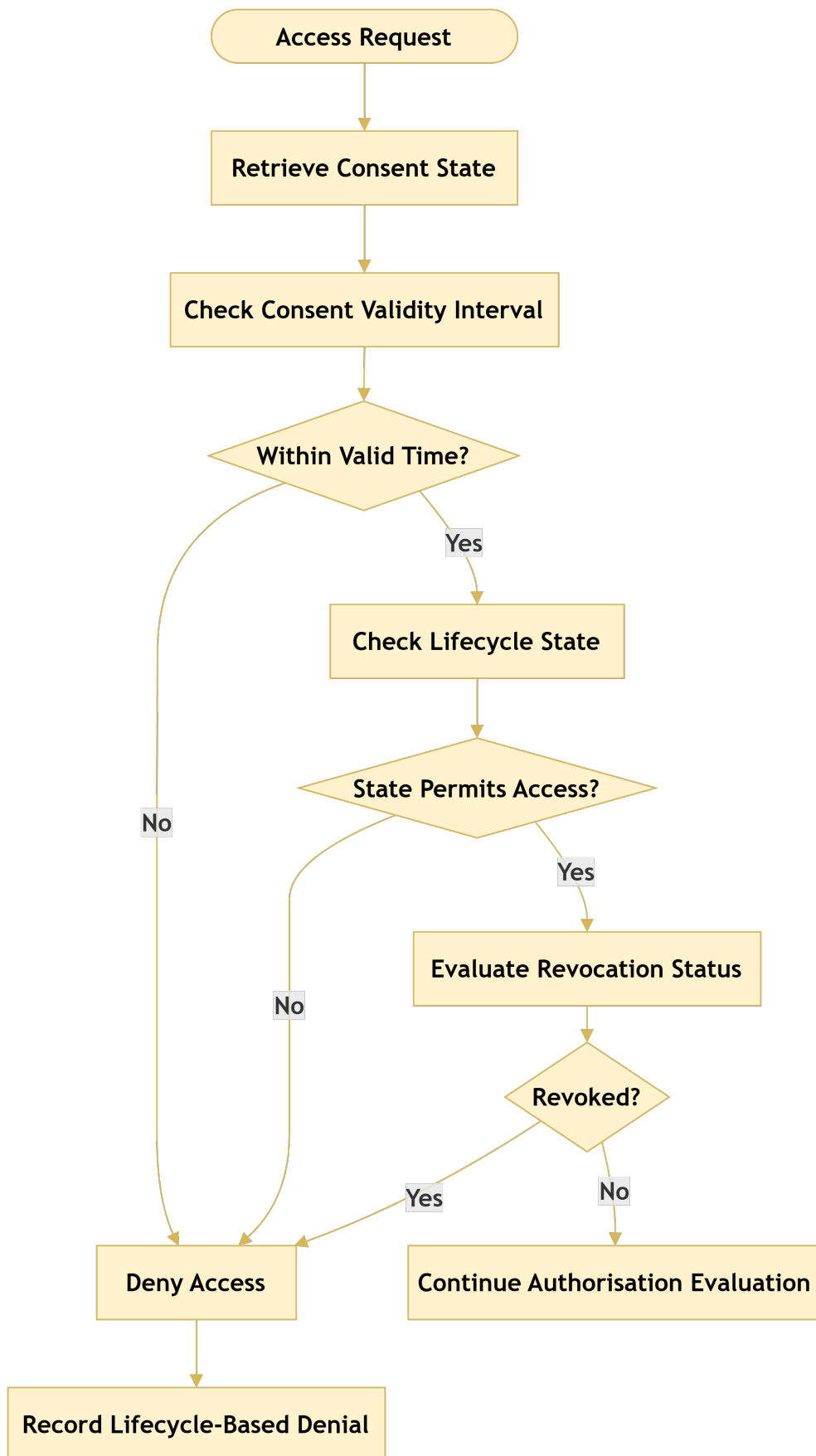


Figure 11: RO5 planned workflow for temporal and consent lifecycle trust

Algorithm 5 extends the current stage works on decision process by ensuring that consent validity is dynamic rather than permanent. The algorithm is intended for the CA3 implementation and evaluation stage. It will be used to investigate expiration, revocation, and controlled state transitions as additional conditions of trustworthy access.

6.6 Formal Security Assurance and Empirical Validation for RO6

RO6 addresses RQ6 by formally analysing and empirically evaluating whether the proposed trust-oriented authorisation framework satisfies its defined security and authorisation properties.

The objective combines two complementary forms of assurance. Formal security assurance specifies the conditions under which the authorisation mechanism should be considered secure and consistent. Empirical validation evaluates whether the implemented system behaves according to those conditions under representative healthcare data-sharing scenarios.

The formal decision model is expressed as

$$\text{Decision}(C, R, t) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (66)$$

Repeat - delete; cite Eq. (27)

For current stage, the primary validation conditions are

$$\text{Decision}(C, R) = \text{ALLOW} \Rightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R). \quad (67)$$

This implication expresses the soundness requirement that every granted request must satisfy the identity, authorisation, and policy conditions. Conversely, if any mandatory condition is violated, the request must be denied:

$$\neg V_I(u) \vee \neg V_A(C) \vee \neg V_P(C, R) \Rightarrow \text{Decision}(C, R) = \text{DENY}. \quad (68)$$

6.6.1 RO6 Assurance and Validation Workflow

The validation process begins by defining the security and authorisation properties that the framework is expected to satisfy. These properties include identity validity, threshold correctness, policy compliance, denial of unauthorised requests, and consistency between the authorisation decision and the audit evidence.

The empirical component will evaluate both valid and invalid scenarios. Valid scenarios will examine whether a correctly specified consent can be created, verified, approved, and used for authorised data access. Negative scenarios will examine whether access is denied when a participant is not verified, when the approval threshold is not satisfied, or when the requested purpose or data scope violates the consent.

The HALAH prototype provides the implementation basis for this evaluation. The current system includes separate patient, guardian, doctor, and auditor interfaces. It also records consent creation, guardian approval, token minting, state checks, and data-access events.

Add: 'Current evidence is reported in Section 7.7 (Table 10).'

6.6.2 Procedure for Formal and Empirical Authorisation Validation

The Formal and Empirical Authorisation Validation procedure evaluates whether the proposed framework F correctly implements the intended authorisation model under normal, invalid, and adversarial conditions. Rather than validating the framework only through successful

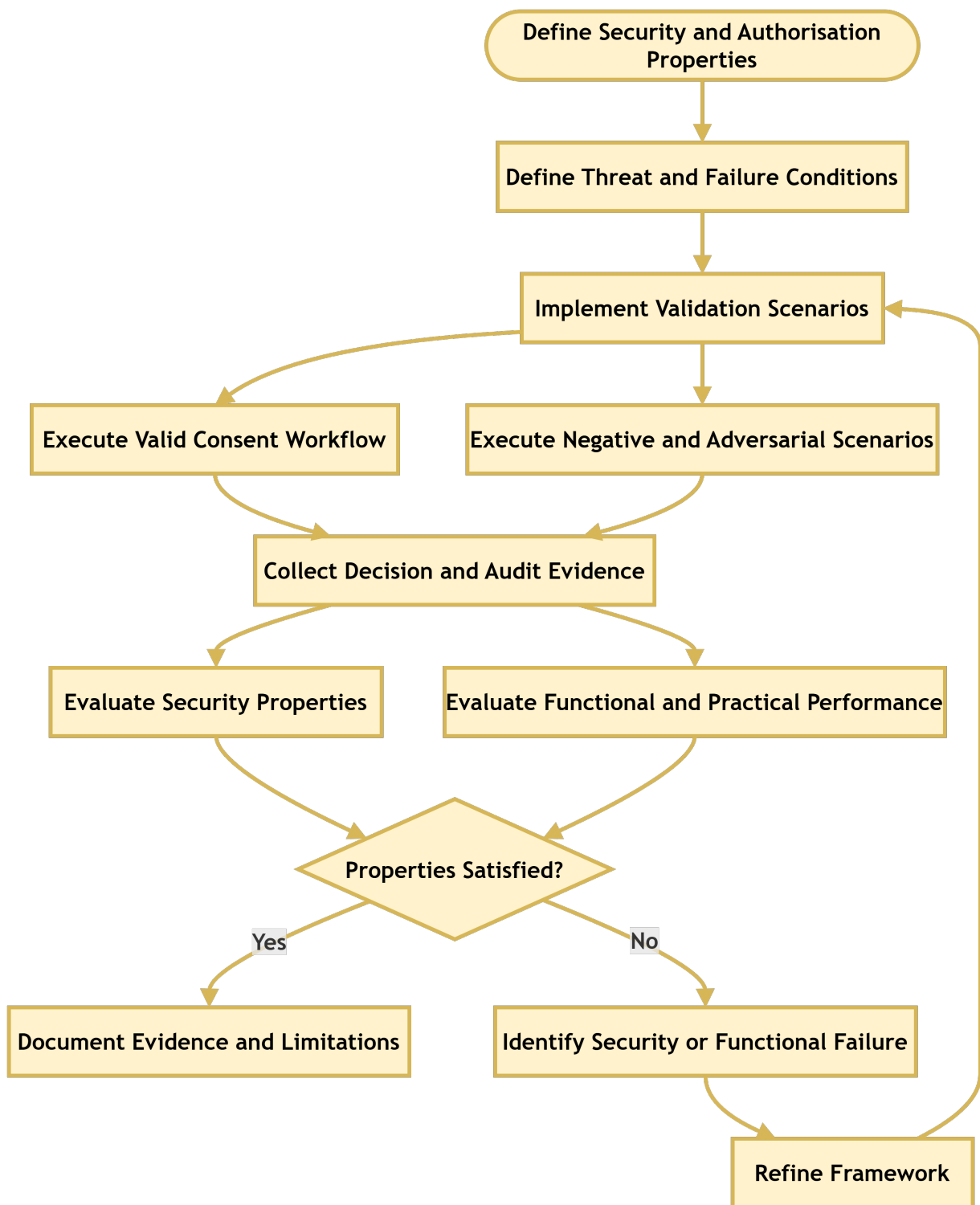


Figure 12: RO6 planned workflow for formal security assurance and empirical validation

execution cases, the procedure systematically evaluates both positive and negative behaviours and examines whether observed authorisation decisions are consistent with the formally defined security properties. The procedure therefore combines scenario-based empirical testing with property-oriented validation of authorisation correctness, denial behaviour, threshold enforcement, policy and scope compliance, and audit consistency.

1. Step 1 – Define the Expected Authorisation Properties.

The first step is to define the security and authorisation properties $\mathcal{P}$ that the framework is expected to satisfy. These properties provide the formal evaluation criteria against which the observed system behaviour will subsequently be compared.

The properties may include authorisation soundness, correct denial of unauthorised requests, threshold correctness, policy compliance, scope enforcement, temporal consistency, and audit consistency.

Formally,

$$\mathcal{P} = \{P_{\text{sound}}, P_{\text{deny}}, P_{\text{threshold}}, P_{\text{policy}}, P_{\text{scope}}, P_{\text{audit}}\}.$$

2. Step 2 – Define Valid Scenarios.

The system defines a set of valid scenarios $\mathcal{S}_{\text{valid}}$, representing legitimate healthcare data-access workflows. These scenarios should contain valid patient identities, valid credentials, active consent, sufficient authority, satisfied multi-party approval, compatible purposes, and authorised data scopes.

The purpose of these scenarios is to verify that legitimate requests are successfully authorised and that the framework does not incorrectly reject valid operations.

3. Step 3 – Define Negative Scenarios. The system defines a set of negative scenarios $\mathcal{S}_{\text{negative}}$, representing requests that violate one or more authorisation conditions.

Examples include invalid identities, expired consent, revoked consent, insufficient approval, unauthorised roles, incompatible purposes, and requests for data outside the consent scope. These scenarios test whether the framework correctly prevents access when an authorisation requirement is not satisfied.

4. Step 4 – Define Adversarial Scenarios.

The system defines adversarial scenarios $\mathcal{S}_{\text{adv}}$, representing attempts to circumvent or manipulate the authorisation process.

Such scenarios may include replayed approvals, duplicate approvals, unauthorised participants attempting to satisfy a threshold, invalid or forged credentials, attempts to access data outside the authorised scope, and attempts to use a revoked or expired consent object.

The adversarial test set is particularly important because a framework should not only demonstrate that legitimate requests succeed, but also demonstrate resilience against foreseeable attempts to bypass its security controls.

5. Step 5 – Construct the Complete Validation Scenario Set.

The three scenario classes are combined into the complete validation set:

$$\mathcal{S} = \mathcal{S}_{\text{valid}} \cup \mathcal{S}_{\text{negative}} \cup \mathcal{S}_{\text{adv}}.$$

Each scenario $s \in \mathcal{S}$ is associated with an expected authorisation outcome and the security properties that it is intended to evaluate.

6. Step 6 – Execute Each Scenario Using the Framework.

The system executes each scenario s using the implemented framework F . During execution, the framework performs the corresponding consent, identity, authority, threshold, policy, scope, and lifecycle checks.

The execution process is treated as an empirical observation of the implemented authorisation model that

$$F(s) \rightarrow D_{obs},$$

where D_{obs} denotes the observed authorisation decision.

7. Step 7 – Collect the Observed Authorisation Decision.

After each scenario has been executed, the system records the resulting authorisation decision. Depending on the operation, the observed result may be *ALLOW*, *DENY*, *PENDING*, or another explicitly defined lifecycle state.

The observed decision is stored together with the corresponding scenario identifier to enable subsequent comparison with the expected outcome.

8. Step 8 – Collect Supporting Authorisation Evidence.

In addition to the final decision, the system collects the evidence generated during the authorisation process. This evidence may include identity verification results, VC validation results, participant approvals, threshold status, consent state, purpose evaluation, scope evaluation, timestamps, and audit records.

The collected evidence can therefore be represented as

$$E_s = \{E_I, E_A, E_C, E_T, E_P, E_S, E_L\},$$

where the individual components represent identity, authority, consent, threshold, policy, scope, and lifecycle evidence.

9. Step 9 – Compare Observed and Expected Decisions.

The observed decision is compared with the expected decision defined for scenario s .

Let

$$D_{exp}(s)$$

denote the expected decision and

$$D_{obs}(s)$$

denote the observed decision. The scenario passes when

$$D_{obs}(s) = D_{exp}(s).$$

Otherwise, the scenario is classified as a validation failure.

10. Step 10 – Record the Scenario Result.

The system records whether each scenario has passed or failed. For each failure, the corresponding condition, observed behaviour, expected behaviour, and supporting evidence are retained for subsequent analysis.

This enables validation results to be traced from the final decision back to the individual authorisation conditions that produced that decision.

11. Step 11 – Evaluate Authorisation Soundness.

The system evaluates the soundness property to determine whether every granted request satisfies the required authorisation conditions.

Formally,

$$D_{obs}(s) = ALLOW \Rightarrow Authorised(s) = TRUE.$$

A sound framework should not grant access when one or more mandatory authorisation conditions are violated.

12. Step 12 – Evaluate Denial Correctness.

The system evaluates whether invalid or unauthorised requests are correctly denied.

The denial property can be represented as

$$Authorised(s) = FALSE \Rightarrow D_{obs}(s) \neq ALLOW.$$

This evaluation is particularly important for negative and adversarial scenarios because successful operation under valid conditions alone cannot demonstrate that unauthorised access is reliably prevented.

13. Step 13 – Evaluate Threshold Correctness.

The system evaluates whether multi-party authorisation is activated only when the required threshold condition is satisfied.

The expected threshold property is

$$Authorisation(C) = ALLOW \Rightarrow |A_v| \geq N.$$

The evaluation should also verify that invalid, duplicate, or unauthorised approvals do not contribute to A_v . This ensures that the threshold cannot be artificially satisfied by repeated or illegitimate approval submissions.

14. Step 14 – Evaluate Policy and Scope Enforcement.

The system evaluates whether every granted request satisfies the consent-defined policy and data-scope constraints.

In particular, the scope enforcement property is

$$D_{obs}(s) = ALLOW \Rightarrow S_R \subseteq S_C.$$

The evaluation should verify that a participant cannot obtain healthcare resources outside the scope authorised by the patient's consent, even when the participant possesses a valid identity and authority credential.

Purpose compatibility is evaluated similarly:

$$D_{obs}(s) = ALLOW \Rightarrow P_R \models P_C.$$

15. Step 15 – Evaluate Audit Consistency.

The system evaluates whether the recorded audit evidence is consistent with the actual authorisation decision and the underlying verification events.

For an access event e , the audit record should provide sufficient evidence to establish a relationship between the request, requester, consent, policy evaluation, authorisation result, and timestamp.

Therefore,

$$Audit(e) \models Decision(e).$$

An audit inconsistency occurs when the recorded evidence does not correspond to the actual system decision or when critical authorisation evidence is missing.

16. Step 16 – Analyse Failures and Limitations.

Any failed scenario is analysed to determine the source and significance of the failure. The analysis distinguishes between implementation defects, policy-definition errors, integration problems, incomplete security controls, and limitations of the experimental environment.

The purpose of this step is not to conceal unsuccessful cases but to determine whether observed failures represent violations of the intended security properties or limitations that should be addressed in future work.

17. Step 17 – Consolidate the Validation Results.

Finally, the individual scenario results and property-level evaluations are consolidated into an overall validation result.

The resulting evidence includes:

$$V = \{R_{scenario}, R_{sound}, R_{deny}, R_{threshold}, R_{policy}, R_{scope}, R_{audit}\}.$$

The framework is considered empirically consistent with the specified authorisation model when the observed decisions satisfy the expected outcomes across the defined validation scenarios and no critical security property is violated.

The overall validation process can therefore be represented as

$$\begin{aligned} \mathcal{P} &\rightarrow \mathcal{S}_{valid} \cup \mathcal{S}_{negative} \cup \mathcal{S}_{adv} \\ &\rightarrow F(s) \rightarrow D_{obs} \rightarrow E_s \\ &\rightarrow D_{obs} \stackrel{?}{=} D_{exp} \rightarrow \textit{Property Evaluation} \\ &\rightarrow \textit{Failure Analysis} \rightarrow \textit{Validation Evidence} \end{aligned}$$

The fundamental scenario-level validation criterion is

$$Pass(s) \iff D_{obs}(s) = D_{exp}(s)$$

while the framework-level validation can be expressed as:

$$Valid(F) \Rightarrow P_{sound} \wedge P_{deny} \wedge P_{threshold} \wedge P_{policy} \wedge P_{scope} \wedge P_{audit}$$

This procedure establishes a distinction between *functional correctness* and *security correctness*. A system may successfully execute an access request and return data without necessarily demonstrating that the request should have been authorised. The proposed validation therefore does not treat successful execution as sufficient evidence of correctness. Instead, the observed decision must be consistent with the formally specified authorisation conditions.

The use of three complementary scenario classes is particularly important. Valid scenarios establish that legitimate users can obtain authorised access, negative scenarios establish that invalid requests are correctly rejected, and adversarial scenarios examine whether security controls can resist deliberate attempts to circumvent the authorisation process. Together, these scenarios provide a more balanced evaluation of both the *positive security property* of granting legitimate access and the *negative security property* of preventing illegitimate access.

The validation procedure also provides traceability between the final access decision and its supporting evidence. For each scenario, the decision can be interpreted as:

$$Decision(s) = f(Identity, Authority, Consent, Threshold, Purpose, Scope, Lifecycle, Evidence).$$

Consequently, validation does not merely determine whether the final output is *ALLOW* or *DENY*; it also determines whether the underlying evidence is consistent with the decision. This is particularly important for a trust-aware framework because a correct decision without sufficient supporting evidence cannot provide strong assurance regarding how the decision was reached.

The relationship between the six algorithms can therefore be represented as

Algorithm 1 : Create Consent

Algorithm 2 : Verify Identity and Authority

Algorithm 3 : Establish Multi-Party Authorisation

Algorithm 4 : Evaluate Access Request

Algorithm 5 : Validate Temporal and Lifecycle State

Algorithm 6 : Validate the Complete Framework

Algorithm 6 therefore operates at the highest level of the proposed methodology. Algorithms 1–5 define the operational authorisation lifecycle, whereas Algorithm 6 evaluates whether the complete lifecycle behaves according to its intended security properties. This creates a closed methodological loop

$$Design \rightarrow Implementation \rightarrow Execution \rightarrow Observation \rightarrow Verification \rightarrow Validation$$

The resulting validation methodology provides empirical evidence that the proposed authorisation model is not merely conceptually defined but is operationally enforceable and testable under legitimate, invalid, and adversarial conditions.

Algorithm 6 Formal and Empirical Authorisation Validation

Require: Framework implementation F , validation scenarios $\mathcal{S}$, security properties $\mathcal{P}$

Ensure: Validation evidence and evaluation results

- 1: Define expected authorisation properties $\mathcal{P}$
 - 2: Define valid scenarios $\mathcal{S} * \text{valid}$
 - 3: Define negative scenarios $\mathcal{S} * \text{negative}$
 - 4: Define adversarial scenarios $\mathcal{S} * \text{adv}$
 - 5: **for** each scenario s in $\mathcal{S} * \text{valid} \cup \mathcal{S} * \text{negative} \cup \mathcal{S} * \text{adv}$ **do**
 - 6: Execute s using framework F
 - 7: Collect authorisation decision
 - 8: Collect identity, approval, policy, and audit evidence
 - 9: Compare observed decision with expected decision
 - 10: Record pass or failure result
 - 11: **end for**
 - 12: Evaluate soundness property
 - 13: Evaluate denial property
 - 14: Evaluate threshold correctness
 - 15: Evaluate policy-scope enforcement
 - 16: Evaluate audit consistency
 - 17: Analyse failures and limitations
 - 18: **return** Validation results
-

Typesetting: ' $\mathcal{S} * \text{valid}$ ' $\rightarrow$ $\mathcal{S}_{\text{valid}}$,
 $\mathcal{S}_{\text{negative}}$,
 $\mathcal{S}_{\text{adv}}$
(subscripts, no
asterisk) in lines
2–5.

6.6.3 Algorithm 6: Formal and Empirical Authorisation Validation

Algorithm 6 provides a structured method for evaluating the framework. It does not assume that successful execution of a consent workflow is sufficient evidence of security. Instead, it requires the system to demonstrate that invalid conditions produce appropriate denial decisions and that the recorded evidence is consistent with the decision.

The formal and empirical components are complementary. Formal reasoning defines what the framework should guarantee, while empirical testing examines whether the implementation satisfies those guarantees in representative operational scenarios. This combination is necessary because a system may be conceptually correct but incorrectly implemented, or may pass functional tests while failing under invalid or adversarial conditions.

6.7 Algorithms and the Research Objectives

The six algorithms correspond directly to the six research objectives and provide a progressive development structure for the proposed framework. Algorithm 1 establishes the consent representation, while Algorithm 2 verifies the identity and authority information contained in that representation. Algorithm 3 then establishes collective authorisation through independently verified approvals. Algorithm 4 evaluates whether a specific access request satisfies the consent policy before healthcare data are released.

The final two algorithms extend this foundational mechanism. Algorithm 5 introduces temporal and lifecycle validity, while Algorithm 6 provides formal and empirical assurance of the complete framework. This structure reflects the staged research design in which current stage establishes the foundational authorisation mechanisms and CA3 investigates their

dynamic validity, security assurance, and comprehensive practical effectiveness.

The overall trust-oriented authorisation process can therefore be summarised as Trust-worthy Access with 1) Identity Trust Authority Trust, 2) Collective Authorisation, 3) Policy Compliance, 4) Temporal and Lifecycle Trust. For the current stage implementation, the operational decision is based on

$$\text{Decision}(C, R) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R). \quad (69)$$

Repeat - delete;
cite Eq. (6)

The CA3 extension incorporates temporal and lifecycle conditions that

$$\text{Decision}(C, R, t) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (70)$$

Repeat - delete;
cite Eq. (27)

These equations demonstrate that trust is not provided by blockchain alone. Blockchain contributes integrity, tamper resistance, persistence, and auditability. DID and VC mechanisms contribute identity and authority evidence. Multi-party authorisation contributes collective decision-making. Policy evaluation contributes contextual compliance. Temporal and lifecycle controls contribute dynamic validity. The proposed framework integrates these mechanisms into a coherent authorisation process in which access is granted only when the required trust conditions are satisfied.

7 Current Progress Status

7.1 Progress of RO1: Trust-Centric Consent Model

Status: Completed

RO1 has been completed at the conceptual and prototype-design level.

The main contribution of RO1 is the transformation of consent from a static permission record into a structured authorisation object. Instead of storing only whether a patient has granted access, the consent object explicitly records the conditions that determine whether access should be permitted. The proposed representation is

$$C = (I, A, P, E). \quad (71)$$

Repeat - delete;
cite Eq. (7)

Identity information establishes the relevant participants. Authorisation requirements define who must approve the consent. Policy information specifies the purpose and permitted data scope. Authorisation evidence records the information required to demonstrate how the consent decision was established.

The model provides the foundation for the remaining objectives because the identity, multi-party approval, and policy mechanisms can all be evaluated against the same consent object.

The current result demonstrates that consent can be represented as an evaluable authorisation object rather than as a binary permission. This provides a conceptual basis for dynamic access decisions and allows subsequent authorisation conditions to be evaluated consistently.

7.2 Progress of RO2: Decentralised Identity and Authority

~~Status: Completed~~ → Status: Completed (prototype level; W3C VC verification in Stage 2)

RO2 has been completed at the conceptual and prototype level. The proposed framework explicitly separates identity authentication from authorisation authority that

$$\text{Identity} \neq \text{Authorisation}. \quad (72)$$

Repeat - delete; cite Eq. (1)

A decentralised identifier is used to establish the identity of a participant, while verifiable credentials provide evidence concerning the participant's role or authority. The identity verification condition is represented as

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u). \quad (73)$$

Repeat - delete; cite Eq. (8)

Successful identity verification therefore does not automatically grant access to healthcare information. Instead, identity and credential validity become trusted inputs to the subsequent authorisation process.

The current implementation demonstrates the separation between participant identity and authorisation authority. A valid healthcare participant identity can be verified independently from the question of whether that participant is authorised to access a particular patient's data.

Add evidence: 'EIP-712 approval signatures are verified by public-key recovery; a wrong guardian, wrong consent ID or missing signature is rejected (Table 10, T1).'

7.3 Progress of RO3: Trustworthy Multi-Party Authorisation

Status: Completed

RO3 has been completed at the conceptual and prototype level. The framework introduces threshold-based multi-party authorisation to prevent a single participant from unilaterally establishing sensitive healthcare data access.

Let A_v represent the set of independently verified authorisation participants and N represent the required approval threshold. The authorisation condition is

$$V_A(C) = \begin{cases} 1, & |A_v| \geq N, \\ 0, & |A_v| < N. \end{cases} \quad (74)$$

Repeat - delete; cite Eq. (9)

If the threshold is not satisfied,

$$|A_v| < N \longrightarrow \text{Decision}(C, R) = \text{DENY}. \quad (75)$$

Repeat - delete; cite Eq. (10)

This mechanism allows the framework to distinguish between insufficient and sufficient collective authorisation.

The prototype demonstrates that a consent object remains unable to establish valid authorisation until the required number of independently verified participants has approved it.

For example, where two approvals are required,

$$|A_v| = 2 \longrightarrow V_A(C) = 1, \quad (76)$$

Replace with: 'one approval leaves the consent pending; two approvals activate it (Eq. (25)-(26); Figure 14; Table 10, T3).'

whereas

$$|A_v| = 1 \longrightarrow V_A(C) = 0. \quad (77)$$

This provides preliminary evidence that the proposed framework can enforce collective rather than unilateral authorisation.

7.4 Progress of RO4: Policy-Aware Access Control

~~Status: In Progress~~ → Status: Completed (prototype level)

RO4 represents the next stage of the framework beyond identity and multi party approval. The objective is to ensure that an otherwise valid requester cannot access healthcare information outside the purpose and data scope authorised by the consent. The proposed policy predicate is

$$V_P(C, R) = \text{Policy}(C, R). \quad (78)$$

For example, if $S_C = \{\text{Observation}, \text{Medication}\}$, and the requester asks for $S_R = \{\text{Observation}, \text{Medication}\}$, the request should be rejected because $S_R \not\subseteq S_C$. The expected outcome is a policy-aware access control mechanism capable of evaluating purpose and data scope constraints before an access decision is issued. This objective will provide the final foundational component of the current stage trust oriented authorisation model.

OUT OF DATE - scope enforcement is implemented (check scope, ACCESS DENIED + audit). Also removes the equation that overflows the page. Replace with A89.1.

7.5 Progress of RO5: Temporal and Lifecycle Trust

~~Status: In Progress~~ → Status: Partially completed (prototype; formal lifecycle analysis in Stage 2)

RO5 is reserved primarily for next stage. The objective is to introduce temporal and lifecycle trust so that consent is not considered permanently valid after creation or approval. A future consent validity interval will be represented as $[t_s, t_e]$, with temporal validity defined as

$$V_T(C, t) = (t_s \leq t \leq t_e). \quad (79)$$

The consent lifecycle will also be extended to represent controlled transitions such as

~~Specification → Verification → Approval → Active → Expiration/Revocation.~~

The expected outcome is a lifecycle-aware consent mechanism capable of rejecting access after expiration or revocation and preventing unauthorised lifecycle transitions. This work will constitute a major component of next stage.

Contradicts 'In Progress'. Replace with: 'A first version of RO5 is already operational in HALAH v1.1 (Section 6.5.1); Stage 2 adds formal transition rules and adversarial evaluation.'

Repeat - delete; cite Eq. (15)

Repeat of Eq. (17) - delete.

7.6 Progress of RO6: Security Assurance and Validation

~~Status: Partially Completed (RQ1-RQ3)~~

RO6 is partially completed through the implementation and initial scenario-based validation of the HALAH prototype.

The current prototype provides a practical environment for evaluating the trust-oriented authorisation model using synthetic healthcare records. The system represents patients and healthcare participants using decentralised identities and provides mechanisms for consent creation, participant verification, multi-party approval, and access-control evaluation.

The current validation focuses primarily on RQ1, RQ2, and RQ3. Representative scenarios include valid identity verification, invalid identity or credential submission, insufficient multi-party approval, and successful completion of the required approval threshold. The central decision model can be formulated as

$$\text{Decision}(C, R) = \begin{cases} \text{ALLOW}, & V_I(u) \wedge V_A(C) \wedge V_P(C, R), \\ \text{DENY}, & \text{otherwise.} \end{cases} \quad (80)$$

Replace with: 'Partially completed (SRQ1-SRQ4; 16 automated tests passed, Table 10)'

Replace with: 'The current validation covers SRQ1-SRQ4 and first SRQ5 checks (Table 10).'

Repeat - delete; cite Eq. (6)

A89.1 - Replacement body of §7.4 Progress of RO4

Replaces 'RO4 represents the next stage of the framework ... current stage trust-oriented authorisation model.'
(also removes the overflowing equation)

RO4 has been implemented at prototype level. The Doctor interface (Figures 15–16) allows the requester to select only modules from the consented scope, and `check_scope()` independently enforces $S_R \subseteq S_C$ (Eq. (5)); a request outside the consented scope is refused with an ACCESS DENIED result that is written to the audit log together with the evaluated scope. The purpose predicate is currently evaluated against the set of permitted purposes {Treatment, Research, Emergency}; binding a purpose declared in each request to the consented purpose ($P_R \models P_C$) and routing data release through the full decision matrix are scheduled for Stage 2 (Section 6.4.1).

At the current stage, the experimental evidence primarily demonstrates the consistency between the implemented consent, identity, and multi-party authorisation mechanisms and their corresponding research questions.

The remaining security assurance and comprehensive empirical evaluation will be conducted in next stage. These activities will include policy-violation scenarios, temporal expiration, revocation, invalid lifecycle transitions, formal security properties, and broader experimental validation.

8 Publications Summary

The publication activities associated with this research are organised according to their current development status and their structural contribution to the thesis chapters and research questions.

Table 7: Summary of Research Outputs and Publication Plan

Research Output / Topic	Target Venue	Current Status	Thesis Alignment
Trust-Centric Consent Framework <i>Model architecture and multi-party authorisation policies</i>	Elsevier/IEEE	Almost Ready	Core architectural contribution; addresses RQ1-RQ4 (Chapters 3-4).
HALAH Prototype & Validation <i>Decentralised implementation and performance evaluation</i>	Systems / Security Conference	In Progress	Empirical validation platform; addresses implementation and evaluation (Chapter 5).
Formal Security & Lifecycle Analysis <i>Verification of temporal constraints and state transitions</i>	^{Specialised} Specialized Workshop / Journal	Planned	Next stage research extension; addresses formal security assurance (Chapter 6) .

The publication strategy is aligned with the progression of the research. The current stage work establishes the conceptual and technical foundation, while the next stage work will strengthen the framework through formal analysis and comprehensive empirical validation.

9 Research Plan

The research plan is divided into two major stages corresponding to current and next stage.

► INSERT A90.1 (red page after p.90)

Add \$7.7 Prototype Evidence (Figs 13–17, Tables 9–11) and \$7.8 Limitations – A90.1.

Replace with: '[name the target journal]'

'Almost Ready' → give a concrete status, e.g. 'Draft complete; submission planned [month] 2026'. Chapter numbers now match Tables 3–4.

Replace with: 'functional security evaluation'

Replace with: '(Chapter 5)'

A90.1 - New §7.7 Prototype Evidence and §7.8 Limitations

Insert at the end of §7 (after §7.6, before §8 Publications Summary).

7.7 Prototype Evidence (HALAH v1.1)

This section reports the evidence currently available from the HALAH prototype (repository commit 0a960ca, 22 September 2026). Figures 13–17 show the four role-specific views, Table 9 maps the framework components to these views, Table 10 summarises the automated test results and Table 11 lists the consent tokens anchored on the Ethereum Sepolia testnet.

The screenshot shows a web interface titled "Create Smart Consent Contract". At the top, there is a dark blue header with the text "History Access Link for Authorised Healthcare (Version 1)". Below this, the form is divided into several sections. On the left, there are three input fields: "Patient DID (Identity Pointer)" with the value "did:patient:fe621c76-a591-b7be-5668-b77f00240d82", "Authorised Doctor DID" with the value "did:hospital:001", and "Data Access Scope (EMR Modules)" with a dropdown menu showing "Choose options". On the right, there is a section for "Designated Guardian DIDs (Comma Separated)" with the value "did:parent A,did:parent B". Below this, there is a section for "Contract Temporal Validity" with two input fields: "Start Time (YYYY-MM-DD HH:MM:SS)" with the value "2026-09-19 03:07:54" and "Expiry Time (YYYY-MM-DD HH:MM:SS)" with the value "2026-12-31 23:59:59". At the bottom left, there is a blue button labeled "Initial Consent".

Figure 13: Patient view - creating a consent: patient DID, authorised doctor DID, EMR-module scope, guardian DIDs and validity interval (Algorithm 1). An expiry time not later than the start time is rejected.

The screenshot shows a web interface titled "Guardian Cryptographic Approval". At the top, there is a dark blue header with the text "History Access Link for Authorised Healthcare (Version 1)". Below this, the form is divided into several sections. On the left, there is a section for "Enter Target Consent ID" with the value "5ef4f807-fa1c-4dec-99d9-546494fb1e74". Below this, there is a blue box with the text "Found active transaction for Patient: did:patient:fe621c76-a591-b7be-5668-b77f00240d82". On the right, there is a section for "Select Your Guardian DID Identity" with a dropdown menu showing "did:parent B". At the bottom left, there is a blue button labeled "Sign Consent via VC".

Figure 14: Guardian view - the guardian selects their DID and approves the consent; the approval counts only after EIP-712 signature verification (Algorithm 3).

RED INSERT PAGE - after original page 90 (continued, part 2)

PATIENT CONSENT MANAGEMENT PLATFORM

History Access Link for Authorised Healthcare (Version 1)

Secure Patient Data Access

Enter Authorised Consent ID

5ef4f807-fa1c-4dec-99d9-546494fb1e74

Consent Information

Patient	Consent ID	Purpose
did:patient:fe621c76-a...	5ef4f807-fa1c-4dec-99...	Treatment

Consent State: ACTIVE

Authorised Data Scope

The following EMR modules are authorised under the patient's consent:

```
[
  0 : "Medication"
  1 : "Procedure"
]
```

Figure 15: Doctor view - consent state (ACTIVE), purpose and authorised scope {Medication, Procedure}.

Request Patient Data

Select Request Scope

Medication x Procedure x

Requested Modules: Medication, Procedure

Execute Zero-Knowledge Access

Cryptographic Verification Successful — Access Granted.

Authorised Medical Records

Medical Module: MEDICATION

	START	STOP	PATIENT	PAYER	ENCOUNTER	CODE	DES
0	2016-12-17T13:57:52Z	2016-12-30T13:57:52Z	fe621c76-a591-b7be-5668-b77f00240d82	df166300-5a78-3502-a46a-832842197811	fe621c76-a591-b7be-ac26-b3481f6a2205	313782	Ace
1	2016-12-23T22:47:14Z	2017-12-18T22:47:14Z	fe621c76-a591-b7be-5668-b77f00240d82	df166300-5a78-3502-a46a-832842197811	fe621c76-a591-b7be-e5a3-71cf8c4a3131	748856	[24
2	2017-06-06T18:52:07Z	2017-06-24T18:52:07Z	fe621c76-a591-b7be-5668-b77f00240d82	df166300-5a78-3502-a46a-832842197811	fe621c76-a591-b7be-aea3-79224dc44682	313782	Ace
3	2018-02-18T22:47:14Z	2018-03-08T22:47:14Z	fe621c76-a591-b7be-5668-b77f00240d82	df166300-5a78-3502-a46a-832842197811	fe621c76-a591-b7be-ad48-efe9c64f03be	310965	Ibu
4	2019-12-08T22:47:14Z	2020-12-02T22:47:14Z	fe621c76-a591-b7be-5668-b77f00240d82	df166300-5a78-3502-a46a-832842197811	fe621c76-a591-b7be-c8ba-72a3b7e01a06	748879	[21
5	2020-03-08T01:19:10Z	2020-03-08T01:19:10Z	fe621c76-a591-b7be-5668-b77f00240d82	df166300-5a78-3502-a46a-832842197811	fe621c76-a591-b7be-1eea-d13a8ddd84a7	1535362	sod

Figure 16: Doctor view - requested modules lie within the consented scope; access is granted and only the authorised Synthea modules are returned (Algorithm 4).

RED INSERT PAGE - after original page 90 (continued, part 3)

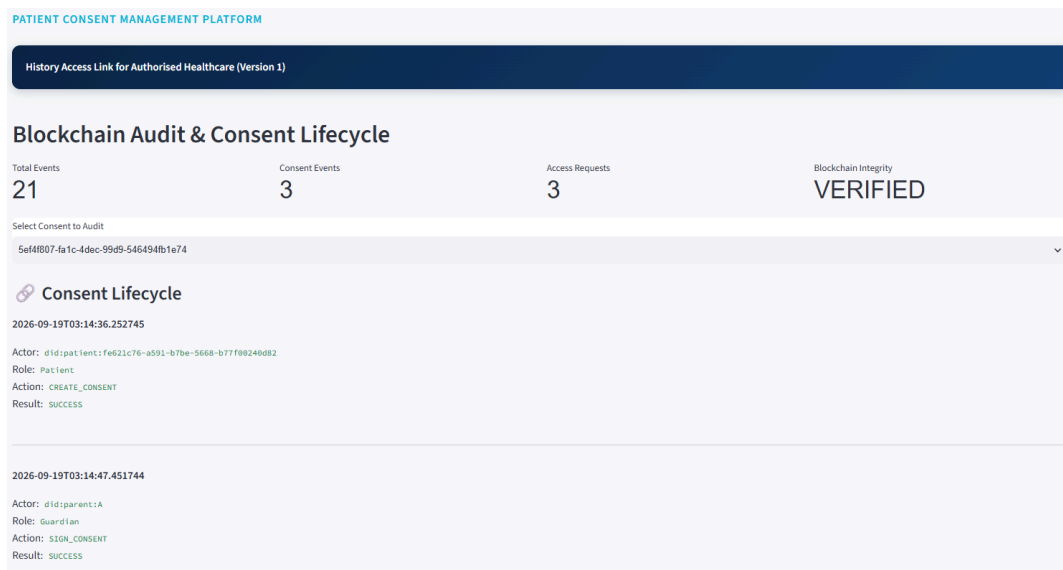


Figure 17: Auditor view - lifecycle events (CREATE_CONSENT, SIGN_CONSENT, ...) for a selected consent.

Author action: these screenshots were captured from v1.0. Retake them from v1.1, where the button 'Execute Zero-Knowledge Access' is relabelled as a ZK placeholder, the guardian step shows the EIP-712 verification result, and the Doctor view shows the VI/VA/VP/VT/VL decision matrix, so that the figures match the current code.

Table 9: Correspondence between framework components and HALAH subsystems

Framework component	Implementation subsystem	Main function
Consent Object Construction	Create Smart Consent Contract	Defines patient, authorised doctor, data scope, guardians and temporal validity
Identity & Authorisation	Guardian Cryptographic Approval	Verifies guardian identities and records the required signatures
Multi-party Consent	Guardian Cryptographic Approval	Implements the 2-of-2 approval condition
Consent Activation	Guardian Cryptographic Approval	Generates the SBT and changes the consent to fully activated
Consent-State Management	Secure Patient Data Access	Checks whether the consent is ACTIVE
Scope Enforcement	Secure Patient Data Access	Restricts access to authorised EMR modules
Cryptographic Access Control	Secure Patient Data Access	Verifies the access request before granting data
Healthcare Data Access	Secure Patient Data Access	Provides authorised Medication and Procedure records
Lifecycle Traceability	Blockchain Audit & Consent Lifecycle	Reconstructs the chronological consent process
Accountability	Detailed Audit Records	Provides event-level evidence
Ledger Integrity	Complete Audit Ledger (SQLite + Sepolia anchors)	Provides the recorded transaction history

RED INSERT PAGE - after original page 90 (continued, part 4)**Table 10: Automated test results (pytest 9.1.1, Python 3.11, run 28 September 2026): 16 passed, 2 skipped, 0 failed**

ID	Scenario	Condition tested → expected outcome	Predicate	Observed
T1	EIP-712 guardian approval	Valid signature accepted; wrong guardian, wrong consent ID and missing signature rejected	VI	Pass
T2	Decision matrix	All conditions true → ALLOW; wrong jurisdiction → VL fails; expired → VT fails; revoked → VA fails; purpose 'Marketing' → VP fails; forged signature → VI fails	VI-VL	Pass
T3	End-to-end lifecycle (chain mocked)	Create → PENDING_SIGNATURE; 2 signatures + mint → ACTIVE; revoke → REVOKED	VA, VL	Pass
T4	Revocation state	An ACTIVE consent becomes REVOKED when revoked	VL	Pass
T5	v3 contract routing	v3 mint carries jurisdiction 'AU' and notBefore < expiry	VT	Pass
T6	Persistence (3 tests)	Consent, revocation and audit events survive a restart	E	Pass
T7	Audit honesty (2 tests)	Off-chain events carry no fake transaction hash; on-chain events keep the real one	E	Pass
T8	Configuration and honesty (6 tests)	Deterministic DID→address; not configured without env; ABI functions present; no fake placeholders; honest UI labels; ZK placeholder labelled	–	Pass
T9	Groth16 ZK (2 tests)	Real proof round-trip and tamper rejection; expired consent cannot be proven	VT	Skipped (needs zk/build_zk.sh)

These are functional unit and integration tests in which the blockchain is mocked. They provide initial evidence for SRQ1–SRQ4 and for the first SRQ5 checks, but they are not yet the complete valid, negative and adversarial scenario set of Algorithm 6. Negative cases still to be added in Stage 2 include insufficient approvals at the data-release gate, a duplicate approval attempt, an out-of-scope request submitted directly to the service API, and a request with a mismatched declared purpose.

Table 11: Consent SBTs anchored on Ethereum Sepolia (chain ID 11155111), contract ConsentSBTv2 0xb0dA0440Abd6bd74bE0aebE226D593492124A6e7

Token	Block	Transaction hash (evidence/onchain_mints_2026-09-21.txt)
#1	11750525	0x5fbf45ee43f180369161db5b2773593c8fab091bdc50e1b2054901c0de105367
#2	11750632	0x1b964596cdef2c67af345f566ea501a5be609a8e917097596b241e56fc522907
#3	11750702	0x6812ab1608bd475891d5a8c2007c6955e7225c06c81a649bd1735aabef251121
#4	11750722	0xa4c4156bd943578a6f8f29a536eb39e1acce238a86c5a4ad00d85eff497e014a

The holder of token #4 equals the address deterministically derived from the patient DID 'did:patient:demo', which demonstrates the DID-to-address binding used by the prototype.

7.8 Limitations and Threats to Validity

- Guardian signing keys are derived from the DID for demonstration; production would use each guardian's own wallet.
- DID verification is syntactic and no W3C Verifiable Credential is yet issued or verified (Stage 2).
- The threshold is $N = |G|$ (all guardians); configurable k-of-n thresholds are not yet supported.
- Purpose is checked against a fixed list; per-request purpose binding is Stage 2.
- Data release uses authorize() (state, proof and scope) rather than the full decision matrix evaluate_allow().
- Healthcare data are synthetic (Synthea [38]); the blockchain is a public testnet, not a production network.
- The Groth16 circuit proves consent validity only and uses a development-only trusted setup.
- Evaluation to date is functional (18 automated tests); no performance or adversarial measurements have yet been made.

9.1 Current Stage: Completed and Current Work

The current stage focuses on establishing the foundational trust-oriented authorisation framework. The main activities are the development of the trust-centric consent model, decentralised identity and authority verification, multi-party authorisation, and policy-aware access control.

~~The progression is RO1, RO2, RO3 and then RO4, in which RO1, RO2, and RO3 have been implemented and initially validated through the HALAH prototype. RO4 represents the current transition towards policy aware access control.~~

Replace with:
'RO1-RO4 have been implemented at prototype level and initially validated through the HALAH prototype (Section 7.7); a first version of RO5 (expiry and revocation) is already operational.'

9.2 Next Stage: Planned Work

The next stage will build upon the foundational trust-oriented authorisation framework established during current stage and extend the research towards dynamic consent governance, formal security assurance, and comprehensive empirical validation. While current stage focuses on establishing the core mechanisms required to construct a trustworthy authorisation decision, next stage will investigate whether this trust can be maintained over time, formally justified, and reliably demonstrated in practical healthcare data-sharing scenarios.

The first major focus of ^{next stage is} ~~next stage is~~ the introduction of *temporal and lifecycle trust*. In the current framework, identity, multi-party approval, and policy compliance provide the principal conditions for an authorisation decision. However, authorisation is not necessarily permanent. A consent decision may become invalid because its validity period has expired, because the patient or an authorised participant has revoked the consent, or because the consent has transitioned into a state in which access should no longer be permitted. Next stage will therefore extend the consent model to explicitly represent temporal constraints and controlled lifecycle transitions. This extension will allow the framework to distinguish between a consent that was previously valid and a consent that remains valid at the time of a particular access request.

The second focus is *formal security assurance*. The current stage framework establishes the conceptual relationship between identity verification, collective authorisation, and policy enforcement. ~~next stage will investigate these~~ relationships more rigorously by defining the security properties that the framework is expected to satisfy. The analysis will consider conditions such as invalid identities, insufficient authorisation, policy violations, expired consent, revoked consent, and unauthorised lifecycle transitions. The purpose of this work is not merely to demonstrate that the prototype works under normal conditions, but to establish explicit security properties and determine whether the proposed authorisation model provides the expected protection when relevant security conditions are violated.

Replace with:
'The next stage will investigate these'

The third focus is *comprehensive empirical validation*. The HALAH prototype provides the experimental environment for evaluating the proposed framework using synthetic healthcare data and representative multi-party consent scenarios. Next stage will extend the current prototype-based evaluation to include both successful and adversarial access requests. The experiments will examine whether the implementation consistently produces an *ALLOW* decision only when the required trust conditions are satisfied and produces a *DENY* decision when one or more required conditions are violated. Particular attention will be given to the relationship between the formal security model and the observed behaviour of the implemented system. The major next stage activities and their expected outcomes are summarised in Table 8.

An important analytical objective of next stage is to examine the relationship between

Table 8: Next Stage Research Activities, Methodological Focus, and Expected Outcomes

Research Focus	Planned Activities	Expected Outcome
Temporal and Lifecycle Trust (<i>Dynamic Consent States</i>)	Extend the consent model to incorporate validity periods, dynamic expiration, immediate revocation, and controlled lifecycle transitions. Evaluate access decisions under varying temporal and consent-state constraints.	A robust, dynamic consent management mechanism capable of validating whether an authorisation remains active at the precise point of access.
Formal Security Assurance (<i>Properties & Verification</i>)	Formally define critical security properties and analyse system behaviour under adverse conditions, including invalid identities, insufficient multi-party approvals, policy violations, expired/revoked states, and illegal transitions.	A rigorous formal security model and verification proof establishing explicit security guarantees for the trust-oriented authorisation framework.
Comprehensive Empirical Validation (<i>HALAH Prototype Scenarios</i>)	Scale and extend HALAH prototype experiments using representative positive and negative healthcare data-sharing scenarios. Measure and compare observed system runtime performance, overhead, and enforcement accuracy.	Empirical evidence and benchmark datasets demonstrating that the implementation consistently and efficiently enforces the proposed authorisation model.
Integrated Framework Evaluation (<i>Synthesis & End-to-End</i>)	Integrate temporal, lifecycle, formal verification, and empirical modules into a unified, cohesive framework. Evaluate cross-component interactions, scalability bottlenecks, and end-to-end feasibility in real-world settings.	A fully integrated, validated Trust Computing framework providing secure, multi-party patient consent and decentralised healthcare data sharing.

the different forms of trust established throughout the framework. Temporal validity, for example, should not be treated as an independent access-control feature. Instead, it should act as an additional condition on an already established authorisation relationship. Similarly, revocation should invalidate a previously established consent rather than merely create a new record indicating that the consent has changed. This perspective allows the research to investigate trust as a dynamic property rather than as a one-time outcome of authentication or approval.

The complete authorisation model developed across current stage and next stage will therefore be evaluated as a conjunction of independently verifiable conditions. Conceptually, the final decision can be expressed as

$$Decision(C, R) = ALLOW \quad (81)$$

only when the identity and authority of the requester are valid, the required multi-party authorisation has been established, the requested operation satisfies the consent policy, and the consent remains valid according to its temporal and lifecycle state. If any required condition is violated, the framework should produce a denial decision and preserve sufficient evidence to explain the reason for that decision.

From a research perspective, this represents an important transition from *static consent management* to *dynamic trustworthy authorisation*. The objective is not to add a collection of independent security mechanisms, but to investigate how these mechanisms jointly contribute to the establishment, maintenance, and verification of trust throughout the consent lifecycle.

By the completion of next stage, the research is expected to provide three complementary forms of contribution. First, the research will provide a conceptual Trust Computing model that explains how trustworthy multi-party consent can be established and maintained. Second, it will provide a technical implementation through the HALAH prototype demonstrating how the proposed trust conditions can be enforced in a decentralised healthcare environment. Third, it will provide formal and empirical evidence concerning the security and practical effectiveness of the proposed framework.

Consequently, ^{next stage will}~~next stage will~~ complete the transition from the foundational authorisation mechanisms established in current stage to a dynamically managed, formally reasoned, and empirically validated Trust Computing framework. The final contribution will be assessed not simply by whether consent can be recorded or whether access can be granted, but by whether the system can provide a defensible basis for determining *why* an access decision should be trusted and *when* that trust should no longer apply.

References

- [1] Abdullah Al Mamun, Sami Azam, and Clementine Gritti. Blockchain-based electronic health records management: a comprehensive review and future research direction. *IEEE Access*, 10:5768–5789, 2022.
- [2] J Andrew, Deva Priya Isravel, K Martin Sagayam, Bharat Bhushan, Yuichi Sei, and Jennifer Eunice. Blockchain for healthcare systems: Architecture, security challenges, trends and future directions. *Journal of Network and Computer Applications*, 215:103633, 2023.

- [3] Mohammad Salar Arbabi, Chhagan Lal, Narasimha Raghavan Veeraragavan, Dusica Mar-
ijan, Jan F Nygård, and Roman Vitenberg. A survey on blockchain for healthcare:
Challenges, benefits, and future directions. ~~IEEE communications surveys & tutorials~~,
25(1):386–424, 2022.
- [4] Haotian Deng, Jinwen Liang, Chuan Zhang, Ximeng Liu, Liehuang Zhu, and Song Guo.
Futuredid: A fully decentralized identity system with multi-party verification. *IEEE
Transactions on Computers*, 73(8):2051–2065, 2024.
- [5] Andrea Flamini, Giada Sciarretta, Mario Scuro, Amir Sharif, Alessandro Tomasi, and
Silvio Ranise. On cryptographic mechanisms for the selective disclosure of verifiable
credentials. *Journal of Information Security and Applications*, 83:103789, 2024.
- [6] Abdul Ghafoor, Iraklis Symeonidis, Anna Rydberg, Cecilia Lindahl, and Abdul Qadus
Abbasi. Towards empowering stakeholders through decentralized trust and secure live-
stock data sharing. *Cryptography*, 9(3):52, 2025.
- [7] Pranto Kumar Ghosh, Arindom Chakraborty, Mehedi Hasan, Khalid Rashid, and Ab-
dul Hasib Siddique. Blockchain application in healthcare systems: a review. *Systems*,
11(1):38, 2023.
- [8] Remy Hellstern, Daniel C Park, Victoria Lemieux, and Guldana Salimjan. Leveraging
blockchain-based archival solutions for sensitive documentation: A xinjiang case study.
Digital Society, 1(1):4, 2022.
- [9] Ateya Megahed Ibrahim, Hassanat Ramadan Abdel-Aziz, Heba Ali Hamed Mohamed,
Donia Elsaid Fathi Zaghamir, Nadia Mohamed Ibrahim Wahba, Ghada A Hassan,
Mostafa Shaban, Mohammad El-Nablaway, Ohoud Naif Aldughmi, and Taghreed Hussien
Aboelola. Balancing confidentiality and care coordination: challenges in patient privacy.
~~BMC nursing~~ ^{BMC Nursing}, 23(1):564, 2024.
- [10] Vitor Jesus and Harshvardhan J Pandit. Consent receipts for a usable and auditable web
of personal data. ~~IEEE Access~~ ^{IEEE Access}, 10:28545–28563, 2022.
- [11] Rong Jiang, Xue Chen, Yimin Yu, Ying Zhang, and Weiping Ding. Risk and ucon-based
access control model for healthcare big data. *Journal of Big Data*, 10(1):104, 2023.
- [12] Katya Kaplow, Max Downey, Darren Stewart, Allan B Massie, Jennifer D Motter, Lauren
Taylor, John Massarelli, Taylor Matalon, Carolyn Sidoti, Macey L Levan, et al. Data
professionals’ attitudes on data privacy, sharing, and consent in healthcare and research.
~~Digital health~~ ^{Digital Health}, 10:20552076241290964, 2024.
- [13] Muhammad Irfan Khalid, Mansoor Ahmed, Markus Helfert, and Jungsuk Kim. Privacy-
first paradigm for dynamic consent management systems: empowering data subjects
through decentralized data controllers and privacy-preserving techniques. *Electronics*,
12(24):4973, 2023.
- [14] Alexander Kharlamov, Roland Hohmann, and Glann Parry. Data sharing decisions: per-
ceptions and intentions in healthcare. *Strategic Change*, 32(6):223–237, 2023.

- [15] Behnam Khayer, Siamak Mirzaei, Hooman Alavizadeh, and Ahmad Salehi Shahraki. Blockchain for secure iot: A review of identity management, access control, and trust mechanisms. *IoT*, 6(4):65, 2025.
- [16] Chalima Dimitra Nassar Kyriakidou, Athanasia Maria Papathanasiou, and George C Polyzos. Decentralized identity with applications to security and privacy for the internet of things. *Computer Networks and Communications*, pages 244–271, 2023.
- [17] Lanlan Li, Charles Z Liu, Kejia Huang, Ruiyi Deng, Majed Abdullah Alrowaily, Mansoor Alghamdi, Ibrahim S Alkhazi, and Malek Alrashidi. Trust-aware environmental state consensus for smart agriculture with tee-enabled sensing and byzantine-resilient blockchain coordination. *Sensors*, 26(14):4577, 2026.
- [18] Lanlan Li, Charles Z Liu, and Sanjeeb Shrestha. Analytical entropy approach for measuring blockchain immutability and tamper-resilient trust. *Entropy*, 28(6):690, 2026.
- [19] Richard K Lomotey, Sandra Kumi, and Ralph Deters. Data trusts as a service: Providing a platform for multi-party data sharing. *International Journal of Information Management Data Insights*, 2(1):100075, 2022.
- [20] Carlo Mazzocca, Abbas Acar, Selcuk Uluagac, Rebecca Montanari, Paolo Bellavista, and Mauro Conti. A survey on decentralized identifiers and verifiable credentials. *IEEE Communications Surveys & Tutorials*, 2025.
- [21] Andrei McCall. Privacy-preserving interoperability in healthcare data ecosystems: balancing data sharing with individual autonomy. *IEEE J. Biomed. Health Inform.*, 28(3):1234–1245, 2024.
- [22] Roy McClelland and Colin M Harper. Information privacy in healthcare—the vital role of informed consent. ~~*European journal of health law*~~, 30(4):469–480, 2022.
- [23] Jämes Ménétrey, Christian Göttel, Anum Khurshid, Marcelo Pasin, Pascal Felber, Valerio Schiavoni, and Shahid Raza. Attestation mechanisms for trusted execution environments demystified. In *IFIP International Conference on Distributed Applications and Interoperable Systems*, pages 95–113. Springer, 2022.
- [24] Minal R Narkhede, Nilesh I Wankhede, and Akanksha M Kamble. Enhancing patient autonomy in data ownership: privacy models and consent frameworks for healthcare. *Journal of Digital Health*, pages 1–23, 2025.
- [25] Aleena Nazir, Mubashir Husain Rehmani, Bernard Butler, and Donna O’Shea. Access control in healthcare iot: A comprehensive survey. *Engineering Reports*, 8(4):e70766, 2026.
- [26] Thanh Linh Nguyen, Lam Nguyen, Thong Hoang, Dilum Bandara, Qin Wang, Qinghua Lu, Xiwei Xu, Liming Zhu, and Shiping Chen. Blockchain-empowered trustworthy data sharing: Fundamentals, applications, and challenges. *ACM Computing Surveys*, 57(8):1–36, 2025.

[16] is a book chapter – justified in A12.1.

[21] VERIFY: no IEEE JBHI record found; other papers cite it only as 'McCall, A. (2024)' with no venue, and the pages 1234–1245 look like a placeholder. Confirm the DOI or replace.

Replace with: 'European Journal of Health Law'

- [27] Rohini Poolat Parameswarath, Prosanta Gope, and Biplab Sikdar. User-empowered privacy-preserving authentication protocol for electric vehicle charging based on decentralized identity and verifiable credential. *ACM Transactions on Management Information Systems (TMIS)*, 13(4):1–21, 2022.
- [28] Ahmed M Tawfik, Ayman Al-Ahwal, Adly S Tag Eldien, and Hala H Zayed. Blockchain-based access control and privacy preservation in healthcare: a comprehensive survey. *Cluster Computing*, 28(8):529, 2025.
- [29] Leonidas Theodorakopoulos, Alexandra Theodoropoulou, and Constantinos Halkiopoulos. Enhancing decentralized decision-making with big data and blockchain technology: A comprehensive review. *Applied Sciences*, 14(16):7007, 2024.
- [30] Mohammad Nawab Turan, Irshad Ahmed Hashimzai, and Mohammad Qaseem Qiam. A blockchain-based framework for secure and transparent environmental data sharing in smart cities: Enhancing trust, integrity, and interoperability in urban sustainability systems. *Nata Palembang: Journal of Environmental Engineering Innovations*, 2(2):70–79, 2025.
- [31] Emily C Webber, David Brick, James P Scibilia, Peter Dehnel, Council on Clinical Information Technology, et al. Electronic communication of the health record and information ~~with pediatric patients and their guardians. 2022.~~
- [32] Hongjian Yin, Yiming Zhao, Lei Zhang, Baojun Qiao, Wenbo Chen, and Huaqing Wang. Attribute-based searchable encryption with decentralized key management for healthcare data sharing. ~~*Journal of systems architecture*~~, 148:103081, 2024.
- [33] Jie Yin, Yang Xiao, Qian Chen, Xuefeng Liu, Qingqi Pei, Jianying Zhou, et al. Dp-did: A dynamic and proactive decentralized identity system. *IEEE Transactions on Information Forensics and Security*, pages 4999–5014, 2025.

[31] Correct entry (PubMed PMID 31209162): '... with Pediatric Patients and Their Guardians,' *Pediatrics*, vol. 144, no. 1, e20191359, 2019. DOI: 10.1542/peds.2019-1359

Replace with: 'Journal of Systems Architecture'

Add new references [34]–[42] – A96.1.

► INSERT A96.1 (red page after p.96)

A96.1 - New references [34]-[42]

Append to the reference list (IEEE numeric style, as used in the report).

[34] Privacy Act 1988 (Cth), incl. Schedule 1 – Australian Privacy Principles. Federal Register of Legislation, Australian Government.

[35] My Health Records Act 2012 (Cth). Federal Register of Legislation, Australian Government.

[36] Healthcare Identifiers Act 2010 (Cth). Federal Register of Legislation, Australian Government.

[37] M. J. Page, J. E. McKenzie, P. M. Bossuyt, et al., "The PRISMA 2020 statement: an updated guideline for reporting systematic reviews," *BMJ*, vol. 372, n71, 2021, doi:10.1136/bmj.n71.

[38] J. Walonoski, M. Kramer, J. Nichols, et al., "Synthea: An approach, method, and software mechanism for generating synthetic patients and the synthetic electronic health care record," *Journal of the American Medical Informatics Association*, vol. 25, no. 3, pp. 230–238, 2018, doi:10.1093/jamia/ocx079.

[39] R. Bloemen, L. Logvinov and J. Evans, "EIP-712: Typed structured data hashing and signing," *Ethereum Improvement Proposals*, 2017. [Online]. Available: <https://eips.ethereum.org/EIPS/eip-712>

[40] "ERC-5484: Consensual Soulbound Tokens," *Ethereum Improvement Proposals*, 2022. [Online]. Available: <https://eips.ethereum.org/EIPS/eip-5484>

[41] W3C, "Decentralized Identifiers (DIDs) v1.0," *W3C Recommendation*, 2022. [Online]. Available: <https://www.w3.org/TR/did-core/>

[42] W3C, "Verifiable Credentials Data Model v2.0," *W3C Recommendation*, 2025. [Online]. Available: <https://www.w3.org/TR/vc-data-model-2.0/>

Also correct existing entries as marked on pp. 94–96: [3], [9], [10], [12], [22], [32] capitalisation; [31] year/venue; [21] verify venue. Cite [34]–[36] in A5.1, [37] in A9.1 and Fig. 2, [38] in §3.3.6, [39]–[42] in A56.1/A61.1.